
BSI Datenschutz++ Namespace Referenzen

Sascha Dierkes



Contents

Namespace Einträge im BSI Grundschutz++	21
Disclaimer	22
Lizenz	22
Namespace: action_words	23
Eintrag: aktivieren	23
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	23
BSI/Grundschutz/Quellkataloge/Kernel	25
Eintrag: anhören	27
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	27
BSI/Grundschutz/Quellkataloge/Kernel	28
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	28
Eintrag: anweisen	28
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	28
BSI/Grundschutz/Quellkataloge/Kernel	29
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	29
BSI/Grundschutz/Quellkataloge/Risikomanagement	29
Eintrag: ausführen	29
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	29
BSI/Grundschutz/Quellkataloge/Kernel	30
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	31
Eintrag: authentifizieren	32
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	32
BSI/Grundschutz/Quellkataloge/Kernel	32
Eintrag: autorisieren	33
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	33
BSI/Grundschutz/Quellkataloge/Kernel	33
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	34
BSI/Grundschutz/Quellkataloge/Risikomanagement	34
Eintrag: blockieren	34
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	34
BSI/Grundschutz/Quellkataloge/Kernel	35
Eintrag: deaktivieren	36
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	36
BSI/Grundschutz/Quellkataloge/Kernel	36
Eintrag: dokumentieren	37
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	37

BSI/Grundschutz/Quellkataloge/Kernel	40
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	42
Eintrag: einschränken	43
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	43
BSI/Grundschutz/Quellkataloge/Kernel	44
Eintrag: festlegen	46
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	46
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	47
BSI/Grundschutz/Quellkataloge/Risikomanagement	48
Eintrag: informieren	48
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	48
BSI/Grundschutz/Quellkataloge/Kernel	48
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	49
Eintrag: installieren	49
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	49
BSI/Grundschutz/Quellkataloge/Kernel	51
Eintrag: löschen	52
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	52
BSI/Grundschutz/Quellkataloge/Kernel	53
Eintrag: platzieren	53
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	53
BSI/Grundschutz/Quellkataloge/Kernel	53
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	54
Eintrag: protokollieren	54
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	54
BSI/Grundschutz/Quellkataloge/Kernel	55
Eintrag: sensibilisieren	55
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	55
BSI/Grundschutz/Quellkataloge/Kernel	57
Eintrag: testen	59
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	59
BSI/Grundschutz/Quellkataloge/Kernel	60
Eintrag: überprüfen	61
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	61
BSI/Grundschutz/Quellkataloge/Kernel	63
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	64
Eintrag: überwachen	65
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	65

BSI/Grundschutz/Quellkataloge/Kernel	66
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	66
Eintrag: untersagen	67
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	67
BSI/Grundschutz/Quellkataloge/Kernel	67
Eintrag: verankern	68
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	68
BSI/Grundschutz/Quellkataloge/Kernel	71
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	74
BSI/Grundschutz/Quellkataloge/Risikomanagement	75
Eintrag: vereinbaren	75
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	75
BSI/Grundschutz/Quellkataloge/Kernel	77
Eintrag: verschlüsseln	78
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	78
BSI/Grundschutz/Quellkataloge/Kernel	79
Eintrag: zuweisen	79
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	79
BSI/Grundschutz/Quellkataloge/Kernel	80
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	81
Namespace: documentation_guidelines	82
Eintrag: ???	82
Eintrag: Abnahmeprotokoll	82
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	82
BSI/Grundschutz/Quellkataloge/Kernel	82
Eintrag: Arbeitsanweisung	82
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	82
BSI/Grundschutz/Quellkataloge/Kernel	84
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	86
Eintrag: Arbeitsvertrag	86
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	86
BSI/Grundschutz/Quellkataloge/Kernel	86
Eintrag: Audit Log	86
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	86
BSI/Grundschutz/Quellkataloge/Kernel	87
Eintrag: Auditbericht	87
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	87
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	88

Eintrag: Auslagerungsregister	88
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	88
BSI/Grundschatz/Quellkataloge/Kernel	88
Eintrag: BC-Leitlinie	88
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	88
BSI/Grundschatz/Quellkataloge/Kernel	88
Eintrag: Behandlung von Sicherheitsvorfällen	89
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	89
BSI/Grundschatz/Quellkataloge/Kernel	89
Eintrag: Bereinigter Netzplan	89
Eintrag: Betriebshandbuch	90
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	90
BSI/Grundschatz/Quellkataloge/Kernel	90
Eintrag: Codehistorie	91
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	91
BSI/Grundschatz/Quellkataloge/Kernel	91
Eintrag: Compliance-Verpflichtungen	91
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	91
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	91
Eintrag: Datensicherungskonzept	91
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	91
BSI/Grundschatz/Quellkataloge/Kernel	92
Eintrag: Detektionskonzept	93
Eintrag: Entwicklungsdokumentation	93
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	93
BSI/Grundschatz/Quellkataloge/Kernel	93
Eintrag: Ergebnisprotokoll	93
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	93
BSI/Grundschatz/Quellkataloge/Kernel	94
Eintrag: Firewallregeln	94
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	94
BSI/Grundschatz/Quellkataloge/Kernel	94
Eintrag: Freigabeplan	95
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	95
BSI/Grundschatz/Quellkataloge/Kernel	95
Eintrag: Freigegebene Ausnahmegenehmigung	96
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	96
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	96

Eintrag: Gebäudedokumentation	96
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	96
BSI/Grundschutz/Quellkataloge/Kernel	97
Eintrag: Geschäftsprozesse	99
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	99
BSI/Grundschutz/Quellkataloge/Kernel	99
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	99
Eintrag: Geschäftsverteilungsplan	99
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	99
BSI/Grundschutz/Quellkataloge/Kernel	100
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	101
Eintrag: Informationssicherheitsleitlinie	101
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	101
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	101
Eintrag: Informationssicherheitsstrategie	101
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	101
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	101
Eintrag: Informationsverbund	101
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	101
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	101
Eintrag: Inventar Anwendungen	102
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	102
BSI/Grundschutz/Quellkataloge/Kernel	102
Eintrag: Inventar Berechtigungen	102
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	102
BSI/Grundschutz/Quellkataloge/Kernel	103
Eintrag: Inventar Berechtigungssysteme	103
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	103
BSI/Grundschutz/Quellkataloge/Kernel	103
Eintrag: Inventar Informationen	103
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	103
BSI/Grundschutz/Quellkataloge/Kernel	104
Eintrag: Inventar IT-Systeme	104
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	104
BSI/Grundschutz/Quellkataloge/Kernel	104
Eintrag: Inventar Standorte	104
Eintrag: ISMS-Regelwerk	104
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	104

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	104
Eintrag: IT-Betriebskonzept	104
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	104
BSI/Grundschutz/Quellkataloge/Kernel	107
Eintrag: Konfigurationshistorie	110
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	110
BSI/Grundschutz/Quellkataloge/Kernel	115
Eintrag: Leistungsbeschreibung	120
Eintrag: Leitlinie zur Informationssicherheit	120
Eintrag: Leitungsentscheidung	120
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	120
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	120
Eintrag: Liste der Hersteller und Dienstleister	120
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	120
BSI/Grundschutz/Quellkataloge/Kernel	121
Eintrag: Liste der Verpflichtungen	121
Eintrag: Managementbericht	121
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	121
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	121
Eintrag: Netzplan	122
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	122
BSI/Grundschutz/Quellkataloge/Kernel	122
Eintrag: Notfallhandbuch	123
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	123
BSI/Grundschutz/Quellkataloge/Kernel	123
Eintrag: Nutzungsbedingungen	124
Eintrag: Outsourcing-Strategie	124
Eintrag: Prozess Beschaffung	124
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	124
BSI/Grundschutz/Quellkataloge/Kernel	124
Eintrag: Prozess Dienstleistersteuerung	125
Eintrag: Prozess Gebäudemanagement	125
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	125
BSI/Grundschutz/Quellkataloge/Kernel	125
Eintrag: Prozess Identitäts- und Berechtigungsmanagement	125
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	125
BSI/Grundschutz/Quellkataloge/Kernel	126

Eintrag: Prozess Personalmanagement	126
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	126
BSI/Grundschutz/Quellkataloge/Kernel	126
Eintrag: Prüfplan	127
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	127
BSI/Grundschutz/Quellkataloge/Kernel	127
Eintrag: Realisierungsplan	127
Eintrag: Richtlinie zur Lenkung von Dokumenten und Aufzeichnungen	127
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	127
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	127
Eintrag: Richtlinie zur Risikoanalyse	127
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	127
BSI/Grundschutz/Quellkataloge/Risikomanagement	128
Eintrag: Risikobewertung	128
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	128
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	128
Eintrag: Schulungsplan	128
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	128
BSI/Grundschutz/Quellkataloge/Kernel	130
Eintrag: Schutzbedarfsfeststellung	132
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	132
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	132
Eintrag: Sicherheitsorganisation	132
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	132
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	132
Eintrag: Tätigkeits- & Rollenbeschreibung	132
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	132
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	132
Eintrag: Übersicht der Kommunikationspartner	132
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	132
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	133
Eintrag: Übungsplan	133
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	133
BSI/Grundschutz/Quellkataloge/Kernel	133
Eintrag: Umsetzungsplan	133
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	133
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	133
BSI/Grundschutz/Quellkataloge/Risikomanagement	134

Eintrag: Verfahrensbeschreibung	134
Eintrag: Verträge	134
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	134
BSI/Grundschutz/Quellkataloge/Kernel	134
Eintrag: Verzeichnis der Schwachstellen	134
Eintrag: Verzeichnis öffentlicher Schlüssel	134
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	134
BSI/Grundschutz/Quellkataloge/Kernel	134
Namespace: effort_level	135
Eintrag: 0	135
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	135
BSI/Grundschutz/Quellkataloge/Kernel	139
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	141
BSI/Grundschutz/Quellkataloge/Risikomanagement	143
Eintrag: 1	143
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	143
BSI/Grundschutz/Quellkataloge/Kernel	145
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	146
Eintrag: 2	146
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	146
BSI/Grundschutz/Quellkataloge/Kernel	151
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	155
BSI/Grundschutz/Quellkataloge/Risikomanagement	155
Eintrag: 3	156
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	156
BSI/Grundschutz/Quellkataloge/Kernel	163
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	170
Eintrag: 4	170
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	170
BSI/Grundschutz/Quellkataloge/Kernel	175
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	179
Eintrag: 5	179
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	179
BSI/Grundschutz/Quellkataloge/Kernel	184
Namespace: modal_verbs	189
Eintrag: KANN	189
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	189
BSI/Grundschutz/Quellkataloge/Kernel	195

Eintrag: MUSS	201
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	201
BSI/Grundschatz/Quellkataloge/Kernel	205
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	207
BSI/Grundschatz/Quellkataloge/Risikomanagement	210
Eintrag: SOLLTE	210
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	210
BSI/Grundschatz/Quellkataloge/Kernel	226
BSI/Grundschatz/Quellkataloge/Methodik-Grundschatz++	242
BSI/Grundschatz/Quellkataloge/Risikomanagement	243
Namespace: practices	243
Eintrag: Änderungen und Tests	243
Eintrag: Architektur	243
Eintrag: Berechtigung	243
Eintrag: Beschaffungsmanagement	243
Eintrag: Detektion	243
Eintrag: Dienstleistersteuerung	243
Eintrag: Entwicklung	244
Eintrag: Gebäudemanagement	244
Eintrag: Governance und Compliance	244
Eintrag: Informationen und Assets	244
Eintrag: Konfiguration	244
Eintrag: Monitoring-Evaluation	244
Eintrag: Notfallplanung	244
Eintrag: Personal	244
Eintrag: Risikomanagement	244
Eintrag: Sensibilisierung	245
Eintrag: Sicherheitsvorfallsbehandlung	245
Eintrag: Strukturmodellierung	245
Eintrag: Umsetzung	245
Eintrag: Verbesserung	245
Namespace: result	245
Eintrag: Alarmierung	245
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	245
BSI/Grundschatz/Quellkataloge/Kernel	245
Eintrag: Anforderung	246
BSI/Grundschatz/Anwenderkatalog/Grundschatz++	246
BSI/Grundschatz/Quellkataloge/Kernel	246

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	246
Eintrag: Asset	247
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	247
BSI/Grundschutz/Quellkataloge/Kernel	247
Eintrag: Authentizität	248
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	248
BSI/Grundschutz/Quellkataloge/Kernel	248
Eintrag: Autorisierung	248
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	248
BSI/Grundschutz/Quellkataloge/Kernel	248
Eintrag: Biometrie	248
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	248
BSI/Grundschutz/Quellkataloge/Kernel	248
Eintrag: Elementare Gefährdungen	249
Eintrag: Gefährdung (englisch "applied threat")	249
Eintrag: Geschäftsprozess	249
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	249
BSI/Grundschutz/Quellkataloge/Kernel	249
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	249
BSI/Grundschutz/Quellkataloge/Risikomanagement	250
Eintrag: Institutionen	250
Eintrag: Integrität	250
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	250
BSI/Grundschutz/Quellkataloge/Kernel	250
Eintrag: Kompetenz	250
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	250
BSI/Grundschutz/Quellkataloge/Kernel	250
Eintrag: Korrekturmaßnahme	251
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	251
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	251
Eintrag: Maßnahme / Schutzmaßnahme	251
Eintrag: Praktik	251
Eintrag: Redundanz	251
Eintrag: Schwachstelle (englisch "vulnerability")	251
Eintrag: Sicherheitskritisches Ereignis	251
Eintrag: Sicherheitsrelevantes Ereignis	251
Eintrag: Sicherheitsvorfall	251

Eintrag: Verfügbarkeit	252
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	252
BSI/Grundschutz/Quellkataloge/Kernel	252
Eintrag: Vertraulichkeit	252
Eintrag: Zielobjekt	252
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	252
BSI/Grundschutz/Quellkataloge/Kernel	252
Eintrag: Zielobjektkategorie	252
Eintrag: Zugang	252
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	252
BSI/Grundschutz/Quellkataloge/Kernel	253
Eintrag: Zugangskonto	254
Eintrag: Zugriff	254
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	254
BSI/Grundschutz/Quellkataloge/Kernel	255
Eintrag: Zutritt	255
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	255
BSI/Grundschutz/Quellkataloge/Kernel	256
Namespace: security_level	256
Eintrag: erhöht	256
Eintrag: normal-SdT	256
Namespace: tags	256
Eintrag: Advanced Persistent Threat (APT)	256
Eintrag: Advanced Persistent Threats (APT)	256
Eintrag: Archivierung	256
Eintrag: Auslandsreisen	257
Eintrag: Authentication and Authorization	257
Eintrag: Automatic Session Locking	257
Eintrag: Automatische Sicherheitsrichtlinie	257
Eintrag: BCM	257
Eintrag: Bring Your Own Device	257
Eintrag: Brute Force Angriffe	257
Eintrag: Brute-Force-Attacke	257
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	257
BSI/Grundschutz/Quellkataloge/Kernel	258
Eintrag: Change Management	258
Eintrag: Command & Control	258
Eintrag: Compliance Management	258

Eintrag: Compliance-Management	258
Eintrag: Credential Stuffing	258
Eintrag: Cryptography	259
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	259
BSI/Grundschutz/Quellkataloge/Kernel	259
Eintrag: Data Exfiltration	259
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	259
BSI/Grundschutz/Quellkataloge/Kernel	259
Eintrag: Data Leak	259
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	259
BSI/Grundschutz/Quellkataloge/Kernel	260
Eintrag: DDoS	260
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	260
BSI/Grundschutz/Quellkataloge/Kernel	260
Eintrag: Defense-in-depth	260
Eintrag: Denial of Service	260
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	260
BSI/Grundschutz/Quellkataloge/Kernel	260
Eintrag: Error Handling	261
Eintrag: Exit-Strategie	261
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	261
BSI/Grundschutz/Quellkataloge/Kernel	261
Eintrag: Failover	262
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	262
BSI/Grundschutz/Quellkataloge/Kernel	262
Eintrag: Führungsverantwortung	262
Eintrag: Hochverfügbarkeit	262
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	262
BSI/Grundschutz/Quellkataloge/Kernel	262
Eintrag: Honeypot	262
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	262
BSI/Grundschutz/Quellkataloge/Kernel	263
Eintrag: Insider Threat	263
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	263
BSI/Grundschutz/Quellkataloge/Kernel	263
Eintrag: Inspektion	263
Eintrag: Internet Exposure	263

Eintrag: Inventories	263
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	263
BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++	263
Eintrag: Kompetenzmanagement	264
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	264
BSI/Grundschutz/Quellkataloge/Kernel	264
Eintrag: Kontakt mit Behörden	264
Eintrag: Langzeitarchivierung	264
Eintrag: Lateral Movement	264
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	264
BSI/Grundschutz/Quellkataloge/Kernel	264
Eintrag: Lieferketten	265
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	265
BSI/Grundschutz/Quellkataloge/Kernel	265
Eintrag: Living off the land	265
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	265
BSI/Grundschutz/Quellkataloge/Kernel	265
Eintrag: MFA	265
Eintrag: Network Access Control	265
Eintrag: Password Policy	265
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	265
BSI/Grundschutz/Quellkataloge/Kernel	266
Eintrag: Pentest	266
Eintrag: Phishing	266
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	266
BSI/Grundschutz/Quellkataloge/Kernel	266
Eintrag: Physical Access Control	266
Eintrag: Privilege Escalation	266
Eintrag: Privilegierte Rechte	267
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	267
BSI/Grundschutz/Quellkataloge/Kernel	267
Eintrag: Produktbeschreibung	267
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	267
BSI/Grundschutz/Quellkataloge/Kernel	267
Eintrag: PSTN	267
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	267
BSI/Grundschutz/Quellkataloge/Kernel	268

Eintrag: Recon	268
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	268
BSI/Grundschutz/Quellkataloge/Kernel	268
Eintrag: Replay Attacks	268
Eintrag: Rogue Access Point	268
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	268
BSI/Grundschutz/Quellkataloge/Kernel	268
Eintrag: Secure Compiling Practices	268
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	268
BSI/Grundschutz/Quellkataloge/Kernel	269
Eintrag: Security by Default	269
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	269
BSI/Grundschutz/Quellkataloge/Kernel	269
Eintrag: Security by Design	269
Eintrag: Separation of Concerns	269
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	269
BSI/Grundschutz/Quellkataloge/Kernel	270
Eintrag: Session Hijacking	270
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	270
BSI/Grundschutz/Quellkataloge/Kernel	270
Eintrag: Shadow IT	270
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	270
BSI/Grundschutz/Quellkataloge/Kernel	270
Eintrag: Shared Responsibility Model	271
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	271
BSI/Grundschutz/Quellkataloge/Kernel	271
Eintrag: Shoulder Surfing	271
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	271
BSI/Grundschutz/Quellkataloge/Kernel	271
Eintrag: VPN	271
Eintrag: Zero Trust	271
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	271
BSI/Grundschutz/Quellkataloge/Kernel	272
Namespace: target_object_categories	272
Eintrag: Administrierende	272
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	272
BSI/Grundschutz/Quellkataloge/Kernel	272

Eintrag: Anwendungen	273
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	273
BSI/Grundschutz/Quellkataloge/Kernel	275
Eintrag: Cloud-Dienste	277
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	277
BSI/Grundschutz/Quellkataloge/Kernel	277
Eintrag: Dateiserver	277
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	277
BSI/Grundschutz/Quellkataloge/Kernel	278
Eintrag: Daten	278
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	278
BSI/Grundschutz/Quellkataloge/Kernel	279
Eintrag: Datenträgerarchiv	280
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	280
BSI/Grundschutz/Quellkataloge/Kernel	280
Eintrag: Dienstleistungen	280
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	280
BSI/Grundschutz/Quellkataloge/Kernel	281
Eintrag: DNS-Server	281
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	281
BSI/Grundschutz/Quellkataloge/Kernel	282
Eintrag: E-Mail	282
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	282
BSI/Grundschutz/Quellkataloge/Kernel	282
Eintrag: Einkäufe	283
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	283
BSI/Grundschutz/Quellkataloge/Kernel	284
Eintrag: Endgeräte	285
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	285
BSI/Grundschutz/Quellkataloge/Kernel	285
Eintrag: Externe Netzanschlüsse	286
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	286
BSI/Grundschutz/Quellkataloge/Kernel	286
Eintrag: Fahrzeuge	287
Eintrag: Faxen	287
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	287
BSI/Grundschutz/Quellkataloge/Kernel	287

Eintrag: Führungskräfte	287
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	287
BSI/Grundschutz/Quellkataloge/Kernel	287
Eintrag: Gebäude	287
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	287
BSI/Grundschutz/Quellkataloge/Kernel	287
Eintrag: Hostsysteme	288
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	288
BSI/Grundschutz/Quellkataloge/Kernel	288
Eintrag: Informationen	288
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	288
BSI/Grundschutz/Quellkataloge/Kernel	288
Eintrag: Institutionsleitung	288
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	288
BSI/Grundschutz/Quellkataloge/Kernel	289
Eintrag: Interne Netzsegmente	289
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	289
BSI/Grundschutz/Quellkataloge/Kernel	289
Eintrag: Interpersonelle Kommunikation	289
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	289
BSI/Grundschutz/Quellkataloge/Kernel	289
Eintrag: IT-Produkte	289
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	289
BSI/Grundschutz/Quellkataloge/Kernel	290
Eintrag: IT-Systeme	290
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	290
BSI/Grundschutz/Quellkataloge/Kernel	293
Eintrag: Mitarbeitende	295
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	295
BSI/Grundschutz/Quellkataloge/Kernel	296
Eintrag: Mobiltelefone	296
Eintrag: Netze	296
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	296
BSI/Grundschutz/Quellkataloge/Kernel	297
Eintrag: Nutzende	298
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	298
BSI/Grundschutz/Quellkataloge/Kernel	299

Eintrag: Office-Anwendungen	301
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	301
BSI/Grundschutz/Quellkataloge/Kernel	301
Eintrag: Outsourcing	301
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	301
BSI/Grundschutz/Quellkataloge/Kernel	302
Eintrag: Räume	303
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	303
BSI/Grundschutz/Quellkataloge/Kernel	303
Eintrag: Räume für technische Infrastruktur	303
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	303
BSI/Grundschutz/Quellkataloge/Kernel	303
Eintrag: Serverräume	304
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	304
BSI/Grundschutz/Quellkataloge/Kernel	304
Eintrag: Standorte	304
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	304
BSI/Grundschutz/Quellkataloge/Kernel	305
Eintrag: TK-Anwendungen	307
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	307
BSI/Grundschutz/Quellkataloge/Kernel	307
Eintrag: Verzeichnisdienste	307
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	307
BSI/Grundschutz/Quellkataloge/Kernel	308
Eintrag: Virtualisierungslösungen	308
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	308
BSI/Grundschutz/Quellkataloge/Kernel	308
Eintrag: VK-Anwendungen	308
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	308
BSI/Grundschutz/Quellkataloge/Kernel	308
Eintrag: Webanwendungen	308
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	308
BSI/Grundschutz/Quellkataloge/Kernel	309
Eintrag: Webbrowser	309
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	309
BSI/Grundschutz/Quellkataloge/Kernel	309
Eintrag: Webserver	310
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	310

BSI/Grundschutz/Quellkataloge/Kernel	310
Eintrag: WLANs	310
BSI/Grundschutz/Anwenderkatalog/Grundschutz++	310
BSI/Grundschutz/Quellkataloge/Kernel	310
Namespace: topics	311
Eintrag: Abnahme	311
Eintrag: Administration	311
Eintrag: Analyse der interessierten Parteien	311
Eintrag: Anforderungsergänzung	311
Eintrag: Anforderungsmodellierung auf die Assets	311
Eintrag: Asset-Modellierung	311
Eintrag: Auditprogramm und -durchführung	311
Eintrag: Aufgaben, Rollen, Zuständigkeiten	311
Eintrag: Ausfallsicherheit	312
Eintrag: Auswahl von Lieferanten	312
Eintrag: Auswahl von Produkten und Dienstleistungen - Kündigung	312
Eintrag: Auswahl von Produkten und Dienstleistungen - Zusammenarbeit	312
Eintrag: Auswahl von Produkten und Dienstleistungen	312
Eintrag: Authentifizierung	312
Eintrag: Authentisierung	312
Eintrag: Bedarfserfassung	312
Eintrag: Behandlung von Compliance-Verstößen	312
Eintrag: Berechtigungsmanagement	313
Eintrag: Bereitstellung	313
Eintrag: Bereitstellung und Betrieb	313
Eintrag: Besondere Aufbauorganisation	313
Eintrag: Bewertung der erreichten Verbesserung	313
Eintrag: Bewertung fehlender Umsetzungen	313
Eintrag: Bewertungsschema und Auditberichte	313
Eintrag: Datensicherung	313
Eintrag: Dedizierte Systeme	313
Eintrag: Definition und Abgrenzung des Informationsverbunds	314
Eintrag: Dekommissionierung von Dienstleistern	314
Eintrag: Dokumentation und Kommunikation	314
Eintrag: Durchführung der Risikobetrachtung	314
Eintrag: Entwicklung einer Sicherheitsleitlinie	314
Eintrag: Ermittlung des Umsetzungsstatus	314
Eintrag: Erstellung eines Anforderungspakets	314

Eintrag: Festlegung des Geltungsbereichs	314
Eintrag: Festlegung des Kontextes der Institution	314
Eintrag: Festlegung und Freigabe der Vorgehensweise	315
Eintrag: Fortschrittsverfolgung der Realisierung	315
Eintrag: Freigabe	315
Eintrag: Freigabeverfahren	315
Eintrag: Freigabeverfahren und Ausnahmemanagement	315
Eintrag: Gemeinsame Arbeitsbereiche	315
Eintrag: Gestaltungsentscheidungen	315
Eintrag: Grundlagen	315
Eintrag: Grundlegende Sensibilisierung	315
Eintrag: Identifikation von Verbesserungspotenzialen	316
Eintrag: Identitätsmanagement	316
Eintrag: Implementierung des Compliance-Managements	316
Eintrag: Initiierung des Risikomanagements	316
Eintrag: Inventarisierung	316
Eintrag: ISMS-Anforderungen des Informationsverbundes	316
Eintrag: Kapazitätsmanagement	316
Eintrag: Kompensierende Kontrollmechanismen	316
Eintrag: Konfiguration von Anwendungen	316
Eintrag: Konfiguration von Systemen	317
Eintrag: Kontinuierliche Verbesserung	317
Eintrag: Kontrolle von Dienstleistern	317
Eintrag: Kontrollierte Datenverarbeitung	317
Eintrag: Korrektur- und Verbesserungsplan	317
Eintrag: Korrektur- und Verbesserungsvorschläge	317
Eintrag: Leistungsbewertung des ISMS	317
Eintrag: Löschen und Vernichten	317
Eintrag: Management von Schwachstellen	317
Eintrag: Managementbewertungen	318
Eintrag: Meldung von Ereignissen	318
Eintrag: Mobiles Arbeiten	318
Eintrag: Monitoringmethoden und -tools	318
Eintrag: Nachbereitung	318
Eintrag: Netzdesign	318
Eintrag: Notfallvorsorge	318
Eintrag: Nutzung von digitalen Dienstleistungen	318
Eintrag: Passwortgebrauch	318

Eintrag: Perimeterschutz	319
Eintrag: Personalbetreuung	319
Eintrag: Personalentwicklung	319
Eintrag: Personalzugang	319
Eintrag: Physische Sicherheit	319
Eintrag: Physischer Perimeter	319
Eintrag: Physischer Schutz	319
Eintrag: Physischer Zutritt	319
Eintrag: Platzierung von Assets	319
Eintrag: Protokollierung	320
Eintrag: Prozess der Informationssicherheitseinstufung	320
Eintrag: Reaktion	320
Eintrag: Regelungen zum Gebrauch	320
Eintrag: Regelungen zum Transfer	320
Eintrag: Ressourcenauslastung	320
Eintrag: Risiko	320
Eintrag: Rollen und Berechtigungen	320
Eintrag: Rücknahme von Assets	320
Eintrag: Schlüsselmanagement	321
Eintrag: Schlüsselverwaltung	321
Eintrag: Schutz vor Elementarschäden	321
Eintrag: Schutz vor Schadcode	321
Eintrag: Schutz vor Schadprogrammen	321
Eintrag: Senden und Empfangen von Nachrichten	321
Eintrag: Sensibilisierung der Leitungsebene	321
Eintrag: Sicherheitsbereiche	321
Eintrag: Sicherheitsorganisation und Rollen	321
Eintrag: Sicherheitsupdates	322
Eintrag: Softwareentwicklung - Code	322
Eintrag: Softwareentwicklung - Härtung	322
Eintrag: Softwareentwicklung - Security by Design	322
Eintrag: Softwareentwicklung - Updates	322
Eintrag: Spezifische Risiken	322
Eintrag: Tests	322
Eintrag: Überprüfung des gesetzten Sicherheitsniveaus	322
Eintrag: Überwachung der Compliance	322
Eintrag: Überwachung von Aktivitäten	323
Eintrag: Umgang mit Datenträgern	323

Eintrag: Umgang mit Informationen	323
Eintrag: Umgang mit Nicht-Konformitäten	323
Eintrag: Umgang mit spezifischen Zielobjekten	323
Eintrag: Umsetzungsplanung und Priorisierung	323
Eintrag: Validierung der Anforderungen	323
Eintrag: Verfügbarkeit von Ressourcen	323
Eintrag: Versorgungseinrichtungen	323
Eintrag: Verteilte Anwendungen	324
Eintrag: Vertrauensbeziehungen	324
Eintrag: Vertrauenswürdige Basisdienste	324
Eintrag: Vertraulichkeit und Integrität im Weitverkehrsnetz	324
Eintrag: Verwahrung von Speichermedien	324
Eintrag: Vorbereitung	324
Eintrag: Vorfallserkennung	324
Eintrag: Wahrung von Compliance in der Umsetzung	324
Eintrag: Wartung	324
Eintrag: Weggang von Mitarbeitenden	325
Eintrag: Wireless LAN	325
Eintrag: Wirksamkeitsprüfung	325
Eintrag: Zugangsbeschränkungen	325
Eintrag: Zugangskonten	325
Eintrag: Zuständigkeiten und Umsetzungsfristen	325

Namespace Einträge im BSI Grundschutz++

Dieses Dokument stellt eine strukturierte Kreuzreferenz zwischen Namespace-Einträgen des BSI-Grundschutz++ und den zugehörigen Controls dar.

Ziel ist es, die in den Namespace-Definitionen verwendeten Begriffe, Klassifizierungen, Attribute und Merkmalsausprägungen transparent den Controls zuzuordnen, in denen diese referenziert oder verwendet werden. Dadurch entsteht ein systematischer Überblick über die Verwendung semantischer Konzepte innerhalb des Regelwerks.

Die Darstellung ist nach Namespaces gegliedert. Innerhalb jedes Namespace werden die vorhandenen Einträge aufgeführt und denjenigen Controls gegenübergestellt, in denen sie vorkommen.

Das Dokument wurde automatisiert erzeugt und bildet den zum Zeitpunkt der Generierung verfügbaren Datenbestand ab.

Disclaimer

Dieses Dokument wurde automatisiert auf Basis der in einem Obsidian-Vault enthaltenen Inhalte generiert. Der verwendete Vault basiert auf dem Repository **BSI-Grundschutz++** und wurde seinerseits automatisiert aus den Inhalten des Projekts **Stand der Technik Bibliothek** des Bundesamts für Sicherheit in der Informationstechnik (BSI) erzeugt.

Die Zusammenstellung, Strukturierung und Ausgabe erfolgte mithilfe von Skripten, Plugins und Konvertierungswerkzeugen. Trotz sorgfältiger Erstellung kann nicht ausgeschlossen werden, dass Inhalte unvollständig, fehlerhaft, veraltet oder missverständlich dargestellt sind.

Maßgeblich sind ausschließlich die Originalinhalte des zugrunde liegenden Repositories:

<https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek>

sowie gegebenenfalls ergänzende Primärquellen, Normtexte, Richtlinien oder offizielle Veröffentlichungen.

Dieses Dokument dient ausschließlich der Information, Dokumentation und internen Unterstützung.

Es wird keine Gewähr für die Richtigkeit, Vollständigkeit, Aktualität oder Eignung für einen bestimmten Zweck übernommen. Jegliche Nutzung erfolgt auf eigene Verantwortung. Vor operativen, fachlichen, rechtlichen oder regulatorischen Entscheidungen sind die Inhalte eigenständig zu prüfen und bei Bedarf fachlich zu validieren.

Automatisch erzeugte Verknüpfungen, Klassifizierungen, Zuordnungen oder Auswertungen können vereinfachend sein und bedürfen gegebenenfalls einer manuellen Nachprüfung.

Lizenz

Dieses Dokument basiert auf Inhalten des **Bundesamts für Sicherheit in der Informationstechnik (BSI)** aus dem Projekt **Stand der Technik Bibliothek (Grundschutz++)**.

Originalquelle:

<https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek>

Verwendete Bestandteile:

- Anwendungskatalog (OSCAL)

- Namespace-Definitionen
- Quellkataloge

Die Originalinhalte stehen unter der Lizenz **Creative Commons Attribution-ShareAlike 4.0 International (CC BY-SA 4.0)**:

<https://creativecommons.org/licenses/by-sa/4.0/>

Dieses Dokument stellt eine bearbeitete bzw. transformierte Fassung dar und wird gemäß den Bedingungen der Lizenz ebenfalls unter **CC BY-SA 4.0** bereitgestellt.

Namespace: action_words

Eintrag: aktivieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.3.3 SSIDs
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.16 Gruppenkonten - MFA
- BER.3.20 Dienstkonten
- BER.3.6 Single-Sign-On
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- DEV.3.4 Passwort-Hashing
- DEV.4.6 Compileroptionen
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- DLS.2.1 Mehr-Faktor-Authentifizierung
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration

- KONF.11.2 Warteraum
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.12.1 Eingabevalidierung
- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.9 Journaling
- KONF.12.10 Cookie-Attribute
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.7 Erweiterte Attribute
- KONF.12.9 Information über Aufzeichnung
- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.14.4 Caching
- KONF.15.3 Denial of Service
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.8 Abgesicherter und authentifzierter Bootprozess
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.3 SIM-PIN
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.4.1 Anbindung an Verzeichnisdienst

- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.12 Konferenzmoderation
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.14 Browser Sandboxing
- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.3 Kiosk-Modus
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.6.6.1 Mandantenfähigkeit
- KONF.7.1 Echtzeitscanner
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.5 Alarmierung
- KONF.7.6 Automatische Updates
- KONF.7.8 Dual-Engine-Strategie
- KONF.8.2 Automatische Updates der Anwendung
- REA.2.2 Automatische Erstreaktion

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.3.3 SSIDs
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.16 Gruppenkonten - MFA
- BER.3.20 Dienstkonten
- BER.3.6 Single-Sign-On
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter

- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- DEV.3.4 Passwort-Hashing
- DEV.4.6 Compileroptionen
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- DLS.2.1 Mehr-Faktor-Authentifizierung
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.2 Warteraum
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.12.1 Eingabevalidierung
- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.9 Journaling
- KONF.12.10 Cookie-Attribute
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.7 Erweiterte Attribute
- KONF.12.9 Information über Aufzeichnung
- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.14.4 Caching
- KONF.15.3 Denial of Service
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.5.1 Automatische Konfigurationsverwaltung

- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.3 SIM-PIN
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.12 Konferenzmoderation
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.14 Browser Sandboxing
- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.3 Kiosk-Modus
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.6.6.1 Mandantenfähigkeit
- KONF.7.1 Echtzeitscanner
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.5 Alarmierung
- KONF.7.6 Automatische Updates
- KONF.7.8 Dual-Engine-Strategie
- KONF.8.2 Automatische Updates der Anwendung
- REA.2.2 Automatische Erstreaktion

Eintrag: anhören

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.7.3 Anhörung Prozessbeteiligter

- DLS.3.4 Anhörung
- GC.7.1.2 Anhörung zuständiger Stellen

BSI/Grundschutz/Quellkataloge/Kernel

- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.7.3 Anhörung Prozessbeteiligter
- DLS.3.4 Anhörung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.7.1.2 Anhörung zuständiger Stellen

Eintrag: anweisen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.3.13 Lagerung physischer Assets
- ASST.5.6 Wartung durch Externe
- GEB.3.4 Berechtigungsmarkierung
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.7.2 Verwahrung von Schlüsseln
- PERF.3.1.3 Auswahl des Auditteams
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- SENS.2.8 Melden von Ereignissen
- SENS.5.5 Löschfristen
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.4 Begleitung Externer
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.3 Verwahrung außer Haus
- TEST.2.2 Folgenabschätzung

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.3.13 Lagerung physischer Assets
- ASST.5.6 Wartung durch Externe
- GEB.3.4 Berechtigungsmarkierung
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.7.2 Verwahrung von Schlüsseln
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- SENS.2.8 Melden von Ereignissen
- SENS.5.5 Löschfristen
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.4 Begleitung Externer
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.3 Verwahrung außer Haus
- TEST.2.2 Folgenabschätzung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- PERF.3.1.3 Auswahl des Auditteams

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.2 Einhaltung der BSI-Kriterien

Eintrag: ausführen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.5.2 Geregelte Wartungen
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.4.1 Identitätsüberprüfung

- BER.6.9 Anlassbezogene Passwortwechsel
- DET.5.10.5 Test gemäß Änderungsmanagement
- DET.6.1.2 Automatische Alarmierung
- DEV.2.6.2 Ausgabekodierung
- DEV.3.2 Routinen zur Fehlerbehandlung
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.9.1.1 Externer Austausch zur Informationssicherheit
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.2.3 Änderung von Default-Zugangsdaten
- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation
- PERF.3.1.2 Planen von internen Audits
- PERF.3.1.4 Umfang von Audits
- PERF.4.1.2 Kommunikation an Stakeholder
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- PERS.3.7 Einarbeitung
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- REA.2.5 IT-Forensik
- STM.5.1 Modellierung der Anforderungen mit Zielobjekt
- STM.5.2 Vererbung von Zielobjektkategorien
- STM.5.3 Konsolidierung und Redundanzprüfung
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.6.2 Auf Grund externer Verpflichtungen
- STM.8.1 Risikobetrachtung bei fehlenden Anforderungen
- TEST.4.2 Signatur
- TEST.5.3 Schrittweiser Rollout

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.5.2 Regelmäßige Wartungen
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.4.1 Identitätsüberprüfung
- BER.6.9 Anlassbezogene Passwortwechsel
- DET.5.10.5 Test gemäß Änderungsmanagement
- DET.6.1.2 Automatische Alarmierung
- DEV.2.6.2 Ausgabekodierung
- DEV.3.2 Routinen zur Fehlerbehandlung
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.2.3 Änderung von Default-Zugangsdaten
- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- PERS.3.7 Einarbeitung
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- REA.2.5 IT-Forensik
- TEST.4.2 Signatur
- TEST.5.3 Schrittweiser Rollout

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.9.1.1 Externer Austausch zur Informationssicherheit
- PERF.3.1.2 Planen von internen Audits
- PERF.3.1.4 Umfang von Audits
- PERF.4.1.2 Kommunikation an Stakeholder
- STM.5.1 Modellierung der Anforderungen mit Zielobjekt
- STM.5.2 Vererbung von Zielobjektkategorien
- STM.5.3 Konsolidierung und Redundanzprüfung

- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.6.2 Auf Grund externer Verpflichtungen
- STM.8.1 Risikobetrachtung bei fehlenden Anforderungen

Eintrag: authentifizieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.3 Authentifizierung von Routingprotokollen
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.1 Zugangskontrollanlage
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.1.2 Pre-Boot-Authentifizierung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.3 Authentifizierung von Routingprotokollen
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.1 Zugangskontrollanlage
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.1.2 Pre-Boot-Authentifizierung

Eintrag: autorisieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.4.2 Autorisiertes Routing
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.5.3 Autorisierung von Wartungen
- ASST.7.6 Autorisierung von Veräußerungen
- BER.7.7 Kein Transport privater Schlüssel
- BES.1.4.1 Freigabe der Strategie
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- DET.5.10.1 Autorisierte Bezugsquellen
- DET.5.3.1 Autorisierung kritischer Scans
- DEV.6.1 Freigabe nach Änderungen und Tests
- GC.10.2 Freigabe von Vorgehensweisen
- GC.6.1.4 Freigabe der Sicherheitsleitlinie
- GEB.1.3 Autorisierung von Standorten
- GEB.3.3.3 Besucheranmeldung
- GEB.4.2 Gesonderte Autorisierung
- KONF.4.2 DNS-Anbindung
- KONF.4.5 Zeitquellen
- RISK.1.10 Freigabe der Umsetzungsplanung
- RISK.1.5 Freigabe des Risikomanagements
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.1.1 Unabhängigkeit der Autorisierung
- UMS.5.1 Autorisierung von Ausnahmen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.4.2 Autorisiertes Routing
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.3.10 Autorisierung von Datenlokationen

- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.5.3 Autorisierung von Wartungen
- ASST.7.6 Autorisierung von Veräußerungen
- BER.7.7 Kein Transport privater Schlüssel
- BES.1.4.1 Freigabe der Strategie
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- DET.5.10.1 Autorisierte Bezugsquellen
- DET.5.3.1 Autorisierung kritischer Scans
- DEV.6.1 Freigabe nach Änderungen und Tests
- GEB.1.3 Autorisierung von Standorten
- GEB.3.3.3 Besucheranmeldung
- GEB.4.2 Gesonderte Autorisierung
- KONF.4.2 DNS-Anbindung
- KONF.4.5 Zeitquellen
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.1.1 Unabhängigkeit der Autorisierung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.10.2 Freigabe von Vorgehensweisen
- GC.6.1.4 Freigabe der Sicherheitsleitlinie
- UMS.5.1 Autorisierung von Ausnahmen

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.10 Freigabe der Umsetzungsplanung
- RISK.1.5 Freigabe des Risikomanagements

Eintrag: blockieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.2 Netzbasierte Angriffe

- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- DEV.3.1 Replay-Angriffe
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- KONF.11.5 Erraten von Zugriffslinks
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.13.1.1 SPAM-Filter
- KONF.14.5 Zeitüberschreitung von Netzverbindungen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- DEV.3.1 Replay-Angriffe
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- KONF.11.5 Erraten von Zugriffslinks
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.13.1.1 SPAM-Filter
- KONF.14.5 Zeitüberschreitung von Netzverbindungen

Eintrag: deaktivieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.2.5 Deaktivierung bei Weggang
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.3 Deaktivierung einfacher Biometrie
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DLS.4.1.2 Berechtigungen deaktivieren
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.14 DNS-Falschinformationen
- KONF.12.6 Browser-Historie
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.5.2 Keine Mehrfachanmeldung

BSI/Grundschutz/Quellkataloge/Kernel

- BER.2.5 Deaktivierung bei Weggang
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.3 Deaktivierung einfacher Biometrie
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DLS.4.1.2 Berechtigungen deaktivieren
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen

- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.14 DNS-Falschinformationen
- KONF.12.6 Browser-Historie
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.5.2 Keine Mehrfachanmeldung

Eintrag: dokumentieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1.1 Dokumentation
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ASST.1.1.1 Dokumentation
- ASST.2.1 Inventar der Informationen
- ASST.2.2 Inventar der Systeme
- ASST.2.3 Inventar der Anwendungen
- ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.7 Dokumentation von Wartungen
- BER.1.1.1 Dokumentation
- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BER.1.4 Inventar der Berechtigungen
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.5.2 Begründung von Berechtigungen
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- BER.7.16.5 Beglaubigungsstatus
- BER.7.16.6 Revocationstatus
- BER.7.3 Verzeichnis öffentlicher Schlüssel
- BES.1.1.1 Dokumentation

- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.1.3.1 Gesamte Lieferkette
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.2.1 Erfassung des Bedarfes
- BES.2.1.1 Verwendungszweck
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.1.3 Systemvoraussetzungen
- BES.2.1.4 Kompatibilität
- BES.2.1.4.1 Kompatibilität der Schnittstellen
- BES.2.1.4.2 Kompatibilität der Netzanbindung
- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.10 Serviceprofil
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.7.4.5 Netzverbindungen ab Werk
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DET.1.1.1 Dokumentation
- DET.3.4 Revisionssicherheit
- DET.3.5 Unbestreitbarkeit
- DET.5.2 Schwachstellenregister
- DET.6.1.3 Dokumentation von Ergebnissen
- DEV.1.1.1 Dokumentation
- DEV.2.2 Dokumentation der (Software-)Architektur

- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.7 Deterministischer Binärcode
- DEV.4.8 Default-Zugangsdaten
- DLS.1.1.1 Dokumentation
- GC.7.1.3 Vertragliche Verpflichtungen
- GEB.1.1.1 Dokumentation
- GEB.1.5 Strukturpläne
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.3.3.2 Dokumentation von Zutritten
- KONF.1.1.1 Dokumentation
- KONF.1.3 Management von Werkzeugen
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.2.1 Grundkonfiguration für Systeme
- NOT.1.1.1 Dokumentation
- NOT.3.1 Wiederanlaufplan
- NOT.3.2 Geschäftsfortführungsplan
- NOT.4.1 Dokumentation der Quellen
- NOT.4.15 Vorgehen zur Wiederherstellung
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- PERF.5.1.9 Maßnahmenvorschläge
- PERS.1.1.1 Dokumentation
- PERS.3.4 Stellenbeschreibungen
- REA.1.1.1 Dokumentation
- REA.2.3 Dokumentation von Vorfällen
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.6.1 Dokumentation des Vorgehens
- REA.3.1.1 Quantitative Analyse
- SENS.1.1.1 Dokumentation
- STM.4.2 Dokumentation relevanter Assets
- TEST.1.1.1 Dokumentation
- TEST.2.2.2 Anpassung der Dokumentation

- TEST.2.2.3 Dokumentation der Abhängigkeiten
- TEST.3.1.1 Dokumentation von Testergebnissen
- TEST.4.1.2 Dokumentation der Freigabe
- UMS.5.2 Dokumentation von Ausnahmen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1.1 Dokumentation
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ASST.1.1.1 Dokumentation
- ASST.2.1 Inventar der Informationen
- ASST.2.2 Inventar der Systeme
- ASST.2.3 Inventar der Anwendungen
- ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.7 Dokumentation von Wartungen
- BER.1.1.1 Dokumentation
- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BER.1.4 Inventar der Berechtigungen
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.5.2 Begründung von Berechtigungen
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- BER.7.16.5 Beglaubigungsstatus
- BER.7.16.6 Revocationstatus
- BER.7.3 Verzeichnis öffentlicher Schlüssel
- BES.1.1.1 Dokumentation
- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.1.3.1 Gesamte Lieferkette
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.2.1 Erfassung des Bedarfes
- BES.2.1.1 Verwendungszweck
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.1.3 Systemvoraussetzungen
- BES.2.1.4 Kompatibilität
- BES.2.1.4.1 Kompatibilität der Schnittstellen
- BES.2.1.4.2 Kompatibilität der Netzanbindung

- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.10 Serviceprofil
- BES.7.4.11 Dokumentierte Mandamententrennung
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.7.4.5 Netzverbindungen ab Werk
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DET.1.1.1 Dokumentation
- DET.3.4 Revisionssicherheit
- DET.3.5 Unbestreitbarkeit
- DET.5.2 Schwachstellenregister
- DET.6.1.3 Dokumentation von Ergebnissen
- DEV.1.1.1 Dokumentation
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.7 Deterministischer Binärcode
- DEV.4.8 Default-Zugangsdaten
- DLS.1.1.1 Dokumentation
- GEB.1.1.1 Dokumentation
- GEB.1.5 Strukturpläne
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.3.3.2 Dokumentation von Zutritten
- KONF.1.1.1 Dokumentation
- KONF.1.3 Management von Werkzeugen

- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.2.1 Grundkonfiguration für Systeme
- NOT.1.1.1 Dokumentation
- NOT.3.1 Wiederanlaufplan
- NOT.3.2 Geschäftsfortführungsplan
- NOT.4.1 Dokumentation der Quellen
- NOT.4.15 Vorgehen zur Wiederherstellung
- PERS.1.1.1 Dokumentation
- PERS.3.4 Stellenbeschreibungen
- REA.1.1.1 Dokumentation
- REA.2.3 Dokumentation von Vorfällen
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.6.1 Dokumentation des Vorgehens
- REA.3.1.1 Quantitative Analyse
- SENS.1.1.1 Dokumentation
- TEST.1.1.1 Dokumentation
- TEST.2.2.2 Anpassung der Dokumentation
- TEST.2.2.3 Dokumentation der Abhängigkeiten
- TEST.3.1.1 Dokumentation von Testergebnissen
- TEST.4.1.2 Dokumentation der Freigabe

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.7.1.3 Vertragliche Verpflichtungen
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- PERF.5.1.9 Maßnahmenvorschläge
- STM.4.2 Dokumentation relevanter Assets
- UMS.5.2 Dokumentation von Ausnahmen

Eintrag: einschränken

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.1 Externe Netzanschlüsse
 - ARCH.2.2.10 Drucker-Netz
 - ARCH.2.2.11 Physische Segmentierung
 - ARCH.2.2.2 Gastnetz
 - ARCH.2.2.3 Segmentierung von Servern und Clients
 - ARCH.2.2.4 VoIP-Netz
 - ARCH.2.2.5 OT-Systeme
 - ARCH.2.2.8 Segmentierung von Test und Betrieb
 - ARCH.2.2.9 Segmentierung von IPv4 und IPv6
 - ARCH.2.3 Mikrosegmentierung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
 - ARCH.5.1.10 Webfilterung
 - ARCH.5.1.10.1 Bekannte schädliche Inhalte
 - ARCH.5.1.10.2 Bekannte illegale Inhalte
 - ARCH.5.1.10.3 Speicherdienste
 - ARCH.5.1.12 Software-definierte Verbindungen
 - ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
 - ARCH.5.1.9 Filterung von DNS
- BER.2.2 Einschränkung
- BER.3.2 Einschränkung des Managements
- BER.5.1 Prinzip der geringsten Berechtigungen
- DET.3.2 Filterung nicht benötigter Inhalte
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8 Einschränkung von Schnittstellen
 - KONF.11.8.1 Einschränkung von Zonentransfers
 - KONF.11.8.2 Einschränkung von TK-Verbindungen
 - KONF.11.8.2.1 Einschränkung der TK-Gegenstellen

- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.6 JavaScript
- KONF.12.3 Cookies
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.6 Getrennte Datenhaltung
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.15 Lokale Firewall
- KONF.7.9 Einschränkung der Installation
- KONF.9.1 Speicherplatzbegrenzung
- KONF.9.2 Begrenzung der Rechenleistung
- TEST.1.3 Einschränkung von Änderungen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
- ARCH.2.2.1 Externe Netzanschlüsse
- ARCH.2.2.10 Drucker-Netz
- ARCH.2.2.11 Physische Segmentierung

- ARCH.2.2.2 Gastnetz
- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.3 Mikrosegmentierung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS
- BER.2.2 Einschränkung
- BER.3.2 Einschränkung des Managements
- BER.5.1 Prinzip der geringsten Berechtigungen
- DET.3.2 Filterung nicht benötigter Inhalte
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.6 JavaScript
- KONF.12.3 Cookies
- KONF.12.5 Auto-Vervollständigung von Daten

- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.6 Getrennte Datenhaltung
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.15 Lokale Firewall
- KONF.7.9 Einschränkung der Installation
- KONF.9.1 Speicherplatzbegrenzung
- KONF.9.2 Begrenzung der Rechenleistung
- TEST.1.3 Einschränkung von Änderungen

Eintrag: festlegen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.10.1 Festlegung von Vorgehensweisen
- GC.4.1 Festlegung des Geltungsbereichs
- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs
- GC.6.1 Festlegung von Zielen für die Informationssicherheit
- GC.6.1.1 Festlegung einer Sicherheitsstrategie
- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.8.1.3 Vermeidung von Interessenkonflikten
- GC.8.1.4 Festlegung einer Sicherheitsorganisation

- GC.8.1.5 Sicherstellung der Qualifikation
- PERF.3.1.1 Erstellen eines Auditsplans
- PERF.4.1.1 Einheitliches Bewertungsschema
- PERF.6.1.2 Schwachstellen
- PERF.6.1.3 Bedrohungen
- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen
- STM.4.1 Erfassung relevanter Assets
- UMS.2.1 Bewertung des Restrisikos
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.2 Festlegung von Umsetzungsfristen
- VRB.2.1 Umgang mit Nicht-Konformitäten
- VRB.4.1 Korrekturmaßnahmen
- VRB.4.2 Verbesserungsmaßnahmen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.10.1 Festlegung von Vorgehensweisen
- GC.4.1 Festlegung des Geltungsbereichs
- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs
- GC.6.1 Festlegung von Zielen für die Informationssicherheit
- GC.6.1.1 Festlegung einer Sicherheitsstrategie
- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.8.1.3 Vermeidung von Interessenkonflikten
- GC.8.1.4 Festlegung einer Sicherheitsorganisation
- GC.8.1.5 Sicherstellung der Qualifikation
- PERF.3.1.1 Erstellen eines Auditsplans
- PERF.4.1.1 Einheitliches Bewertungsschema
- PERF.6.1.2 Schwachstellen
- PERF.6.1.3 Bedrohungen
- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen
- STM.4.1 Erfassung relevanter Assets
- UMS.2.1 Bewertung des Restrisikos
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.2 Festlegung von Umsetzungsfristen
- VRB.2.1 Umgang mit Nicht-Konformitäten

- VRB.4.1 Korrekturmaßnahmen
- VRB.4.2 Verbesserungsmaßnahmen

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.4 Risikoappetit

Eintrag: informieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1.3 Bekanntgabe
- ASST.1.1.3 Bekanntgabe
- ASST.5.5 Wartungsfenster
- BER.1.1.3 Bekanntgabe
- BES.1.1.3 Bekanntgabe
- DET.1.1.3 Bekanntgabe
- DEV.1.1.3 Bekanntgabe
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DLS.1.1.3 Bekanntgabe
- GEB.1.1.3 Bekanntgabe
- KONF.1.1.3 Bekanntgabe
- NOT.1.1.3 Bekanntgabe
- PERF.5.2 Bericht an die Institutionsleitung
- PERS.1.1.3 Bekanntgabe
- REA.1.1.3 Bekanntgabe
- REA.2.6.2.1 Information zuständiger Behörden
- SENS.1.1.3 Bekanntgabe
- SENS.2.2 Meldewege
- TEST.1.1.3 Bekanntgabe
- TEST.5.1 Information betroffener Kreise

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1.3 Bekanntgabe
- ASST.1.1.3 Bekanntgabe
- ASST.5.5 Wartungsfenster

- BER.1.1.3 Bekanntgabe
- BES.1.1.3 Bekanntgabe
- DET.1.1.3 Bekanntgabe
- DEV.1.1.3 Bekanntgabe
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DLS.1.1.3 Bekanntgabe
- GEB.1.1.3 Bekanntgabe
- KONF.1.1.3 Bekanntgabe
- NOT.1.1.3 Bekanntgabe
- PERS.1.1.3 Bekanntgabe
- REA.1.1.3 Bekanntgabe
- REA.2.6.2.1 Information zuständiger Behörden
- SENS.1.1.3 Bekanntgabe
- SENS.2.2 Meldewege
- TEST.1.1.3 Bekanntgabe
- TEST.5.1 Information betroffener Kreise

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- PERF.5.2 Bericht an die Institutionsleitung

Eintrag: installieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2.12 Sprungserver
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.4.1.2 Quarantäne
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.13 Produktdiversität
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.2 Redundante TK-Anbindung
- ARCH.8.3 Redundante Server
- ARCH.9.1 Dimensionierung der Netzanbindung
- ARCH.9.4 Content Delivery Network

- ASST.7.5 Vernichtungseinrichtungen
- BER.3.1 Zentrales Management
- BER.3.21 Notfallzugang
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.6.1 Passwortmanager
- DET.2.1.2 Meldeformulare
- DET.4.10 Host-basierte Köder
- DET.4.11.2 Netzwerk-Honeypots
- DET.6.2.2 Datenträgerschleuse
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- GEB.10.1 Klimatisierung
- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.1 Installation von Perimetern
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.5 Einbruchhemmung
- GEB.4.1 Einrichtung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- GEB.9.5 Strukturierte Datenverkabelung

- GEB.9.5.1 Physisch geschützte Verlegung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.3.4 Physischer Diebstahlschutz
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.2.1.3 Stabsraum
- NOT.4.11 Datenträgerarchiv
- NOT.4.9 Speichermedien
- TEST.3.1.4 Testumgebung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2.12 Sprungserver
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.4.1.2 Quarantäne
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.13 Produktdiversität
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.2 Redundante TK-Anbindung
- ARCH.8.3 Redundante Server
- ARCH.9.1 Dimensionierung der Netzanbindung
- ARCH.9.4 Content Delivery Network
- ASST.7.5 Vernichtungseinrichtungen
- BER.3.1 Zentrales Management
- BER.3.21 Notfallzugang
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.6.1 Passwortmanager
- DET.2.1.2 Meldeformulare
- DET.4.10 Host-basierte Köder
- DET.4.11.2 Netzwerk-Honeypots
- DET.6.2.2 Datenträgerschleuse
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- GEB.10.1 Klimatisierung
- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte

- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.1 Installation von Perimetern
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.5 Einbruchhemmung
- GEB.4.1 Einrichtung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.3.4 Physischer Diebstahlschutz
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.2.1.3 Stabsraum
- NOT.4.11 Datenträgerarchiv
- NOT.4.9 Speichermedien
- TEST.3.1.4 Testumgebung

Eintrag: löschen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.7.3 Geregeltes Löschen oder Vernichten
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.7 Beschriftungen entfernen
- BER.2.6 Löschen nach Fristablauf
- BER.3.13 Zugang löschen nach Fristablauf

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.7.3 Geregeltes Löschen oder Vernichten
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.7 Beschriftungen entfernen
- BER.2.6 Löschen nach Fristablauf
- BER.3.13 Zugang löschen nach Fristablauf

Eintrag: platzieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.7.2 Dedizierte Hardware
- ARCH.7.3 Entwicklungs- und Testumgebungen
- GEB.1.4 Exponierte Bereiche
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.1 Gesonderte Aufbewahrung
- GEB.8.1.1 Archiv
- NOT.4.10 Getrennte Aufbewahrung
- STM.2.1 Erstellung eines Anforderungspakets
- STM.3.1 ISMS-Anforderungen des Informationsverbundes

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.7.2 Dedizierte Hardware
- ARCH.7.3 Entwicklungs- und Testumgebungen
- GEB.1.4 Exponierte Bereiche
- GEB.6.2 Geschützte Aufstellung

- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.1 Gesonderte Aufbewahrung
- GEB.8.1.1 Archiv
- NOT.4.10 Getrennte Aufbewahrung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- STM.2.1 Erstellung eines Anforderungspakets
- STM.3.1 ISMS-Anforderungen des Informationsverbundes

Eintrag: protokollieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.4.4 Nachweis des Zugangs
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.3.3 Protokollierung von Änderungen
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
- DET.3.1.1 Authentifizierungen
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.6.1.1 Automatisierte Feststellung
- DEV.4.10 Protokollierung von Codeänderungen
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- TEST.2.1 Versionshistorie

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.4.4 Nachweis des Zugangs
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.3.3 Protokollierung von Änderungen
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
 - DET.3.1.1 Authentifizierungen
 - DET.3.1.10 Nutzungsstatistik
 - DET.3.1.11 Anwendungsspezifische Ereignisse
 - DET.3.1.12 Datenverarbeitungen
 - DET.3.1.13 Integration von Cloud-Diensten
 - DET.3.1.2 Ausgeführte Kommandozeilenbefehle
 - DET.3.1.3 Anbindung von Peripheriegeräten
 - DET.3.1.4 Systemfehler
 - DET.3.1.5 Störungen der Netzerreichbarkeit
 - DET.3.1.6 Systemspezifische Ereignisse
 - DET.3.1.7 Was, Wann, Wo
 - DET.3.1.8 Privilegierte Ereignisse
 - DET.3.1.9 Fehler der Anwendung
- DET.6.1.1 Automatisierte Feststellung
- DEV.4.10 Protokollierung von Codeänderungen
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- TEST.2.1 Versionshistorie

Eintrag: sensibilisieren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.12.1 Hohe Risiken

- SENS.2.1 Schutzziele
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.6 Papiervernichtung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.12 Öffentliche WLANs
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.15 Social Engineering Anrufe
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.2 Virensan
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.25 Zugang zum Fahrzeug
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links

- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.7.9 Aktive Inhalte
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten
- SENS.8.5 Verwahrung Intern
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise

BSI/Grundschutz/Quellkataloge/Kernel

- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.12.1 Hohe Risiken
- SENS.2.1 Schutzziele
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.5 Biometrische Authentifikation

- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.6 Papiervernichtung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.12 Öffentliche WLANs
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.15 Social Engineering Anrufe
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.2 Virensan
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.25 Zugang zum Fahrzeug
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links
- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.7.9 Aktive Inhalte
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten
- SENS.8.5 Verwahrung Intern
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise

Eintrag: testen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.3.1 Netzadeckung
- ASST.3.6 Verifikation
- ASST.6.3 Konformitätsprüfung
- ASST.7.4 Wiederherstelltest
- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- DET.5.10.4 Integritätsprüfung von Patches
- DET.5.3.3 Historische Analyse
- DET.6.2.1 Dynamische Sandbox-Analyse
- DEV.2.6.1 Eingabevalidierung
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DLS.4.1.1 Unabhängigkeit
- GEB.1.3.1 Abnahme von Standorten
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.2.4 Elektromagnetische Abschirmung
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- TEST.3.1 Sicherheitstest
- TEST.3.1.10 Penetrationstest bei Änderungen
- TEST.3.1.2 Integritätstest
- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering
- TEST.3.1.7 Analyse der Zusammensetzung
- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest
- TEST.4.1.1.1 Staging
- TEST.5.4 Persistenz

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.3.1 Netzadeckung
- ASST.3.6 Verifikation
- ASST.6.3 Konformitätsprüfung
- ASST.7.4 Wiederherstelltest
- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- DET.5.10.4 Integritätsprüfung von Patches
- DET.5.3.3 Historische Analyse
- DET.6.2.1 Dynamische Sandbox-Analyse
- DEV.2.6.1 Eingabevalidierung
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DLS.4.1.1 Unabhängigkeit
- GEB.1.3.1 Abnahme von Standorten
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.2.4 Elektromagnetische Abschirmung
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- TEST.3.1 Sicherheitstest
- TEST.3.1.10 Penetrationstest bei Änderungen
- TEST.3.1.2 Integritätstest
- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering
- TEST.3.1.7 Analyse der Zusammensetzung
- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest
- TEST.4.1.1.1 Staging
- TEST.5.4 Persistenz

Eintrag: überprüfen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.2 Regelmäßige Überprüfung
- ARCH.2.6 Topologieüberwachung
- ASST.1.2 Regelmäßige Überprüfung
- ASST.2.3.2.1 Software Discovery
- BER.1.2 Regelmäßige Überprüfung
- BER.2.3 Stammdatenprüfung
- BER.5.3 Überprüfung von Berechtigungen
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.7.14 Schlüssel vor Ablauf prüfen
- BES.1.2 Regelmäßige Überprüfung
- DET.1.2 Regelmäßige Überprüfung
- DET.3.3 Speicherkapazität
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen
- DET.4.18 Öffentliche Blocklisten
- DET.4.9 Manipulations-Checkup
- DET.5.1.1 Risikobasierte Priorisierung
- DET.5.3.2 Korrelation komplexer Angriffswege
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- DET.5.6 Threat Hunting
- DET.5.7 Analyse verdeckter Kanäle
- DET.5.8 Bedrohungsanalyse
- DET.5.8.1 Auswertung öffentlicher Quellen
- DEV.1.2 Regelmäßige Überprüfung
- DLS.1.2 Regelmäßige Überprüfung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.6 Portabilität
- GEB.1.2 Regelmäßige Überprüfung
- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.4.1 Niederohmigkeit
- GEB.3.7 Kontrolle der Zutrittskontrolle

- GEB.7.3 Schlüsselaudit
- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.2 Lasttest
- KONF.1.2 Regelmäßige Überprüfung
- KONF.10.5 Überprüfung der Konfiguration
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.2.5 Überprüfung der Konfiguration
- KONF.7.7 Regelmäßiger Funktionstest
- NOT.1.2 Regelmäßige Überprüfung
- NOT.2.1.4 Stabsübung
- NOT.3.4 Funktionstest
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.17 Anwendungstest
- PERF.1.1.1 Auswertung der Gefährdungslage
- PERF.1.1.2 Auswertung des Umsetzungsplans
- PERF.1.1.3 Auswertung von Auditergebnissen
- PERF.1.1.4 Auswertung von Sicherheitsvorfällen
- PERF.2.1 Überwachung der Einhaltung von Verpflichtungen
- PERF.5.1 Eignungsprüfung
- PERF.7.1 Aktualität der Anforderungen
- PERS.1.2 Regelmäßige Überprüfung
- PERS.4.1 Qualifikationsbedarf
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- REA.1.2 Regelmäßige Überprüfung
- REA.1.3 Übungen zur Vorfallsbehandlung
- REA.3.1 Verbesserung durch Erkenntnisse
- SENS.1.2 Erfolgsmessung
- STM.7.1 Überprüfung des gesetzten Sicherheitsniveaus
- TEST.1.2 Regelmäßige Überprüfung
- TEST.3.2 Testabdeckung
- TEST.5.5 Rückblick
- UMS.1.1 Ermittlung des Umsetzungsstatus
- VRB.2.2 Anpassung des ISMS
- VRB.6.1 Wirksamkeitsprüfung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.2 Regelmäßige Überprüfung
- ARCH.2.6 Topologieüberwachung
- ASST.1.2 Regelmäßige Überprüfung
- ASST.2.3.2.1 Software Discovery
- BER.1.2 Regelmäßige Überprüfung
- BER.2.3 Stammdatenprüfung
- BER.5.3 Überprüfung von Berechtigungen
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.7.14 Schlüssel vor Ablauf prüfen
- BES.1.2 Regelmäßige Überprüfung
- DET.1.2 Regelmäßige Überprüfung
- DET.3.3 Speicherkapazität
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen
- DET.4.18 Öffentliche Blocklisten
- DET.4.9 Manipulations-Checkup
- DET.5.1.1 Risikobasierte Priorisierung
- DET.5.3.2 Korrelation komplexer Angriffswege
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- DET.5.6 Threat Hunting
- DET.5.7 Analyse verdeckter Kanäle
- DET.5.8 Bedrohungsanalyse
- DET.5.8.1 Auswertung öffentlicher Quellen
- DEV.1.2 Regelmäßige Überprüfung
- DLS.1.2 Regelmäßige Überprüfung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.6 Portabilität
- GEB.1.2 Regelmäßige Überprüfung
- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.4.1 Niederohmigkeit
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.7.3 Schlüsselaudit

- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.2 Lasttest
- KONF.1.2 Regelmäßige Überprüfung
- KONF.10.5 Überprüfung der Konfiguration
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.2.5 Überprüfung der Konfiguration
- KONF.7.7 Regelmäßiger Funktionstest
- NOT.1.2 Regelmäßige Überprüfung
- NOT.2.1.4 Stabsübung
- NOT.3.4 Funktionstest
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.17 Anwendungstest
- PERS.1.2 Regelmäßige Überprüfung
- PERS.4.1 Qualifikationsbedarf
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- REA.1.2 Regelmäßige Überprüfung
- REA.1.3 Übungen zur Vorfallsbehandlung
- REA.3.1 Verbesserung durch Erkenntnisse
- SENS.1.2 Erfolgsmessung
- TEST.1.2 Regelmäßige Überprüfung
- TEST.3.2 Testabdeckung
- TEST.5.5 Rückblick

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- PERF.1.1.1 Auswertung der Gefährdungslage
- PERF.1.1.2 Auswertung des Umsetzungsplans
- PERF.1.1.3 Auswertung von Auditergebnissen
- PERF.1.1.4 Auswertung von Sicherheitsvorfällen
- PERF.2.1 Überwachung der Einhaltung von Verpflichtungen
- PERF.5.1 Eignungsprüfung
- PERF.7.1 Aktualität der Anforderungen
- STM.7.1 Überprüfung des gesetzten Sicherheitsniveaus
- UMS.1.1 Ermittlung des Umsetzungsstatus
- VRB.2.2 Anpassung des ISMS
- VRB.6.1 Wirksamkeitsprüfung

Eintrag: überwachen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.6.10 Monitoring von Zugangsdaten
- DET.4.1 Überwachung der Protokollierung
- DET.4.11 Anomalien in Netzen und am Perimeter
- DET.4.11.3 Netzverkehrsfluss
- DET.4.12 Monitoring der Netzverfügbarkeit
- DET.4.12.1 Auslastung des Netzes
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.15 Ressourcenauslastung von Hostsystemen
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.19 Unautorisierte Sendeanlagen
- DET.4.2 Automatische Angriffserkennung
- DET.4.3 Überwachung der Angriffserkennung
- DET.4.4 Änderungen an Sicherheitsrichtlinien
- DET.4.5 Unerwünschte Datenabflüsse
- DET.4.6 Anomale Nutzung der Anwendung
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DET.5.8.1.1 Unautorisierte Publikation
- DEV.7.2 Zertifikatsmonitoring
- GEB.10.1.2 Klimamessung
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.3.2 Leckagesensor
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.6 Einbruchmeldeanlagen
- GEB.8.4 Überwachung schonender Klimatisierung
- KONF.8.1 Automatische Überprüfung
- PERF.6.1.1 Sicherheitsvorfälle

BSI/Grundschutz/Quellkataloge/Kernel

- BER.6.10 Monitoring von Zugangsdaten
- DET.4.1 Überwachung der Protokollierung
- DET.4.11 Anomalien in Netzen und am Perimeter
- DET.4.11.3 Netzverkehrsfluss
- DET.4.12 Monitoring der Netzverfügbarkeit
- DET.4.12.1 Auslastung des Netzes
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.15 Ressourcenauslastung von Hostsystemen
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.19 Unautorisierte Sendeanlagen
- DET.4.2 Automatische Angriffserkennung
- DET.4.3 Überwachung der Angriffserkennung
- DET.4.4 Änderungen an Sicherheitsrichtlinien
- DET.4.5 Unerwünschte Datenabflüsse
- DET.4.6 Anomale Nutzung der Anwendung
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DET.5.8.1.1 Unautorisierte Publikation
- DEV.7.2 Zertifikatsmonitoring
- GEB.10.1.2 Klimamessung
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.3.2 Leckagesensor
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.6 Einbruchmeldeanlagen
- GEB.8.4 Überwachung schonender Klimatisierung
- KONF.8.1 Automatische Überprüfung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- PERF.6.1.1 Sicherheitsvorfälle

Eintrag: untersagen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.3.15 Keine Gruppenkonten
- BER.7.10 Abgelaufene Schlüssel
- BER.7.9 Zweckbindung
- BES.3.3 Unzuverlässige Lieferanten
- DEV.4.2 Bibliotheksquellen
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.9.7 Zweckentfremdung
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.9.6 Mitnahme ins Ausland

BSI/Grundschutz/Quellkataloge/Kernel

- BER.3.15 Keine Gruppenkonten
- BER.7.10 Abgelaufene Schlüssel
- BER.7.9 Zweckbindung
- BES.3.3 Unzuverlässige Lieferanten
- DEV.4.2 Bibliotheksquellen
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.9.7 Zweckentfremdung
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.7.14 Unautorisierte WLANs

- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.9.6 Mitnahme ins Ausland

Eintrag: verankern

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1 Verfahren und Regelungen
- ARCH.2.1 Netzsegmente
- ASST.1.1 Verfahren und Regelungen
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- ASST.3.14 Reserve physischer Assets
- ASST.3.15 Ausleihe physischer Assets
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.7.1 Nicht mehr benötigte Anwendungen
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Löschverfahren
- BER.1.1 Verfahren und Regelungen
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.5 Privilegierte Zugangskonten
- BER.5.8 Entzug von Berechtigungen
- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
- BER.7.11 Integrität

- BER.7.12 Authentizität
- BER.7.13 Gültigkeit
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BES.1.1 Verfahren und Regelungen
- BES.1.4 Outsourcing-Strategie
- BES.3.2 Auswahlkriterien
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.4.3 Beschaffung anhand der Kriterien
- BES.7.2 Prozesse vor Netzanbindung
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- DET.1.1 Verfahren und Regelungen
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.2.1.3 Rückmeldungen
- DET.2.3 Ständiger Bereitschaftsdienst
- DET.5.1 Zeitnahes Schwachstellenmanagement
- DET.5.10 Zeitnahes Patchmanagement
- DET.5.3 Schwachstellenscans
- DET.5.9 Externe Schwachstellenmeldungen
- DET.5.9.1 Bonusprogramm
- DET.6.1 Beurteilung von Ereignissen
- DET.6.2 Beurteilung von Eingängen
- DEV.1.1 Verfahren und Regelungen
- DEV.2.1 Security by Design Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.7.1 Sichere Bereitstellung
- DLS.1.1 Verfahren und Regelungen
- DLS.4.1 Dekommissionierung
- GC.1.1 Errichtung und Aufrechterhaltung eines ISMS
- GC.11.1 Methodik für das Risikomanagement

- GC.2.1 Festlegung des externen Kontextes der Institution
- GC.2.2 Festlegung des internen Kontextes der Institution
- GC.3.1 Analyse der externen interessierten Parteien
- GC.3.2 Analyse der internen interessierten Parteien
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
- GC.7.1 Verfahren und Regelungen
- GC.7.1.4 Prävention von Verstößen
- GC.8.1 Verfahren zur Ressourcenplanung
- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement
- GC.9.1.2 Kommunikation im Projektmanagement
- GC.9.1.3 Dokumentenlenkung
- GEB.1.1 Verfahren und Regelungen
- GEB.10.2 Brandschutz
- GEB.8.2 Staub und Schmutz
- KONF.1.1 Verfahren und Regelungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- NOT.1.1 Verfahren und Regelungen
- NOT.1.1.4 Business Continuity Management System
- NOT.2.1 Verfahren und Regelungen
- NOT.2.1.2 Alarmierung
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen
- NOT.4.12 Georedundanz
- NOT.4.6 Geschützte Aufbewahrung
- NOT.4.7 Versionierte Datensicherung
- PERF.1.1 Verfahren und Regelungen
- PERF.3.1 Aufbau und Pflege eines Auditprogramms
- PERF.4.1 Dokumentation von Auditergebnissen
- PERF.6.1 Sicherheitsvorfälle
- PERS.1.1 Verfahren und Regelungen
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.3 Rollentrennung
- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung

- PERS.2.3.3 Rollentrennung - Audits
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.5.1 Maßregelung
- PERS.5.2 Innentäter
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- REA.1.1 Verfahren und Regelungen
- REA.2.4 Diagnosedaten
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.6 Ursachenanalyse und Behandlung
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.3 Koordinierung
- REA.2.6.4 Service Level
- REA.2.6.5 Eskalation
- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.3 Risikoeigentümer
- SENS.1.1 Verfahren und Regelungen
- TEST.1.1 Verfahren und Regelungen
- TEST.3.1.3 Testdaten
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen
- UMS.3.1 Umsetzungsplanung
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.1.1 Verfahren zur kontinuierlichen Verbesserung
- VRB.1.2 Änderungen im ISMS
- VRB.3.1 Identifikation von Verbesserungspotenzialen
- VRB.7.1 Bewertung der erreichten Verbesserung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1 Verfahren und Regelungen
- ARCH.2.1 Netzsegmente
- ASST.1.1 Verfahren und Regelungen
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- ASST.3.14 Reserve physischer Assets

- ASST.3.15 Ausleihe physischer Assets
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.7.1 Nicht mehr benötigte Anwendungen
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Löschverfahren
- BER.1.1 Verfahren und Regelungen
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.5 Privilegierte Zugangskonten
- BER.5.8 Entzug von Berechtigungen
- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
- BER.7.11 Integrität
- BER.7.12 Authentizität
- BER.7.13 Gültigkeit
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BES.1.1 Verfahren und Regelungen
- BES.1.4 Outsourcing-Strategie
- BES.3.2 Auswahlkriterien
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.4.3 Beschaffung anhand der Kriterien

- BES.7.2 Prozesse vor Netzanbindung
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- DET.1.1 Verfahren und Regelungen
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.2.1.3 Rückmeldungen
- DET.2.3 Ständiger Bereitschaftsdienst
- DET.5.1 Zeitnahes Schwachstellenmanagement
- DET.5.10 Zeitnahes Patchmanagement
- DET.5.3 Schwachstellenscans
- DET.5.9 Externe Schwachstellenmeldungen
- DET.5.9.1 Bonusprogramm
- DET.6.1 Beurteilung von Ereignissen
- DET.6.2 Beurteilung von Eingängen
- DEV.1.1 Verfahren und Regelungen
- DEV.2.1 Security by Design Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.7.1 Sichere Bereitstellung
- DLS.1.1 Verfahren und Regelungen
- DLS.4.1 Dekomissionierung
- GEB.1.1 Verfahren und Regelungen
- GEB.10.2 Brandschutz
- GEB.8.2 Staub und Schmutz
- KONF.1.1 Verfahren und Regelungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- NOT.1.1 Verfahren und Regelungen
- NOT.1.1.4 Business Continuity Management System
- NOT.2.1 Verfahren und Regelungen
- NOT.2.1.2 Alarmierung
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen
- NOT.4.12 Georedundanz
- NOT.4.6 Geschützte Aufbewahrung
- NOT.4.7 Versionierte Datensicherung

- PERS.1.1 Verfahren und Regelungen
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.3 Rollentrennung
- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.5.1 Maßregelung
- PERS.5.2 Innentäter
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- REA.1.1 Verfahren und Regelungen
- REA.2.4 Diagnosedaten
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.6 Ursachenanalyse und Behandlung
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.3 Koordinierung
- REA.2.6.4 Service Level
- REA.2.6.5 Eskalation
- SENS.1.1 Verfahren und Regelungen
- TEST.1.1 Verfahren und Regelungen
- TEST.3.1.3 Testdaten
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.1.1 Errichtung und Aufrechterhaltung eines ISMS
- GC.11.1 Methodik für das Risikomanagement
- GC.2.1 Festlegung des externen Kontextes der Institution
- GC.2.2 Festlegung des internen Kontextes der Institution
- GC.3.1 Analyse der externen interessierten Parteien
- GC.3.2 Analyse der internen interessierten Parteien
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
- GC.7.1 Verfahren und Regelungen
- GC.7.1.4 Prävention von Verstößen
- GC.8.1 Verfahren zur Ressourcenplanung

- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement
- GC.9.1.2 Kommunikation im Projektmanagement
- GC.9.1.3 Dokumentenlenkung
- PERF.1.1 Verfahren und Regelungen
- PERF.3.1 Aufbau und Pflege eines Auditprogramms
- PERF.4.1 Dokumentation von Auditergebnissen
- PERF.6.1 Sicherheitsvorfälle
- UMS.3.1 Umsetzungsplanung
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.1.1 Verfahren zur kontinuierlichen Verbesserung
- VRB.1.2 Änderungen im ISMS
- VRB.3.1 Identifikation von Verbesserungspotenzialen
- VRB.7.1 Bewertung der erreichten Verbesserung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.3 Risikoeigentümer
- RISK.1.6 Kritikalitätskriterien für Geschäftsprozesse
- RISK.1.7 Kriterien für die Risikobeurteilung
- RISK.1.8 Kriterien für die Risikoakzeptanz
- RISK.1.9 Bestätigung des Restrisikos

Eintrag: vereinbaren

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.4.5 Security by Design
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.5.2 Mandantentrennung
- BES.4.6 Security by Default
- BES.4.6.1 Authentifizierung des Kunden

- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.6.3 Manipulationsschutz
- BES.4.7 ISMS beim Dienstleister
- BES.4.8 Konformitätsnachweise
- BES.4.8.1 Zertifizierung
- BES.4.8.2 Cloud-Konformität
- BES.4.8.3 IT-Grundschutz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.1 Kompetenzen
- BES.5.10 Behandlung von Vorfällen
- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.11 Recht auf Audit
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.13.1 Datenbereitstellung
- BES.5.14 Löschregeln
- BES.5.2 Service Level Agreement
- BES.5.3 Compliance-Verpflichtungen
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.5 Nutzungsregelungen
- BES.5.5.1 Datenlokationen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.5.7 Schulung
- BES.5.8 Rechte für geistiges Eigentum
- BES.5.9 Umgang mit Änderungen
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten

- BES.6.2.1 Löschverfahren
- BES.6.3 Übertragbarkeit von Daten
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.8.4 Individuelle Implementierung kritischer Komponenten
- BES.8.5 Treuhand
- PERS.3.1 Dienst- oder Arbeitsvertrag
- REA.2.5.3 Forensik-Dienstleister

BSI/Grundschatz/Quellkataloge/Kernel

- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.4.5 Security by Design
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.5.2 Mandantentrennung
- BES.4.6 Security by Default
- BES.4.6.1 Authentifizierung des Kunden
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.6.3 Manipulationsschutz
- BES.4.7 ISMS beim Dienstleister
- BES.4.8 Konformitätsnachweise
- BES.4.8.1 Zertifizierung
- BES.4.8.2 Cloud-Konformität
- BES.4.8.3 IT-Grundschatz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.1 Kompetenzen
- BES.5.10 Behandlung von Vorfällen
- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.11 Recht auf Audit
- BES.5.12 Informationspflichten

- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.13.1 Datenbereitstellung
- BES.5.14 Löschregeln
- BES.5.2 Service Level Agreement
- BES.5.3 Compliance-Verpflichtungen
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.5 Nutzungsregelungen
- BES.5.5.1 Datenlokationen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.5.7 Schulung
- BES.5.8 Rechte für geistiges Eigentum
- BES.5.9 Umgang mit Änderungen
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.2.1 Lösungsverfahren
- BES.6.3 Übertragbarkeit von Daten
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.8.4 Individuelle Implementierung kritischer Komponenten
- BES.8.5 Treuhand
- PERS.3.1 Dienst- oder Arbeitsvertrag
- REA.2.5.3 Forensik-Dienstleister

Eintrag: verschlüsseln

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- DLS.2.2 Transportverschlüsselung
- DLS.2.3 Vollverschlüsselung
- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen

- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.3.2 Speicherverschlüsselung
- KONF.4.2.1 DNS-Verschlüsselung
- NOT.4.8 Verschlüsselte Datensicherung
- TEST.5.2 Verschlüsselte Bereitstellung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- DLS.2.2 Transportverschlüsselung
- DLS.2.3 Vollverschlüsselung
- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.3.2 Speicherverschlüsselung
- KONF.4.2.1 DNS-Verschlüsselung
- NOT.4.8 Verschlüsselte Datensicherung
- TEST.5.2 Verschlüsselte Bereitstellung

Eintrag: zuweisen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1.2 Zuweisung der Aufgaben
- ASST.1.1.2 Zuweisung der Aufgaben
- ASST.2.1.1 Informationsverantwortung
- ASST.2.4 Klassifizierung
- ASST.3.5 Tainting
- BER.1.1.2 Zuweisung der Aufgaben
- BER.2.1 Person-Identität
- BER.3.4 Identität-Zugangskonto
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.7 IT-System-Zugangskonto
- BER.7.16.1 Zertifizierungsstelle

- BER.7.2 Schlüssellänge
- BES.1.1.2 Zuweisung der Aufgaben
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.8.3 Ressourcensouveränität
- DET.1.1.2 Zuweisung der Aufgaben
- DET.2.2 Security Operations Center
- DEV.1.1.2 Zuweisung der Aufgaben
- DLS.1.1.2 Zuweisung der Aufgaben
- GC.6.1.2 Verpflichtung der Institutionsleitung
- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.1.1 Informationssicherheitsbeauftragter
- GC.8.1.2 Stellvertreterregelungen
- GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.7.1 Schlüsselbeauftragte
- KONF.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.2 Zuweisung der Aufgaben
- NOT.2.1.1 Rollen
- PERS.1.1.2 Zuweisung der Aufgaben
- PERS.2.4 Zuständigkeiten
- PERS.6.1.2 Neubesetzung
- REA.1.1.2 Zuweisung der Aufgaben
- REA.2.1 Triage und Erstreaktion
- SENS.1.1.2 Zuweisung der Aufgaben
- STM.4.3 Mapping des Assets auf die Zielobjektkategorien
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- TEST.1.1.2 Zuweisung der Aufgaben
- TEST.2.2.1 Kategorisierung von Änderungen
- UMS.4.1 Benennung von Umsetzungszuständigen
- VRB.5.1 Priorisierung von Maßnahmen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1.2 Zuweisung der Aufgaben
- ASST.1.1.2 Zuweisung der Aufgaben
- ASST.2.1.1 Informationsverantwortung

- ASST.2.4 Klassifizierung
- ASST.3.5 Tainting
- BER.1.1.2 Zuweisung der Aufgaben
- BER.2.1 Person-Identität
- BER.3.4 Identität-Zugangskonto
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.7 IT-System-Zugangskonto
- BER.7.16.1 Zertifizierungsstelle
- BER.7.2 Schlüssellänge
- BES.1.1.2 Zuweisung der Aufgaben
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.8.3 Ressourcensouveränität
- DET.1.1.2 Zuweisung der Aufgaben
- DET.2.2 Security Operations Center
- DEV.1.1.2 Zuweisung der Aufgaben
- DLS.1.1.2 Zuweisung der Aufgaben
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.7.1 Schlüsselbeauftragte
- KONF.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.2 Zuweisung der Aufgaben
- NOT.2.1.1 Rollen
- PERS.1.1.2 Zuweisung der Aufgaben
- PERS.2.4 Zuständigkeiten
- PERS.6.1.2 Neubesetzung
- REA.1.1.2 Zuweisung der Aufgaben
- REA.2.1 Triage und Erstreaktion
- SENS.1.1.2 Zuweisung der Aufgaben
- TEST.1.1.2 Zuweisung der Aufgaben
- TEST.2.2.1 Kategorisierung von Änderungen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.6.1.2 Verpflichtung der Institutionsleitung
- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.1.1 Informationssicherheitsbeauftragter
- GC.8.1.2 Stellvertreterregelungen
- GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten

- STM.4.3 Mapping des Assets auf die Zielobjektkategorien
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- UMS.4.1 Benennung von Umsetzungszuständigen
- VRB.5.1 Priorisierung von Maßnahmen

Namespace: documentation_guidelines

Eintrag: ???

Keine Controls gefunden.

Eintrag: Abnahmeprotokoll

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4 Vollständigkeit der Unterlagen
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.2.4 Elektromagnetische Abschirmung

BSI/Grundschutz/Quellkataloge/Kernel

- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4 Vollständigkeit der Unterlagen
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.2.4 Elektromagnetische Abschirmung

Eintrag: Arbeitsanweisung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.3.5 Tainting
- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.6.3 Konformitätsprüfung
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3 Geregeltes Löschen oder Vernichten
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.6.2.2 Datenträgerschleuse
- DEV.4.2 Bibliotheksquellen
- GC.7.1.4 Prävention von Verstößen
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.3.4 Berechtigungsmarkierung
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.9.7 Zweckentfremdung
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- REA.2.6 Ursachenanalyse und Behandlung
- SENS.2.2 Meldewege

- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.2.8 Melden von Ereignissen
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.5.5 Löschfristen
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.8.4 Begleitung Externer
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.3 Verwahrung außer Haus
- SENS.9.6 Mitnahme ins Ausland

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.3.10 Autorisierung von Datenloktionen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.3.5 Tainting
- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung

- ASST.3.9 Aktualisierung
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.6.3 Konformitätsprüfung
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3 Geregeltes Löschen oder Vernichten
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.6.2.2 Datenträgerschleuse
- DEV.4.2 Bibliotheksquellen
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.3.4 Berechtigungsmarkierung
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.9.7 Zweckentfremdung
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- REA.2.6 Ursachenanalyse und Behandlung
- SENS.2.2 Meldewege
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.2.8 Melden von Ereignissen
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.5.5 Löschfristen
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.7.20 Authentifizierung von Gesprächspartnern

- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.8.4 Begleitung Externer
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.3 Verwahrung außer Haus
- SENS.9.6 Mitnahme ins Ausland

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.7.1.4 Prävention von Verstößen

Eintrag: Arbeitsvertrag

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- PERS.3.1 Dienst- oder Arbeitsvertrag

BSI/Grundschutz/Quellkataloge/Kernel

- PERS.3.1 Dienst- oder Arbeitsvertrag

Eintrag: Audit Log

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.4.4 Nachweis des Zugangs
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.3.3 Protokollierung von Änderungen
- DET.3.1.1 Authentifizierungen
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.5 Störungen der Netzerreichbarkeit

- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.4.11.3 Netzverkehrsfluss
- GEB.3.3.2 Dokumentation von Zutritten
- TEST.2.1 Versionshistorie

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.4.4 Nachweis des Zugangs
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.3.3 Protokollierung von Änderungen
- DET.3.1.1 Authentifizierungen
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.4.11.3 Netzverkehrsfluss
- GEB.3.3.2 Dokumentation von Zutritten
- TEST.2.1 Versionshistorie

Eintrag: Auditbericht

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- PERF.4.1 Dokumentation von Auditergebnissen
- PERF.4.1.1 Einheitliches Bewertungsschema
- PERF.4.1.2 Kommunikation an Stakeholder

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- PERF.4.1 Dokumentation von Auditergebnissen
- PERF.4.1.1 Einheitliches Bewertungsschema
- PERF.4.1.2 Kommunikation an Stakeholder

Eintrag: Auslagerungsregister

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.7.4.10 Serviceprofil
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DLS.3.1.1 Audit oder Zertifikat

BSI/Grundschutz/Quellkataloge/Kernel

- BES.7.4.10 Serviceprofil
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DLS.3.1.1 Audit oder Zertifikat

Eintrag: BC-Leitlinie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- NOT.1.1 Verfahren und Regelungen
- NOT.1.1.4 Business Continuity Management System

BSI/Grundschutz/Quellkataloge/Kernel

- NOT.1.1 Verfahren und Regelungen
- NOT.1.1.4 Business Continuity Management System

Eintrag: Behandlung von Sicherheitsvorfällen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- REA.2.1 Triage und Erstreaktion
- REA.2.3 Dokumentation von Vorfällen
- REA.2.4 Diagnosedaten
- REA.2.5 IT-Forensik
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.6.1 Dokumentation des Vorgehens
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.2.1 Information zuständiger Behörden
- REA.2.6.3 Koordinierung
- REA.2.6.4 Service Level
- REA.2.6.5 Eskalation
- REA.3.1 Verbesserung durch Erkenntnisse
- REA.3.1.1 Quantitative Analyse

BSI/Grundschutz/Quellkataloge/Kernel

- REA.2.1 Triage und Erstreaktion
- REA.2.3 Dokumentation von Vorfällen
- REA.2.4 Diagnosedaten
- REA.2.5 IT-Forensik
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.6.1 Dokumentation des Vorgehens
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.2.1 Information zuständiger Behörden
- REA.2.6.3 Koordinierung
- REA.2.6.4 Service Level
- REA.2.6.5 Eskalation
- REA.3.1 Verbesserung durch Erkenntnisse
- REA.3.1.1 Quantitative Analyse

Eintrag: Bereinigter Netzplan

Keine Controls gefunden.

Eintrag: Betriebshandbuch

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Geregelte Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.7.4.5 Netzverbindungen ab Werk
- DLS.3.4 Anhörung
- DLS.4.1 Dekommissionierung
- DLS.4.1.2 Berechtigungen deaktivieren
- GEB.5.4 Schutz gegen Manipulation
- KONF.3.4 Physischer Diebstahlschutz

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Geregelte Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.7.4.5 Netzverbindungen ab Werk
- DLS.3.4 Anhörung
- DLS.4.1 Dekommissionierung
- DLS.4.1.2 Berechtigungen deaktivieren
- GEB.5.4 Schutz gegen Manipulation
- KONF.3.4 Physischer Diebstahlschutz

Eintrag: Codehistorie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default

Eintrag: Compliance-Verpflichtungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.7.1 Verfahren und Regelungen
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.7.1.2 Anhörung zuständiger Stellen
- GC.7.1.3 Vertragliche Verpflichtungen
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.7.1 Verfahren und Regelungen
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.7.1.2 Anhörung zuständiger Stellen
- GC.7.1.3 Vertragliche Verpflichtungen
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.8.1 Behandlung von Compliance-Verstößen

Eintrag: Datensicherungskonzept

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- NOT.4.1 Dokumentation der Quellen
- NOT.4.10 Getrennte Aufbewahrung
- NOT.4.11 Datenträgerarchiv
- NOT.4.12 Georedundanz

- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.15 Vorgehen zur Wiederherstellung
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.17 Anwendungstest
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation
- NOT.4.6 Geschützte Aufbewahrung
- NOT.4.7 Versionierte Datensicherung
- NOT.4.8 Verschlüsselte Datensicherung
- NOT.4.9 Speichermedien

BSI/Grundschutz/Quellkataloge/Kernel

- NOT.4.1 Dokumentation der Quellen
- NOT.4.10 Getrennte Aufbewahrung
- NOT.4.11 Datenträgerarchiv
- NOT.4.12 Georedundanz
- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.15 Vorgehen zur Wiederherstellung
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.17 Anwendungstest
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation
- NOT.4.6 Geschützte Aufbewahrung
- NOT.4.7 Versionierte Datensicherung
- NOT.4.8 Verschlüsselte Datensicherung

- NOT.4.9 Speichermedien

Eintrag: Detektionskonzept

Keine Controls gefunden.

Eintrag: Entwicklungsdokumentation

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.2.1 Security by Design Architektur
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.7 Deterministischer Binärcode
- DEV.4.8 Default-Zugangsdaten
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.6.1 Freigabe nach Änderungen und Tests
- DEV.7.1 Sichere Bereitstellung

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.2.1 Security by Design Architektur
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.7 Deterministischer Binärcode
- DEV.4.8 Default-Zugangsdaten
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.6.1 Freigabe nach Änderungen und Tests
- DEV.7.1 Sichere Bereitstellung

Eintrag: Ergebnisprotokoll

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.3.8 Ereignisgesteuerte Deaktivierung

- DLS.4.1.1 Unabhängigkeit
- TEST.2.2.2 Anpassung der Dokumentation

BSI/Grundschutz/Quellkataloge/Kernel

- BER.3.8 Ereignisgesteuerte Deaktivierung
- DLS.4.1.1 Unabhängigkeit
- TEST.2.2.2 Anpassung der Dokumentation

Eintrag: Firewallregeln

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe

- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen

Eintrag: Freigabeplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
 - DEV.2.6.1 Eingabevalidierung
 - DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.3.4 Passwort-Hashing
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.6 Compileroptionen
- TEST.3.1 Sicherheitstest
 - TEST.3.1.1 Dokumentation von Testergebnissen
 - TEST.3.1.10 Penetrationstest bei Änderungen
 - TEST.3.1.2 Integritätstest
 - TEST.3.1.5 Kontinuierliche Tests
 - TEST.3.1.6 Chaos Engineering
 - TEST.3.1.7 Analyse der Zusammensetzung
 - TEST.3.1.8 Fuzzing
 - TEST.3.1.9 Lasttest

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.2.3 Ausführbarkeit mit minimalen Rechten

- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
 - DEV.2.6.1 Eingabevalidierung
 - DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.3.4 Passwort-Hashing
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.6 Compileroptionen
- TEST.3.1 Sicherheitstest
 - TEST.3.1.1 Dokumentation von Testergebnissen
 - TEST.3.1.10 Penetrationstest bei Änderungen
 - TEST.3.1.2 Integritätstest
 - TEST.3.1.5 Kontinuierliche Tests
 - TEST.3.1.6 Chaos Engineering
 - TEST.3.1.7 Analyse der Zusammensetzung
 - TEST.3.1.8 Fuzzing
 - TEST.3.1.9 Lasttest

Eintrag: Freigegebene Ausnahmegenehmigung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- UMS.5.2 Dokumentation von Ausnahmen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- UMS.5.2 Dokumentation von Ausnahmen

Eintrag: Gebäudedokumentation

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung

- GEB.10.2 Brandschutz
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.1 Installation von Perimetern
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.5 Einbruchhemmung
- GEB.4.1 Einrichtung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.1 Gesonderte Aufbewahrung
- GEB.8.1.1 Archiv
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung

BSI/Grundschutz/Quellkataloge/Kernel

- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
- GEB.10.2 Brandschutz
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.1 Installation von Perimetern
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.5 Einbruchhemmung
- GEB.4.1 Einrichtung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.1 Gesonderte Aufbewahrung
- GEB.8.1.1 Archiv
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung

Eintrag: Geschäftsprozesse

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.2.1.2 Geschäftsprozessprofile
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität
- GC.5.1.1 Festlegung der Geschäftsprozesse

BSI/Grundschutz/Quellkataloge/Kernel

- BES.2.1.2 Geschäftsprozessprofile
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.5.1.1 Festlegung der Geschäftsprozesse

Eintrag: Geschäftsverteilungsplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1.2 Zuweisung der Aufgaben
- ASST.1.1.2 Zuweisung der Aufgaben
- BER.1.1.2 Zuweisung der Aufgaben
- BES.1.1.2 Zuweisung der Aufgaben
- DET.1.1.2 Zuweisung der Aufgaben
- DEV.1.1.2 Zuweisung der Aufgaben
- DLS.1.1.2 Zuweisung der Aufgaben
- GC.8.1.2 Stellvertreterregelungen
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.7.1 Schlüsselbeauftragte
- KONF.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.2 Zuweisung der Aufgaben

- PERS.1.1.2 Zuweisung der Aufgaben
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.3 Rollentrennung
- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.2.4 Zuständigkeiten
- REA.1.1.2 Zuweisung der Aufgaben
- SENS.1.1.2 Zuweisung der Aufgaben
- TEST.1.1.2 Zuweisung der Aufgaben

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1.2 Zuweisung der Aufgaben
- ASST.1.1.2 Zuweisung der Aufgaben
- BER.1.1.2 Zuweisung der Aufgaben
- BES.1.1.2 Zuweisung der Aufgaben
- DET.1.1.2 Zuweisung der Aufgaben
- DEV.1.1.2 Zuweisung der Aufgaben
- DLS.1.1.2 Zuweisung der Aufgaben
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.7.1 Schlüsselbeauftragte
- KONF.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.2 Zuweisung der Aufgaben
- PERS.1.1.2 Zuweisung der Aufgaben
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.3 Rollentrennung
- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.2.4 Zuständigkeiten
- REA.1.1.2 Zuweisung der Aufgaben
- SENS.1.1.2 Zuweisung der Aufgaben
- TEST.1.1.2 Zuweisung der Aufgaben

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.8.1.2 Stellvertreterregelungen

Eintrag: Informationssicherheitsleitlinie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.6.1.4 Freigabe der Sicherheitsleitlinie

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.6.1.4 Freigabe der Sicherheitsleitlinie

Eintrag: Informationssicherheitsstrategie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.6.1 Festlegung von Zielen für die Informationssicherheit
- GC.6.1.1 Festlegung einer Sicherheitsstrategie

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.6.1 Festlegung von Zielen für die Informationssicherheit
- GC.6.1.1 Festlegung einer Sicherheitsstrategie

Eintrag: Informationsverbund

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen

Eintrag: Inventar Anwendungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.2.3 Inventar der Anwendungen
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.2.3.2 Software Bill of Materials (SBOM)

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.2.3 Inventar der Anwendungen
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.2.3.2 Software Bill of Materials (SBOM)

Eintrag: Inventar Berechtigungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.1.1 Verfahren und Regelungen
- BER.1.4 Inventar der Berechtigungen
- BER.2.1 Person-Identität
- BER.2.3 Stammdatenprüfung
- BER.2.5 Deaktivierung bei Weggang
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.20 Dienstkonten
- BER.3.21 Notfallzugang
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.3.5 Privilegierte Zugangskonten
- BER.5.1 Prinzip der geringsten Berechtigungen
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.5.2 Begründung von Berechtigungen
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.5.7 IT-System-Zugangskonto
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur

BSI/Grundschutz/Quellkataloge/Kernel

- BER.1.1 Verfahren und Regelungen
- BER.1.4 Inventar der Berechtigungen
- BER.2.1 Person-Identität
- BER.2.3 Stammdatenprüfung
- BER.2.5 Deaktivierung bei Weggang
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.20 Dienstkonten
- BER.3.21 Notfallzugang
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.3.5 Privilegierte Zugangskonten
- BER.5.1 Prinzip der geringsten Berechtigungen
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.5.2 Begründung von Berechtigungen
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.5.7 IT-System-Zugangskonto
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur

Eintrag: Inventar Berechtigungssysteme

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme

BSI/Grundschutz/Quellkataloge/Kernel

- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme

Eintrag: Inventar Informationen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.2.1 Inventar der Informationen
- ASST.2.1.1 Informationsverantwortung
- ASST.2.4 Klassifizierung

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.2.1 Inventar der Informationen
- ASST.2.1.1 Informationsverantwortung
- ASST.2.4 Klassifizierung

Eintrag: Inventar IT-Systeme

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.2.2 Inventar der Systeme

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.2.2 Inventar der Systeme

Eintrag: Inventar Standorte

Keine Controls gefunden.

Eintrag: ISMS-Regelwerk

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.10.1 Festlegung von Vorgehensweisen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.10.1 Festlegung von Vorgehensweisen

Eintrag: IT-Betriebskonzept

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1.1 Dokumentation
- ARCH.1.1.3 Bekanntgabe
- ARCH.2.6 Topologieüberwachung
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.13 Produktdiversität

- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.9.1 Dimensionierung der Netzanbindung
- ASST.1.1 Verfahren und Regelungen
 - ASST.1.1.1 Dokumentation
 - ASST.1.1.3 Bekanntgabe
- ASST.2.3.2.1 Software Discovery
- ASST.3.13 Lagerung physischer Assets
- ASST.3.14 Reserve physischer Assets
- ASST.3.15 Ausleihe physischer Assets
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.5 Wartungsfenster
- ASST.5.6 Wartung durch Externe
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- ASST.7.1 Nicht mehr benötigte Anwendungen
 - ASST.7.3.1 Standardisierte Vernichtung
 - ASST.7.3.2 Lösungsverfahren
 - ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.4 Wiederherstelltest
- ASST.7.5 Vernichtungseinrichtungen
- ASST.7.6 Autorisierung von Veräußerungen
- ASST.7.7 Beschriftungen entfernen
- BER.2.6 Löschen nach Fristablauf
- BER.3.1 Zentrales Management
 - BER.3.13 Zugang löschen nach Fristablauf
 - BER.3.14 Zugang nur durch zwei Personen
 - BER.3.15 Keine Gruppenkonten
 - BER.3.16 Gruppenkonten - MFA
 - BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.4 Identität-Zugangskonto
- BER.4.1 Identitätsüberprüfung
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.5.8 Entzug von Berechtigungen
- BER.6.1 Passwortmanager
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.3 Deaktivierung einfacher Biometrie
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen

- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.6.9 Anlassbezogene Passwortwechsel
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
- BER.7.10 Abgelaufene Schlüssel
- BER.7.11 Integrität
- BER.7.12 Authentizität
- BER.7.13 Gültigkeit
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.16.1 Zertifizierungsstelle
- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.7 Kein Transport privater Schlüssel
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BER.7.9 Zweckbindung
- BES.1.1.1 Dokumentation
- BES.1.1.3 Bekanntgabe
- DET.1.1.1 Dokumentation
- DET.1.1.3 Bekanntgabe
- DEV.1.1.1 Dokumentation
- DEV.1.1.3 Bekanntgabe
- DLS.1.1.1 Dokumentation
- DLS.1.1.3 Bekanntgabe
- GEB.1.1.1 Dokumentation
- GEB.1.1.3 Bekanntgabe
- GEB.10.1.2 Klimamessung
- GEB.10.1.3 Redundante Klimatisierung
- GEB.8.2 Staub und Schmutz
- GEB.8.4 Überwachung schonender Klimatisierung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- KONF.1.1 Verfahren und Regelungen
- KONF.1.1.1 Dokumentation
- KONF.1.1.3 Bekanntgabe
- KONF.1.3 Management von Werkzeugen

- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- NOT.1.1.1 Dokumentation
- NOT.1.1.3 Bekanntgabe
- PERS.1.1.1 Dokumentation
- PERS.1.1.3 Bekanntgabe
- REA.1.1.1 Dokumentation
- REA.1.1.3 Bekanntgabe
- SENS.1.1.1 Dokumentation
- SENS.1.1.3 Bekanntgabe
- TEST.1.1 Verfahren und Regelungen
- TEST.1.1.1 Dokumentation
- TEST.1.1.3 Bekanntgabe
- TEST.1.3 Einschränkung von Änderungen
- TEST.2.2 Folgenabschätzung
- TEST.2.2.1 Kategorisierung von Änderungen
- TEST.3.1.4 Testumgebung
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.1.1 Unabhängigkeit der Autorisierung
- TEST.4.1.1.1 Staging
- TEST.4.1.2 Dokumentation der Freigabe
- TEST.4.2 Signatur
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen
- TEST.5.1 Information betroffener Kreise

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1.1 Dokumentation
- ARCH.1.1.3 Bekanntgabe
- ARCH.2.6 Topologieüberwachung
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.13 Produktdiversität
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.9.1 Dimensionierung der Netzanbindung
- ASST.1.1 Verfahren und Regelungen

- ASST.1.1.1 Dokumentation
- ASST.1.1.3 Bekanntgabe
- ASST.2.3.2.1 Software Discovery
- ASST.3.13 Lagerung physischer Assets
- ASST.3.14 Reserve physischer Assets
- ASST.3.15 Ausleihe physischer Assets
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.5 Wartungsfenster
- ASST.5.6 Wartung durch Externe
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- ASST.7.1 Nicht mehr benötigte Anwendungen
- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Lösungsverfahren
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.4 Wiederherstelltest
- ASST.7.5 Vernichtungseinrichtungen
- ASST.7.6 Autorisierung von Veräußerungen
- ASST.7.7 Beschriftungen entfernen
- BER.2.6 Löschen nach Fristablauf
- BER.3.1 Zentrales Management
- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.15 Keine Gruppenkonten
- BER.3.16 Gruppenkonten - MFA
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.4 Identität-Zugangskonto
- BER.4.1 Identitätsüberprüfung
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.5.8 Entzug von Berechtigungen
- BER.6.1 Passwortmanager
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.3 Deaktivierung einfacher Biometrie
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.6.9 Anlassbezogene Passwortwechsel
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung

- BER.7.10 Abgelaufene Schlüssel
- BER.7.11 Integrität
- BER.7.12 Authentizität
- BER.7.13 Gültigkeit
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.16.1 Zertifizierungsstelle
- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.7 Kein Transport privater Schlüssel
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BER.7.9 Zweckbindung
- BES.1.1.1 Dokumentation
- BES.1.1.3 Bekanntgabe
- DET.1.1.1 Dokumentation
- DET.1.1.3 Bekanntgabe
- DEV.1.1.1 Dokumentation
- DEV.1.1.3 Bekanntgabe
- DLS.1.1.1 Dokumentation
- DLS.1.1.3 Bekanntgabe
- GEB.1.1.1 Dokumentation
- GEB.1.1.3 Bekanntgabe
- GEB.10.1.2 Klimamessung
- GEB.10.1.3 Redundante Klimatisierung
- GEB.8.2 Staub und Schmutz
- GEB.8.4 Überwachung schonender Klimatisierung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- KONF.1.1 Verfahren und Regelungen
- KONF.1.1.1 Dokumentation
- KONF.1.1.3 Bekanntgabe
- KONF.1.3 Management von Werkzeugen
- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge

- NOT.1.1.1 Dokumentation
- NOT.1.1.3 Bekanntgabe
- PERS.1.1.1 Dokumentation
- PERS.1.1.3 Bekanntgabe
- REA.1.1.1 Dokumentation
- REA.1.1.3 Bekanntgabe
- SENS.1.1.1 Dokumentation
- SENS.1.1.3 Bekanntgabe
- TEST.1.1 Verfahren und Regelungen
- TEST.1.1.1 Dokumentation
- TEST.1.1.3 Bekanntgabe
- TEST.1.3 Einschränkung von Änderungen
- TEST.2.2 Folgenabschätzung
- TEST.2.2.1 Kategorisierung von Änderungen
- TEST.3.1.4 Testumgebung
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.1.1 Unabhängigkeit der Autorisierung
- TEST.4.1.1.1 Staging
- TEST.4.1.2 Dokumentation der Freigabe
- TEST.4.2 Signatur
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen
- TEST.5.1 Information betroffener Kreise

Eintrag: Konfigurationshistorie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.1.2 Quarantäne
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.7.2 Dedizierte Hardware
- ARCH.7.3 Entwicklungs- und Testumgebungen

- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.2 Redundante TK-Anbindung
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.2 Einschränkung des Managements
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.2.2 Transportverschlüsselung
- DLS.2.3 Vollverschlüsselung
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.10.5 Überprüfung der Konfiguration
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.11.2 Warteraum
- KONF.11.3 Alternative Authentifizierung
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.5 Erraten von Zugriffslinks
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers

- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1 Eingabevalidierung
- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.6 JavaScript
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.12.1.9 Journaling
- KONF.12.10 Cookie-Attribute
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- KONF.12.14 DNS-Falschinformationen
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.3 Cookies
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.12.6 Browser-Historie
- KONF.12.7 Erweiterte Attribute
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.1.1 SPAM-Filter
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende

- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.14.4 Caching
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.1 Grundkonfiguration für Systeme
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.3 SIM-PIN
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen

- KONF.4.2 DNS-Anbindung
 - KONF.4.2.1 DNS-Verschlüsselung
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.5.1 Authentifizierung am System
 - KONF.5.1.1 Authentifizierung an der Firmware
 - KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
 - KONF.6.1.1 Datenkapselung
 - KONF.6.1.2 Isolierung von Anwendungen
 - KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.12 Konferenzmoderation
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.14 Browser Sandboxing
- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.3 Kiosk-Modus
- KONF.6.4 Privilegierte Systemfunktionen
 - KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.6.6 Getrennte Datenhaltung
 - KONF.6.6.1 Mandantenfähigkeit
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code
- KONF.7.1 Echtzeitscanner
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.15 Lokale Firewall
- KONF.7.16 Anti-Exploit

- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.5 Alarmierung
- KONF.7.6 Automatische Updates
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.8.2 Automatische Updates der Anwendung
- KONF.9.1 Speicherplatzbegrenzung
- KONF.9.2 Begrenzung der Rechenleistung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- REA.2.2 Automatische Erstreaktion
- TEST.3.1.3 Testdaten
- TEST.5.2 Verschlüsselte Bereitstellung
- TEST.5.3 Schrittweiser Rollout
- TEST.5.4 Persistenz

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.1.2 Quarantäne
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.7.2 Dedizierte Hardware
- ARCH.7.3 Entwicklungs- und Testumgebungen
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.2 Redundante TK-Anbindung
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung

- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.2 Einschränkung des Managements
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.2.2 Transportverschlüsselung
- DLS.2.3 Vollverschlüsselung
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.10.5 Überprüfung der Konfiguration
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.11.2 Warteraum
- KONF.11.3 Alternative Authentifizierung
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.5 Erraten von Zugriffslinks
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1 Eingabevalidierung
- KONF.12.1.1 Zertifikatsprüfung

- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.6 JavaScript
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.12.1.9 Journaling
- KONF.12.10 Cookie-Attribute
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- KONF.12.14 DNS-Falschinformationen
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.3 Cookies
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.12.6 Browser-Historie
- KONF.12.7 Erweiterte Attribute
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.1.1 SPAM-Filter
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports

- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.14.1 Verschlüsselung beim Transport
 - KONF.14.1.1 Obligatorische Verschlüsselung
 - KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.14.4 Caching
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.1 Grundkonfiguration für Systeme
 - KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
 - KONF.2.4.1 Nicht benötigte Zertifikate
 - KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
 - KONF.2.5.1 Automatische Konfigurationsverwaltung
 - KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.3 SIM-PIN
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
 - KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
 - KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2 DNS-Anbindung
 - KONF.4.2.1 DNS-Verschlüsselung
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen

- KONF.5.1 Authentifizierung am System
 - KONF.5.1.1 Authentifizierung an der Firmware
 - KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
 - KONF.6.1.1 Datenkapselung
 - KONF.6.1.2 Isolierung von Anwendungen
 - KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.12 Konferenzmoderation
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.14 Browser Sandboxing
- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.3 Kiosk-Modus
- KONF.6.4 Privilegierte Systemfunktionen
 - KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.6.6 Getrennte Datenhaltung
 - KONF.6.6.1 Mandantenfähigkeit
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code
- KONF.7.1 Echtzeitscanner
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.15 Lokale Firewall
- KONF.7.16 Anti-Exploit
 - KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.5 Alarmierung

- KONF.7.6 Automatische Updates
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.8.2 Automatische Updates der Anwendung
- KONF.9.1 Speicherplatzbegrenzung
- KONF.9.2 Begrenzung der Rechenleistung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- REA.2.2 Automatische Erstreaktion
- TEST.3.1.3 Testdaten
- TEST.5.2 Verschlüsselte Bereitstellung
- TEST.5.3 Schrittweiser Rollout
- TEST.5.4 Persistenz

Eintrag: Leistungsbeschreibung

Keine Controls gefunden.

Eintrag: Leitlinie zur Informationssicherheit

Keine Controls gefunden.

Eintrag: Leitungsentscheidung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.6.1.2 Verpflichtung der Institutionsleitung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.6.1.2 Verpflichtung der Institutionsleitung

Eintrag: Liste der Hersteller und Dienstleister

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.1.3.1 Gesamte Lieferkette
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- REA.2.5.3 Forensik-Dienstleister

BSI/Grundschutz/Quellkataloge/Kernel

- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.1.3.1 Gesamte Lieferkette
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- REA.2.5.3 Forensik-Dienstleister

Eintrag: Liste der Verpflichtungen

Keine Controls gefunden.

Eintrag: Managementbericht

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.10.2 Freigabe von Vorgehensweisen
- PERF.5.1 Eignungsprüfung
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- PERF.5.1.9 Maßnahmenvorschläge

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.10.2 Freigabe von Vorgehensweisen
- PERF.5.1 Eignungsprüfung
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen

- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- PERF.5.1.9 Maßnahmenvorschläge

Eintrag: Netzplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.1 Externe Netzanschlüsse
 - ARCH.2.2.10 Drucker-Netz
 - ARCH.2.2.11 Physische Segmentierung
 - ARCH.2.2.12 Sprungserver
 - ARCH.2.2.2 Gastnetz
- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.3 Mikrosegmentierung
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ARCH.3.1 Netzabdeckung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.3.3 SSIDs

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.1 Externe Netzanschlüsse

- ARCH.2.2.10 Drucker-Netz
- ARCH.2.2.11 Physische Segmentierung
- ARCH.2.2.12 Sprungserver
- ARCH.2.2.2 Gastnetz
- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.3 Mikrosegmentierung
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ARCH.3.1 Netzabdeckung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.3.3 SSIDs

Eintrag: Notfallhandbuch

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- NOT.2.1 Verfahren und Regelungen
 - NOT.2.1.1 Rollen
 - NOT.2.1.2 Alarmierung
 - NOT.2.1.3 Stabsraum
 - NOT.2.1.4 Stabsübung
- NOT.3.1 Wiederanlaufplan
- NOT.3.2 Geschäftsfortführungsplan
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen

BSI/Grundschutz/Quellkataloge/Kernel

- NOT.2.1 Verfahren und Regelungen
 - NOT.2.1.1 Rollen
 - NOT.2.1.2 Alarmierung
 - NOT.2.1.3 Stabsraum

- NOT.2.1.4 Stabsübung
- NOT.3.1 Wiederanlaufplan
- NOT.3.2 Geschäftsfortführungsplan
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen

Eintrag: Nutzungsbedingungen

Keine Controls gefunden.

Eintrag: Outsourcing-Strategie

Keine Controls gefunden.

Eintrag: Prozess Beschaffung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.1.1 Verfahren und Regelungen
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.3 Beschaffung anhand der Kriterien
- BES.8.1 Bereithaltung alternativer Lieferanten
- DLS.1.1 Verfahren und Regelungen
- DLS.3.5 Blockierung unzuverlässiger Dienstleister

BSI/Grundschutz/Quellkataloge/Kernel

- BES.1.1 Verfahren und Regelungen
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.3 Beschaffung anhand der Kriterien
- BES.8.1 Bereithaltung alternativer Lieferanten
- DLS.1.1 Verfahren und Regelungen

- DLS.3.5 Blockierung unzuverlässiger Dienstleister

Eintrag: Prozess Dienstleistersteuerung

Keine Controls gefunden.

Eintrag: Prozess Gebäudemanagement

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.1.1 Verfahren und Regelungen
- GEB.1.3 Autorisierung von Standorten
- GEB.1.3.1 Abnahme von Standorten
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.3 Besucheranmeldung
- GEB.3.6 Einbruchmeldeanlagen

BSI/Grundschutz/Quellkataloge/Kernel

- GEB.1.1 Verfahren und Regelungen
- GEB.1.3 Autorisierung von Standorten
- GEB.1.3.1 Abnahme von Standorten
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.3 Besucheranmeldung
- GEB.3.6 Einbruchmeldeanlagen

Eintrag: Prozess Identitäts- und Berechtigungsmanagement

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.1.1.1 Dokumentation

- BER.1.1.3 Bekanntgabe
- BER.2.2 Einschränkung
- GEB.4.2 Gesonderte Autorisierung

BSI/Grundschutz/Quellkataloge/Kernel

- BER.1.1.1 Dokumentation
- BER.1.1.3 Bekanntgabe
- BER.2.2 Einschränkung
- GEB.4.2 Gesonderte Autorisierung

Eintrag: Prozess Personalmanagement

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- PERS.1.1 Verfahren und Regelungen
- PERS.3.4 Stellenbeschreibungen
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- PERS.3.7 Einarbeitung
- PERS.5.1 Maßregelung
- PERS.5.2 Innentäter
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- PERS.6.1.2 Neubesetzung

BSI/Grundschutz/Quellkataloge/Kernel

- PERS.1.1 Verfahren und Regelungen
- PERS.3.4 Stellenbeschreibungen
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- PERS.3.7 Einarbeitung
- PERS.5.1 Maßregelung
- PERS.5.2 Innentäter
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen

- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- PERS.6.1.2 Neubesetzung

Eintrag: Prüfplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.1.2 Regelmäßige Überprüfung
- BER.5.3 Überprüfung von Berechtigungen

BSI/Grundschutz/Quellkataloge/Kernel

- BER.1.2 Regelmäßige Überprüfung
- BER.5.3 Überprüfung von Berechtigungen

Eintrag: Realisierungsplan

Keine Controls gefunden.

Eintrag: Richtlinie zur Lenkung von Dokumenten und Aufzeichnungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.9.1.3 Dokumentenlenkung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.9.1.3 Dokumentenlenkung

Eintrag: Richtlinie zur Risikoanalyse

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.3 Risikoeigentümer
- RISK.1.5 Freigabe des Risikomanagements

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.2 Einhaltung der BSI-Kriterien
- RISK.1.3 Risikoeigentümer
- RISK.1.4 Risikoappetit
- RISK.1.5 Freigabe des Risikomanagements
- RISK.1.6 Kritikalitätskriterien für Geschäftsprozesse
- RISK.1.7 Kriterien für die Risikobeurteilung
- RISK.1.8 Kriterien für die Risikoakzeptanz

Eintrag: Risikobewertung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.11.1 Methodik für das Risikomanagement
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.11.1 Methodik für das Risikomanagement
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf

Eintrag: Schulungsplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- PERS.4.1 Qualifikationsbedarf
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling

- SENS.12.1 Hohe Risiken
- SENS.2.1 Schutzziele
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.6 Papiervernichtung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.12 Öffentliche WLANs
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.15 Social Engineering Anrufe
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.2 Virensan
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.25 Zugang zum Fahrzeug
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links

- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.7.9 Aktive Inhalte
- SENS.8.5 Verwahrung Intern
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise

BSI/Grundschutz/Quellkataloge/Kernel

- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- PERS.4.1 Qualifikationsbedarf
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.12.1 Hohe Risiken
- SENS.2.1 Schutzziele
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe

- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.6 Papiervernichtung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.12 Öffentliche WLANs
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.15 Social Engineering Anrufe
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.2 Virensan
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.25 Zugang zum Fahrzeug
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links
- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.7.9 Aktive Inhalte
- SENS.8.5 Verwahrung Intern
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise

Eintrag: Schutzbedarfsfeststellung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.5.1.2 Festlegung des Schutzbedarfs

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.5.1.2 Festlegung des Schutzbedarfs

Eintrag: Sicherheitsorganisation

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.8.1.1.1 Informationssicherheitsbeauftragter
- GC.8.1.4 Festlegung einer Sicherheitsorganisation

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.8.1.1.1 Informationssicherheitsbeauftragter
- GC.8.1.4 Festlegung einer Sicherheitsorganisation

Eintrag: Tätigkeits- & Rollenbeschreibung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
- GC.8.1.5 Sicherstellung der Qualifikation

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
- GC.8.1.5 Sicherstellung der Qualifikation

Eintrag: Übersicht der Kommunikationspartner

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement

Eintrag: Übungsplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- NOT.3.4 Funktionstest
- REA.1.3 Übungen zur Vorfallsbehandlung
- SENS.1.2 Erfolgsmessung

BSI/Grundschutz/Quellkataloge/Kernel

- NOT.3.4 Funktionstest
- REA.1.3 Übungen zur Vorfallsbehandlung
- SENS.1.2 Erfolgsmessung

Eintrag: Umsetzungsplan

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- RISK.1.10 Freigabe der Umsetzungsplanung
- UMS.3.1 Umsetzungsplanung
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- VRB.5.1 Priorisierung von Maßnahmen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- UMS.3.1 Umsetzungsplanung
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- VRB.5.1 Priorisierung von Maßnahmen

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.10 Freigabe der Umsetzungsplanung
- RISK.1.9 Bestätigung des Restrisikos

Eintrag: Verfahrensbeschreibung

Keine Controls gefunden.

Eintrag: Verträge

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.4.5 Vereinbarungen zum Austausch

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.4.5 Vereinbarungen zum Austausch

Eintrag: Verzeichnis der Schwachstellen

Keine Controls gefunden.

Eintrag: Verzeichnis öffentlicher Schlüssel

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.7.14 Schlüssel vor Ablauf prüfen
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16.5 Beglaubigungsstatus
- BER.7.16.6 Revocationstatus
- BER.7.2 Schlüssellänge
- BER.7.3 Verzeichnis öffentlicher Schlüssel

BSI/Grundschutz/Quellkataloge/Kernel

- BER.7.14 Schlüssel vor Ablauf prüfen
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16.5 Beglaubigungsstatus

- BER.7.16.6 Revocationstatus
- BER.7.2 Schlüssellänge
- BER.7.3 Verzeichnis öffentlicher Schlüssel

Namespace: effort_level

Eintrag: 0

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1 Verfahren und Regelungen
 - ARCH.1.1.1 Dokumentation
 - ARCH.1.1.2 Zuweisung der Aufgaben
 - ARCH.1.1.3 Bekanntgabe
- ARCH.1.2 Regelmäßige Überprüfung
- ASST.1.1 Verfahren und Regelungen
 - ASST.1.1.1 Dokumentation
 - ASST.1.1.2 Zuweisung der Aufgaben
 - ASST.1.1.3 Bekanntgabe
- ASST.1.2 Regelmäßige Überprüfung
- BER.1.1 Verfahren und Regelungen
 - BER.1.1.1 Dokumentation
 - BER.1.1.2 Zuweisung der Aufgaben
 - BER.1.1.3 Bekanntgabe
- BER.1.2 Regelmäßige Überprüfung
- BES.1.1 Verfahren und Regelungen
 - BES.1.1.1 Dokumentation
 - BES.1.1.2 Zuweisung der Aufgaben
 - BES.1.1.3 Bekanntgabe
- BES.1.2 Regelmäßige Überprüfung
- DET.1.1 Verfahren und Regelungen
 - DET.1.1.1 Dokumentation
 - DET.1.1.2 Zuweisung der Aufgaben
 - DET.1.1.3 Bekanntgabe
- DET.1.2 Regelmäßige Überprüfung
- DEV.1.1 Verfahren und Regelungen
 - DEV.1.1.1 Dokumentation
 - DEV.1.1.2 Zuweisung der Aufgaben

- DEV.1.1.3 Bekanntgabe
- DEV.1.2 Regelmäßige Überprüfung
- DLS.1.1 Verfahren und Regelungen
 - DLS.1.1.1 Dokumentation
 - DLS.1.1.2 Zuweisung der Aufgaben
 - DLS.1.1.3 Bekanntgabe
- DLS.1.2 Regelmäßige Überprüfung
- GC.1.1 Errichtung und Aufrechterhaltung eines ISMS
- GC.10.1 Festlegung von Vorgehensweisen
- GC.10.2 Freigabe von Vorgehensweisen
- GC.11.1 Methodik für das Risikomanagement
- GC.2.1 Festlegung des externen Kontextes der Institution
- GC.2.2 Festlegung des internen Kontextes der Institution
- GC.3.1 Analyse der externen interessierten Parteien
- GC.3.2 Analyse der internen interessierten Parteien
- GC.4.1 Festlegung des Geltungsbereichs
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
 - GC.5.1.1 Festlegung der Geschäftsprozesse
 - GC.5.1.2 Festlegung des Schutzbedarfs
 - GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- GC.6.1 Festlegung von Zielen für die Informationssicherheit
 - GC.6.1.2 Verpflichtung der Institutionsleitung
 - GC.6.1.3 Erstellung einer Sicherheitsleitlinie
 - GC.6.1.4 Freigabe der Sicherheitsleitlinie
- GC.7.1 Verfahren und Regelungen
- GC.8.1 Verfahren zur Ressourcenplanung
 - GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
 - GC.8.1.1.1 Informationssicherheitsbeauftragter
 - GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
 - GC.8.1.2 Stellvertreterregelungen
 - GC.8.1.3 Vermeidung von Interessenkonflikten
 - GC.8.1.4 Festlegung einer Sicherheitsorganisation
 - GC.8.1.5 Sicherstellung der Qualifikation
 - GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten
- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement
 - GC.9.1.2 Kommunikation im Projektmanagement
 - GC.9.1.3 Dokumentenlenkung
- GEB.1.1 Verfahren und Regelungen

- GEB.1.1.1 Dokumentation
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.1.1.3 Bekanntgabe
- GEB.1.2 Regelmäßige Überprüfung
- KONF.1.1 Verfahren und Regelungen
- KONF.1.1.1 Dokumentation
- KONF.1.1.2 Zuweisung der Aufgaben
- KONF.1.1.3 Bekanntgabe
- KONF.1.2 Regelmäßige Überprüfung
- NOT.1.1 Verfahren und Regelungen
- NOT.1.1.1 Dokumentation
- NOT.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.3 Bekanntgabe
- NOT.1.2 Regelmäßige Überprüfung
- PERF.1.1 Verfahren und Regelungen
- PERF.3.1 Aufbau und Pflege eines Auditprogramms
- PERF.3.1.2 Planen von internen Audits
- PERF.3.1.3 Auswahl des Auditteams
- PERF.3.1.4 Umfang von Audits
- PERF.4.1 Dokumentation von Auditergebnissen
- PERF.4.1.2 Kommunikation an Stakeholder
- PERF.5.1 Eignungsprüfung
- PERF.5.1.9 Maßnahmenvorschläge
- PERF.5.2 Bericht an die Institutionsleitung
- PERF.6.1 Sicherheitsvorfälle
- PERF.6.1.1 Sicherheitsvorfälle
- PERF.6.1.2 Schwachstellen
- PERF.6.1.3 Bedrohungen
- PERF.7.1 Aktualität der Anforderungen
- PERS.1.1 Verfahren und Regelungen
- PERS.1.1.1 Dokumentation
- PERS.1.1.2 Zuweisung der Aufgaben
- PERS.1.1.3 Bekanntgabe
- PERS.1.2 Regelmäßige Überprüfung
- REA.1.1 Verfahren und Regelungen
- REA.1.1.1 Dokumentation
- REA.1.1.2 Zuweisung der Aufgaben
- REA.1.1.3 Bekanntgabe

- REA.1.2 Regelmäßige Überprüfung
- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.10 Freigabe der Umsetzungsplanung
- RISK.1.3 Risikoeigentümer
- RISK.1.5 Freigabe des Risikomanagements
- SENS.1.1 Verfahren und Regelungen
- SENS.1.1.1 Dokumentation
- SENS.1.1.2 Zuweisung der Aufgaben
- SENS.1.1.3 Bekanntgabe
- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen
- STM.2.1 Erstellung eines Anforderungspakets
- STM.3.1 ISMS-Anforderungen des Informationsverbundes
- STM.4.1 Erfassung relevanter Assets
- STM.4.2 Dokumentation relevanter Assets
- STM.4.3 Mapping des Assets auf die Zielobjektkategorien
- STM.5.1 Modellierung der Anforderungen mit Zielobjekt
- STM.5.2 Vererbung von Zielobjektkategorien
- STM.5.3 Konsolidierung und Redundanzprüfung
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.6.2 Auf Grund externer Verpflichtungen
- STM.7.1 Überprüfung des gesetzten Sicherheitsniveaus
- STM.8.1 Risikobetrachtung bei fehlenden Anforderungen
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- TEST.1.1 Verfahren und Regelungen
- TEST.1.1.1 Dokumentation
- TEST.1.1.2 Zuweisung der Aufgaben
- TEST.1.1.3 Bekanntgabe
- TEST.1.2 Regelmäßige Überprüfung
- UMS.1.1 Ermittlung des Umsetzungsstatus
- UMS.3.1 Umsetzungsplanung
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen
- UMS.5.1 Autorisierung von Ausnahmen
- UMS.5.2 Dokumentation von Ausnahmen

- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.1.1 Verfahren zur kontinuierlichen Verbesserung
- VRB.1.2 Änderungen im ISMS
- VRB.2.1 Umgang mit Nicht-Konformitäten
- VRB.4.1 Korrekturmaßnahmen
- VRB.4.2 Verbesserungsmaßnahmen
- VRB.5.1 Priorisierung von Maßnahmen
- VRB.6.1 Wirksamkeitsprüfung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1 Verfahren und Regelungen
 - ARCH.1.1.1 Dokumentation
 - ARCH.1.1.2 Zuweisung der Aufgaben
 - ARCH.1.1.3 Bekanntgabe
- ARCH.1.2 Regelmäßige Überprüfung
- ASST.1.1 Verfahren und Regelungen
 - ASST.1.1.1 Dokumentation
 - ASST.1.1.2 Zuweisung der Aufgaben
 - ASST.1.1.3 Bekanntgabe
- ASST.1.2 Regelmäßige Überprüfung
- BER.1.1 Verfahren und Regelungen
 - BER.1.1.1 Dokumentation
 - BER.1.1.2 Zuweisung der Aufgaben
 - BER.1.1.3 Bekanntgabe
- BER.1.2 Regelmäßige Überprüfung
- BES.1.1 Verfahren und Regelungen
 - BES.1.1.1 Dokumentation
 - BES.1.1.2 Zuweisung der Aufgaben
 - BES.1.1.3 Bekanntgabe
- BES.1.2 Regelmäßige Überprüfung
- DET.1.1 Verfahren und Regelungen
 - DET.1.1.1 Dokumentation
 - DET.1.1.2 Zuweisung der Aufgaben
 - DET.1.1.3 Bekanntgabe
- DET.1.2 Regelmäßige Überprüfung

- DEV.1.1 Verfahren und Regelungen
 - DEV.1.1.1 Dokumentation
 - DEV.1.1.2 Zuweisung der Aufgaben
 - DEV.1.1.3 Bekanntgabe
- DEV.1.2 Regelmäßige Überprüfung
- DLS.1.1 Verfahren und Regelungen
 - DLS.1.1.1 Dokumentation
 - DLS.1.1.2 Zuweisung der Aufgaben
 - DLS.1.1.3 Bekanntgabe
- DLS.1.2 Regelmäßige Überprüfung
- GEB.1.1 Verfahren und Regelungen
 - GEB.1.1.1 Dokumentation
 - GEB.1.1.2 Zuweisung der Aufgaben
 - GEB.1.1.3 Bekanntgabe
- GEB.1.2 Regelmäßige Überprüfung
- KONF.1.1 Verfahren und Regelungen
 - KONF.1.1.1 Dokumentation
 - KONF.1.1.2 Zuweisung der Aufgaben
 - KONF.1.1.3 Bekanntgabe
- KONF.1.2 Regelmäßige Überprüfung
- NOT.1.1 Verfahren und Regelungen
 - NOT.1.1.1 Dokumentation
 - NOT.1.1.2 Zuweisung der Aufgaben
 - NOT.1.1.3 Bekanntgabe
- NOT.1.2 Regelmäßige Überprüfung
- PERS.1.1 Verfahren und Regelungen
 - PERS.1.1.1 Dokumentation
 - PERS.1.1.2 Zuweisung der Aufgaben
 - PERS.1.1.3 Bekanntgabe
- PERS.1.2 Regelmäßige Überprüfung
- REA.1.1 Verfahren und Regelungen
 - REA.1.1.1 Dokumentation
 - REA.1.1.2 Zuweisung der Aufgaben
 - REA.1.1.3 Bekanntgabe
- REA.1.2 Regelmäßige Überprüfung
- SENS.1.1 Verfahren und Regelungen
 - SENS.1.1.1 Dokumentation
 - SENS.1.1.2 Zuweisung der Aufgaben

- SENS.1.1.3 Bekanntgabe
- TEST.1.1 Verfahren und Regelungen
- TEST.1.1.1 Dokumentation
- TEST.1.1.2 Zuweisung der Aufgaben
- TEST.1.1.3 Bekanntgabe
- TEST.1.2 Regelmäßige Überprüfung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.1.1 Errichtung und Aufrechterhaltung eines ISMS
- GC.10.1 Festlegung von Vorgehensweisen
- GC.10.2 Freigabe von Vorgehensweisen
- GC.11.1 Methodik für das Risikomanagement
- GC.2.1 Festlegung des externen Kontextes der Institution
- GC.2.2 Festlegung des internen Kontextes der Institution
- GC.3.1 Analyse der externen interessierten Parteien
- GC.3.2 Analyse der internen interessierten Parteien
- GC.4.1 Festlegung des Geltungsbereichs
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- GC.6.1 Festlegung von Zielen für die Informationssicherheit
- GC.6.1.2 Verpflichtung der Institutionsleitung
- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.6.1.4 Freigabe der Sicherheitsleitlinie
- GC.7.1 Verfahren und Regelungen
- GC.8.1 Verfahren zur Ressourcenplanung
- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.1.1 Informationssicherheitsbeauftragter
- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
- GC.8.1.2 Stellvertreterregelungen
- GC.8.1.3 Vermeidung von Interessenkonflikten
- GC.8.1.4 Festlegung einer Sicherheitsorganisation
- GC.8.1.5 Sicherstellung der Qualifikation
- GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten
- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement
- GC.9.1.2 Kommunikation im Projektmanagement

- GC.9.1.3 Dokumentenlenkung
- PERF.1.1 Verfahren und Regelungen
- PERF.3.1 Aufbau und Pflege eines Auditprogramms
 - PERF.3.1.2 Planen von internen Audits
 - PERF.3.1.3 Auswahl des Auditteams
 - PERF.3.1.4 Umfang von Audits
- PERF.4.1 Dokumentation von Auditergebnissen
 - PERF.4.1.2 Kommunikation an Stakeholder
- PERF.5.1 Eignungsprüfung
 - PERF.5.1.9 Maßnahmenvorschläge
- PERF.5.2 Bericht an die Institutionsleitung
- PERF.6.1 Sicherheitsvorfälle
 - PERF.6.1.1 Sicherheitsvorfälle
 - PERF.6.1.2 Schwachstellen
 - PERF.6.1.3 Bedrohungen
- PERF.7.1 Aktualität der Anforderungen
- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen
- STM.2.1 Erstellung eines Anforderungspakets
- STM.3.1 ISMS-Anforderungen des Informationsverbundes
- STM.4.1 Erfassung relevanter Assets
- STM.4.2 Dokumentation relevanter Assets
- STM.4.3 Mapping des Assets auf die Zielobjektkategorien
- STM.5.1 Modellierung der Anforderungen mit Zielobjekt
- STM.5.2 Vererbung von Zielobjektkategorien
- STM.5.3 Konsolidierung und Redundanzprüfung
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.6.2 Auf Grund externer Verpflichtungen
- STM.7.1 Überprüfung des gesetzten Sicherheitsniveaus
- STM.8.1 Risikobetrachtung bei fehlenden Anforderungen
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- UMS.1.1 Ermittlung des Umsetzungsstatus
- UMS.3.1 Umsetzungsplanung
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen

- UMS.5.1 Autorisierung von Ausnahmen
- UMS.5.2 Dokumentation von Ausnahmen
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.1.1 Verfahren zur kontinuierlichen Verbesserung
- VRB.1.2 Änderungen im ISMS
- VRB.2.1 Umgang mit Nicht-Konformitäten
- VRB.4.1 Korrekturmaßnahmen
- VRB.4.2 Verbesserungsmaßnahmen
- VRB.5.1 Priorisierung von Maßnahmen
- VRB.6.1 Wirksamkeitsprüfung

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.10 Freigabe der Umsetzungsplanung
- RISK.1.2 Einhaltung der BSI-Kriterien
- RISK.1.3 Risikoeigentümer
- RISK.1.4 Risikoappetit
- RISK.1.5 Freigabe des Risikomanagements
- RISK.1.6 Kritikalitätskriterien für Geschäftsprozesse
- RISK.1.7 Kriterien für die Risikobeurteilung
- RISK.1.8 Kriterien für die Risikoakzeptanz

Eintrag: 1

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.21 Notfallzugang
- BER.5.1 Prinzip der geringsten Berechtigungen
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.9 Anlassbezogene Passwortwechsel
- BER.7.10 Abgelaufene Schlüssel
- BER.7.11 Integrität
- BER.7.13 Gültigkeit

- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.3.4 Passwort-Hashing
- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.9 Journaling
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.7 Erweiterte Attribute
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.2.1 Schutzziele
- SENS.2.7 Änderung von Konfigurationen
- SENS.4.1.5 Biometrische Authentifikation
- SENS.7.15 Social Engineering Anrufe
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.7.5 SPAM - Nichtbeantwortung

- SENS.7.6 SPAM - Links
- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten

BSI/Grundschutz/Quellkataloge/Kernel

- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.21 Notfallzugang
- BER.5.1 Prinzip der geringsten Berechtigungen
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.9 Anlassbezogene Passwortwechsel
- BER.7.10 Abgelaufene Schlüssel
- BER.7.11 Integrität
- BER.7.13 Gültigkeit
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.3.4 Passwort-Hashing
- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.9 Journaling
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.7 Erweiterte Attribute
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware

- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.2.1 Schutzziele
- SENS.2.7 Änderung von Konfigurationen
- SENS.4.1.5 Biometrische Authentifikation
- SENS.7.15 Social Engineering Anrufe
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links
- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen

Eintrag: 2

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.1 Externe Netzanschlüsse
 - ARCH.2.2.2 Gastnetz
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ARCH.3.1 Netzabdeckung
- ARCH.3.3 SSIDs
- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen

- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ASST.2.2 Inventar der Systeme
- ASST.2.3 Inventar der Anwendungen
- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.3 Geregeltes Löschen oder Vernichten
- ASST.7.6 Autorisierung von Veräußerungen
- ASST.7.7 Beschriftungen entfernen
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.15 Keine Gruppenkonten
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.2 Einschränkung des Managements
- BER.3.4 Identität-Zugangskonto
- BER.3.5 Privilegierte Zugangskonten
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.1 Passwortmanager
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- BER.6.7 Trivialpasswörter
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
- BER.7.12 Authentizität
- BER.7.14 Schlüssel vor Ablauf prüfen
- BER.7.2 Schlüssellänge
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BER.7.9 Zweckbindung
- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.2.1 Erfassung des Bedarfes
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.4.2 Dokumentation der Beschaffungskriterien

- BES.4.3 Beschaffung anhand der Kriterien
- BES.4.5 Security by Design
- BES.4.6 Security by Default
- BES.4.6.1 Authentifizierung des Kunden
- BES.5.8 Rechte für geistiges Eigentum
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.6 Rückgewähr von Assets
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.7 Organisatorische Schnittstellen
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
- DET.3.1.8 Privilegierte Ereignisse
- DEV.2.1 Security by Design Architektur
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- DEV.2.6.2 Ausgabekodierung
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.2 Bibliotheksquellen
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.8 Default-Zugangsdaten
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.7.2 Zertifikatsmonitoring
- DLS.2.2 Transportverschlüsselung
- DLS.4.1 Dekommissionierung
- GEB.1.3 Autorisierung von Standorten
- GEB.10.2 Brandschutz
- GEB.10.3 Wasserschutz
- GEB.2.1 Installation von Perimetern
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.8.1 Gesonderte Aufbewahrung
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.14.1 Verschlüsselung beim Transport

- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.3.3 SIM-PIN
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.14 Browser Sandboxing
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.6 Getrennte Datenhaltung
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.9 Zugriff auf Code
- KONF.7.1 Echtzeitscanner
- KONF.7.15 Lokale Firewall
- KONF.7.2 Regelmäßige Scans
- KONF.7.6 Automatische Updates
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.2 Automatische Updates der Anwendung
- NOT.4.1 Dokumentation der Quellen
- NOT.4.15 Vorgehen zur Wiederherstellung
- NOT.4.6 Geschützte Aufbewahrung
- PERF.1.1.1 Auswertung der Gefährdungslage
- PERF.1.1.2 Auswertung des Umsetzungsplans
- PERF.1.1.3 Auswertung von Auditergebnissen
- PERF.1.1.4 Auswertung von Sicherheitsvorfällen
- PERF.2.1 Überwachung der Einhaltung von Verpflichtungen
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.4 Zuständigkeiten
- PERS.3.1 Dienst- oder Arbeitsvertrag
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- PERS.3.7 Einarbeitung
- PERS.4.1 Qualifikationsbedarf
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- PERS.6.1 Vorgehensweise für den Weggang

- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- PERS.6.1.2 Neubesetzung
- REA.2.1 Triage und Erstreaktion
- REA.2.6 Ursachenanalyse und Behandlung
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.2.2 Meldewege
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.8 Melden von Ereignissen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.5 Löschfristen
- SENS.5.6 Papiervernichtung
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.9 Aktive Inhalte
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.5 Verwahrung Intern
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.2 Vorsicht vor Mithören

- SENS.9.4 Mobile Arbeit mit Dokumenten
- TEST.1.3 Einschränkung von Änderungen
- TEST.2.2 Folgenabschätzung
- TEST.2.2.2 Anpassung der Dokumentation
- UMS.2.1 Bewertung des Restrisikos
- VRB.2.2 Anpassung des ISMS
- VRB.7.1 Bewertung der erreichten Verbesserung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
- ARCH.2.2.1 Externe Netzanschlüsse
- ARCH.2.2.2 Gastnetz
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ARCH.3.1 Netzabdeckung
- ARCH.3.3 SSIDs
- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ASST.2.2 Inventar der Systeme
- ASST.2.3 Inventar der Anwendungen
- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.3 Geregeltetes Löschen oder Vernichten
- ASST.7.6 Autorisierung von Veräußerungen
- ASST.7.7 Beschriftungen entfernen
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.15 Keine Gruppenkonten
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.2 Einschränkung des Managements

- BER.3.4 Identität-Zugangskonto
- BER.3.5 Privilegierte Zugangskonten
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.1 Passwortmanager
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- BER.6.7 Trivialpasswörter
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
- BER.7.12 Authentizität
- BER.7.14 Schlüssel vor Ablauf prüfen
- BER.7.2 Schlüssellänge
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BER.7.9 Zweckbindung
- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.2.1 Erfassung des Bedarfes
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.3 Beschaffung anhand der Kriterien
- BES.4.5 Security by Design
- BES.4.6 Security by Default
- BES.4.6.1 Authentifizierung des Kunden
- BES.5.8 Rechte für geistiges Eigentum
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.6 Rückgewähr von Assets
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.7 Organisatorische Schnittstellen
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
- DET.3.1.8 Privilegierte Ereignisse
- DEV.2.1 Security by Design Architektur
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- DEV.2.6.2 Ausgabekodierung
- DEV.3.2 Routinen zur Fehlerbehandlung

- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.2 Bibliotheksquellen
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.8 Default-Zugangsdaten
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.7.2 Zertifikatsmonitoring
- DLS.2.2 Transportverschlüsselung
- DLS.4.1 Dekommissionierung
- GEB.1.3 Autorisierung von Standorten
- GEB.10.2 Brandschutz
- GEB.10.3 Wasserschutz
- GEB.2.1 Installation von Perimetern
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.8.1 Gesonderte Aufbewahrung
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.14.1 Verschlüsselung beim Transport
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.3.3 SIM-PIN
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.14 Browser Sandboxing
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.6 Getrennte Datenhaltung
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.9 Zugriff auf Code
- KONF.7.1 Echtzeitscanner
- KONF.7.15 Lokale Firewall
- KONF.7.2 Regelmäßige Scans
- KONF.7.6 Automatische Updates
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.2 Automatische Updates der Anwendung

- NOT.4.1 Dokumentation der Quellen
- NOT.4.15 Vorgehen zur Wiederherstellung
- NOT.4.6 Geschützte Aufbewahrung
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.4 Zuständigkeiten
- PERS.3.1 Dienst- oder Arbeitsvertrag
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- PERS.3.7 Einarbeitung
- PERS.4.1 Qualifikationsbedarf
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- PERS.6.1.2 Neubesetzung
- REA.2.1 Triage und Erstreaktion
- REA.2.6 Ursachenanalyse und Behandlung
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.2.2 Meldewege
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.8 Melden von Ereignissen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.5 Löschfristen
- SENS.5.6 Papiervernichtung
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung

- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.9 Aktive Inhalte
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.5 Verwahrung Intern
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.4 Mobile Arbeit mit Dokumenten
- TEST.1.3 Einschränkung von Änderungen
- TEST.2.2 Folgenabschätzung
- TEST.2.2.2 Anpassung der Dokumentation

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- PERF.1.1.1 Auswertung der Gefährdungslage
- PERF.1.1.2 Auswertung des Umsetzungsplans
- PERF.1.1.3 Auswertung von Auditergebnissen
- PERF.1.1.4 Auswertung von Sicherheitsvorfällen
- PERF.2.1 Überwachung der Einhaltung von Verpflichtungen
- UMS.2.1 Bewertung des Restrisikos
- VRB.2.2 Anpassung des ISMS
- VRB.7.1 Bewertung der erreichten Verbesserung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.9 Bestätigung des Restrisikos

Eintrag: 3

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.9 Filterung von DNS
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.9.1 Dimensionierung der Netzanbindung
- ASST.2.1 Inventar der Informationen
- ASST.2.1.1 Informationsverantwortung
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.2.4 Klassifizierung
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.13 Lagerung physischer Assets
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Regelmäßige Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.5.5 Wartungsfenster
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- ASST.7.1 Nicht mehr benötigte Anwendungen

- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Lösungsverfahren
- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BER.1.4 Inventar der Berechtigungen
- BER.2.1 Person-Identität
- BER.2.2 Einschränkung
- BER.2.3 Stammdatenprüfung
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.2.5 Deaktivierung bei Weggang
- BER.3.1 Zentrales Management
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.3 Protokollierung von Änderungen
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.4.1 Identitätsüberprüfung
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.2 Begründung von Berechtigungen
- BER.5.3 Überprüfung von Berechtigungen
- BER.5.8 Entzug von Berechtigungen
- BER.6.10 Monitoring von Zugangsdaten
- BER.6.3 Deaktivierung einfacher Biometrie
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.16.5 Beglaubigungsstatus
- BER.7.16.6 Revocationstatus
- BER.7.3 Verzeichnis öffentlicher Schlüssel
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.1.1 Verwendungszweck
- BES.2.1.3 Systemvoraussetzungen
- BES.2.1.4 Kompatibilität

- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.2 Auswahlkriterien
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.5.10 Behandlung von Vorfällen
- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.14 Löschregeln
- BES.5.3 Compliance-Verpflichtungen
- BES.5.5 Nutzungsregelungen
- BES.6.2 Löschung von Daten
- BES.6.3 Übertragbarkeit von Daten
- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.10 Serviceprofil
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.6 Shared Responsibility
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DET.3.1.1 Authentifizierungen
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.9 Fehler der Anwendung
- DET.3.5 Unbestreitbarkeit
- DET.4.11.2 Netzwerk-Honeypots
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.15 Ressourcenauslastung von Hostsystemen

- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.4 Änderungen an Sicherheitsrichtlinien
- DET.4.6 Anomale Nutzung der Anwendung
- DET.5.10 Zeitnahes Patchmanagement
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.2 Schwachstellenregister
- DET.5.3.2 Korrelation komplexer Angriffswege
- DET.5.3.3 Historische Analyse
- DET.5.8.1.1 Unautorisierte Publikation
- DET.6.1 Beurteilung von Ereignissen
- DET.6.1.2 Automatische Alarmierung
- DET.6.2.2 Datenträgerschleuse
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.6.1 Eingabevalidierung
- DEV.3.1 Replay-Angriffe
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.6 Compileroptionen
- DEV.6.1 Freigabe nach Änderungen und Tests
- DEV.7.1 Sichere Bereitstellung
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- DLS.4.1.1 Unabhängigkeit
- DLS.4.1.2 Berechtigungen deaktivieren
- GC.6.1.1 Festlegung einer Sicherheitsstrategie
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.7.1.2 Anhörung zuständiger Stellen
- GC.7.1.3 Vertragliche Verpflichtungen
- GC.7.1.4 Prävention von Verstößen
- GEB.1.3.1 Abnahme von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
- GEB.10.1.2 Klimamessung
- GEB.10.2.1 Baulicher Brandschutz

- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.3 Besucheranmeldung
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.7.1 Schlüsselbeauftragte
- GEB.7.3 Schlüsselaudit
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- GEB.9.7 Zweckentfremdung
- KONF.1.3 Management von Werkzeugen
- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.11.2 Warteraum
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.6 Einschränkung unauthifizierter Anschlüsse
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.1 Eingabevalidierung
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.12.10 Cookie-Attribute
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht

- KONF.12.14 DNS-Falschinformationen
- KONF.12.3 Cookies
- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.1.1 SPAM-Filter
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.6 Publikation der Serversignatur
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.2.1 Grundkonfiguration für Systeme
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.4.2 DNS-Anbindung
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.11 Einschränkung von Uploads
- KONF.6.12 Konferenzmoderation
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.5 Alarmierung
- NOT.4.10 Getrennte Aufbewahrung
- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung

- NOT.4.7 Versionierte Datensicherung
- NOT.4.8 Verschlüsselte Datensicherung
- NOT.4.9 Speichermedien
- PERF.3.1.1 Erstellen eines Auditsplans
- PERF.4.1.1 Einheitliches Bewertungsschema
- PERS.2.3 Rollentrennung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.3.4 Stellenbeschreibungen
- PERS.5.1 Maßregelung
- REA.2.3 Dokumentation von Vorfällen
- REA.2.4 Diagnosedaten
- REA.2.5 IT-Forensik
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.6.1 Dokumentation des Vorgehens
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.2.1 Information zuständiger Behörden
- REA.2.6.3 Koordinierung
- REA.3.1 Verbesserung durch Erkenntnisse
- SENS.1.2 Erfolgsmessung
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.5.1 Datenablage
- SENS.7.12 Öffentliche WLANs
- SENS.7.2 Virenskan
- SENS.7.25 Zugang zum Fahrzeug
- SENS.8.7 Verwendung von Brandschutzmitteln
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.3 Verwahrung außer Haus

- SENS.9.6 Mitnahme ins Ausland
- TEST.2.1 Versionshistorie
- TEST.2.2.1 Kategorisierung von Änderungen
- TEST.3.1 Sicherheitstest
- TEST.3.1.2 Integritätstest
- TEST.3.2 Testabdeckung
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen
- TEST.5.1 Information betroffener Kreise
- TEST.5.2 Verschlüsselte Bereitstellung
- TEST.5.4 Persistenz
- VRB.3.1 Identifikation von Verbesserungspotenzialen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.6 Demilitarisierte Zone
- ARCH.2.2.7 Management-Netz
- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.9 Filterung von DNS
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.9.1 Dimensionierung der Netzanbindung
- ASST.2.1 Inventar der Informationen
- ASST.2.1.1 Informationsverantwortung
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.2.4 Klassifizierung
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen

- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.13 Lagerung physischer Assets
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Geregelte Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.5.5 Wartungsfenster
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- ASST.7.1 Nicht mehr benötigte Anwendungen
- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Löschverfahren
- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BER.1.4 Inventar der Berechtigungen
- BER.2.1 Person-Identität
- BER.2.2 Einschränkung
- BER.2.3 Stammdatenprüfung
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.2.5 Deaktivierung bei Weggang
- BER.3.1 Zentrales Management
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.3 Protokollierung von Änderungen
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.4.1 Identitätsüberprüfung
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.2 Begründung von Berechtigungen
- BER.5.3 Überprüfung von Berechtigungen
- BER.5.8 Entzug von Berechtigungen
- BER.6.10 Monitoring von Zugangsdaten
- BER.6.3 Deaktivierung einfacher Biometrie
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.6 Blockieren von Passwort Recycling

- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.16.5 Beglaubigungsstatus
- BER.7.16.6 Revocationstatus
- BER.7.3 Verzeichnis öffentlicher Schlüssel
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.1.1 Verwendungszweck
- BES.2.1.3 Systemvoraussetzungen
- BES.2.1.4 Kompatibilität
- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.2 Auswahlkriterien
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.5.10 Behandlung von Vorfällen
- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.14 Löschregeln
- BES.5.3 Compliance-Verpflichtungen
- BES.5.5 Nutzungsregelungen
- BES.6.2 Löschung von Daten
- BES.6.3 Übertragbarkeit von Daten
- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.10 Serviceprofil
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten

- BES.7.4.6 Shared Responsibility
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DET.3.1.1 Authentifizierungen
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.9 Fehler der Anwendung
- DET.3.5 Unbestreitbarkeit
- DET.4.11.2 Netzwerk-Honeypots
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.15 Ressourcenauslastung von Hostsystemen
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.4 Änderungen an Sicherheitsrichtlinien
- DET.4.6 Anomale Nutzung der Anwendung
- DET.5.10 Zeitnahes Patchmanagement
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.2 Schwachstellenregister
- DET.5.3.2 Korrelation komplexer Angriffswege
- DET.5.3.3 Historische Analyse
- DET.5.8.1.1 Unautorisierte Publikation
- DET.6.1 Beurteilung von Ereignissen
- DET.6.1.2 Automatische Alarmierung
- DET.6.2.2 Datenträgerschleuse
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.6.1 Eingabevalidierung
- DEV.3.1 Replay-Angriffe
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.6 Compileroptionen
- DEV.6.1 Freigabe nach Änderungen und Tests
- DEV.7.1 Sichere Bereitstellung
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- DLS.3.5 Blockierung unzuverlässiger Dienstleister

- DLS.4.1.1 Unabhängigkeit
- DLS.4.1.2 Berechtigungen deaktivieren
- GEB.1.3.1 Abnahme von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
- GEB.10.1.2 Klimamessung
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.3 Besucheranmeldung
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.7.1 Schlüsselbeauftragte
- GEB.7.3 Schlüsselaudit
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- GEB.9.7 Zweckentfremdung
- KONF.1.3 Management von Werkzeugen
- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.11.2 Warteraum
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.11.8.2 Einschränkung von TK-Verbindungen

- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.1 Eingabevalidierung
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.12.10 Cookie-Attribute
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- KONF.12.14 DNS-Falschinformationen
- KONF.12.3 Cookies
- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.1.1 SPAM-Filter
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.6 Publikation der Serversignatur
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.2.1 Grundkonfiguration für Systeme
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.4.2 DNS-Anbindung
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.11 Einschränkung von Uploads
- KONF.6.12 Konferenzmoderation
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.5 Alarmierung

- NOT.4.10 Getrennte Aufbewahrung
- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.7 Versionierte Datensicherung
- NOT.4.8 Verschlüsselte Datensicherung
- NOT.4.9 Speichermedien
- PERS.2.3 Rollentrennung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.3.4 Stellenbeschreibungen
- PERS.5.1 Maßregelung
- REA.2.3 Dokumentation von Vorfällen
- REA.2.4 Diagnosedaten
- REA.2.5 IT-Forensik
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.6.1 Dokumentation des Vorgehens
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.2.1 Information zuständiger Behörden
- REA.2.6.3 Koordinierung
- REA.3.1 Verbesserung durch Erkenntnisse
- SENS.1.2 Erfolgsmessung
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.4 Nutzung unauthorisierter Assets
- SENS.2.4.1 Verbindung unauthorisierter IT-Systeme
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.5.1 Datenablage
- SENS.7.12 Öffentliche WLANs

- SENS.7.2 Virensan
- SENS.7.25 Zugang zum Fahrzeug
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.8.8 Verwendung von Wasserschuttmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.3 Verwahrung außer Haus
- SENS.9.6 Mitnahme ins Ausland
- TEST.2.1 Versionshistorie
- TEST.2.2.1 Kategorisierung von Änderungen
- TEST.3.1 Sicherheitstest
- TEST.3.1.2 Integritätstest
- TEST.3.2 Testabdeckung
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelter Notfalländerungen
- TEST.5.1 Information betroffener Kreise
- TEST.5.2 Verschlüsselte Bereitstellung
- TEST.5.4 Persistenz

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.6.1.1 Festlegung einer Sicherheitsstrategie
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.7.1.2 Anhörung zuständiger Stellen
- GC.7.1.3 Vertragliche Verpflichtungen
- GC.7.1.4 Prävention von Verstößen
- PERF.3.1.1 Erstellen eines Auditsplans
- PERF.4.1.1 Einheitliches Bewertungsschema
- VRB.3.1 Identifikation von Verbesserungspotenzialen

Eintrag: 4

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2.10 Drucker-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.6 Topologieüberwachung

- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- ARCH.7.3 Entwicklungs- und Testumgebungen
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.2 Redundante TK-Anbindung
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.14 Reserve physischer Assets
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.6 Wartung durch Externe
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.7.4 Wiederherstelltest
- ASST.7.5 Vernichtungseinrichtungen
- BER.2.6 Löschen nach Fristablauf
- BER.3.16 Gruppenkonten - MFA
- BER.3.20 Dienstkonten
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- BER.7.16.1 Zertifizierungsstelle
- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BES.1.4 Outsourcing-Strategie
- BES.1.4.1 Freigabe der Strategie
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.1.4.1 Kompatibilität der Schnittstellen

- BES.2.1.4.2 Kompatibilität der Netzanbindung
- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.5.2 Mandantentrennung
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.7 ISMS beim Dienstleister
- BES.4.8 Konformitätsnachweise
- BES.4.8.2 Cloud-Konformität
- BES.5.1 Kompetenzen
- BES.5.11 Recht auf Audit
- BES.5.2 Service Level Agreement
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.5.1 Datenlokationen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.9 Umgang mit Änderungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.5 Netzverbindungen ab Werk
- BES.8.3 Ressourcensouveränität
- DET.2.1.2 Meldeformulare
- DET.2.1.3 Rückmeldungen
- DET.2.2 Security Operations Center
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.3 Speicherkapazität
- DET.3.4 Revisionssicherheit
- DET.4.1 Überwachung der Protokollierung
- DET.4.12.1 Auslastung des Netzes
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.3 Überwachung der Angriffserkennung
- DET.4.5 Unerwünschte Datenabflüsse

- DET.5.1 Zeitnahes Schwachstellenmanagement
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DET.5.10.4 Integritätsprüfung von Patches
- DET.5.3.1 Autorisierung kritischer Scans
- DET.5.6 Threat Hunting
- DET.5.9 Externe Schwachstellenmeldungen
- DET.6.1.1 Automatisierte Feststellung
- DET.6.1.3 Dokumentation von Ergebnissen
- DET.6.2 Beurteilung von Eingängen
- DET.6.2.1 Dynamische Sandbox-Analyse
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.4 Integrität externer Softwarebibliotheken
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.4 Anhörung
- GC.9.1.1 Externer Austausch zur Informationssicherheit
- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.2.2 Brandabschnitte
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.3.1.1 Videoüberwachung
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.5.3 Lieferzugang
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.8.1.1 Archiv
- GEB.9.4 Überspannungsschutz
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.5 Überprüfung der Konfiguration
- KONF.11.5 Erraten von Zugriffslinks
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten

- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.5.1 Strenge Senderpolicy
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2.1 DNS-Verschlüsselung
- KONF.6.6.1 Mandantenfähigkeit
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.9.1 Speicherplatzbegrenzung
- NOT.2.1 Verfahren und Regelungen
- NOT.2.1.1 Rollen
- NOT.2.1.2 Alarmierung
- NOT.3.1 Wiederanlaufplan
- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen
- NOT.4.11 Datenträgerarchiv
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation
- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- REA.2.2 Automatische Erstreaktion
- REA.2.6.5 Eskalation
- REA.3.1.1 Quantitative Analyse
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.8.4 Begleitung Externer
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise
- TEST.2.2.3 Dokumentation der Abhängigkeiten

- TEST.3.1.1 Dokumentation von Testergebnissen
- TEST.3.1.3 Testdaten
- TEST.3.1.4 Testumgebung
- TEST.4.1.1 Unabhängigkeit der Autorisierung
- TEST.4.1.1.1 Staging
- TEST.4.1.2 Dokumentation der Freigabe
- TEST.5.5 Rückblick

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2.10 Drucker-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.6 Topologieüberwachung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- ARCH.7.3 Entwicklungs- und Testumgebungen
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.2 Redundante TK-Anbindung
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.14 Reserve physischer Assets
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.6 Wartung durch Externe
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.7.4 Wiederherstelltest
- ASST.7.5 Vernichtungseinrichtungen

- BER.2.6 Löschen nach Fristablauf
- BER.3.16 Gruppenkonten - MFA
- BER.3.20 Dienstkonten
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- BER.7.16.1 Zertifizierungsstelle
- BER.7.16.2 Beglaubigung
- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BES.1.4 Outsourcing-Strategie
- BES.1.4.1 Freigabe der Strategie
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.1.4.1 Kompatibilität der Schnittstellen
- BES.2.1.4.2 Kompatibilität der Netzanbindung
- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.5.2 Mandantentrennung
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.7 ISMS beim Dienstleister
- BES.4.8 Konformitätsnachweise
- BES.4.8.2 Cloud-Konformität
- BES.5.1 Kompetenzen
- BES.5.11 Recht auf Audit
- BES.5.2 Service Level Agreement
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.5.1 Datenlokationen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.9 Umgang mit Änderungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen

- BES.7.4.5 Netzverbindungen ab Werk
- BES.8.3 Ressourcensouveränität
- DET.2.1.2 Meldeformulare
- DET.2.1.3 Rückmeldungen
- DET.2.2 Security Operations Center
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.3 Speicherkapazität
- DET.3.4 Revisionssicherheit
- DET.4.1 Überwachung der Protokollierung
- DET.4.12.1 Auslastung des Netzes
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.3 Überwachung der Angriffserkennung
- DET.4.5 Unerwünschte Datenabflüsse
- DET.5.1 Zeitnahes Schwachstellenmanagement
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DET.5.10.4 Integritätsprüfung von Patches
- DET.5.3.1 Autorisierung kritischer Scans
- DET.5.6 Threat Hunting
- DET.5.9 Externe Schwachstellenmeldungen
- DET.6.1.1 Automatisierte Feststellung
- DET.6.1.3 Dokumentation von Ergebnissen
- DET.6.2 Beurteilung von Eingängen
- DET.6.2.1 Dynamische Sandbox-Analyse
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.4 Integrität externer Softwarebibliotheken
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.4 Anhörung
- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.2.2 Brandabschnitte
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.3.1.1 Videoüberwachung
- GEB.3.2 Anmelde- und Empfangsbereiche

- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.5.3 Lieferzugang
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.8.1.1 Archiv
- GEB.9.4 Überspannungsschutz
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.5 Überprüfung der Konfiguration
- KONF.11.5 Erraten von Zugriffslinks
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.5.1 Strenge Senderpolicy
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2.1 DNS-Verschlüsselung
- KONF.6.6.1 Mandantenfähigkeit
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.9.1 Speicherplatzbegrenzung
- NOT.2.1 Verfahren und Regelungen
- NOT.2.1.1 Rollen
- NOT.2.1.2 Alarmierung
- NOT.3.1 Wiederanlaufplan
- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen
- NOT.4.11 Datenträgerarchiv
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation

- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- REA.2.2 Automatische Erstreaktion
- REA.2.6.5 Eskalation
- REA.3.1.1 Quantitative Analyse
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.8.4 Begleitung Externer
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise
- TEST.2.2.3 Dokumentation der Abhängigkeiten
- TEST.3.1.1 Dokumentation von Testergebnissen
- TEST.3.1.3 Testdaten
- TEST.3.1.4 Testumgebung
- TEST.4.1.1 Unabhängigkeit der Autorisierung
- TEST.4.1.1.1 Staging
- TEST.4.1.2 Dokumentation der Freigabe
- TEST.5.5 Rückblick

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.9.1.1 Externer Austausch zur Informationssicherheit

Eintrag: 5

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2.11 Physische Segmentierung
- ARCH.2.2.12 Sprungserver
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.3 Mikrosegmentierung
- ARCH.4.1.2 Quarantäne
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.13 Produktdiversität
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.7.2 Dedizierte Hardware

- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.3.2.1 Software Discovery
- ASST.3.15 Ausleihe physischer Assets
- ASST.3.5 Tainting
- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung
- ASST.4.4 Nachweis des Zugangs
- ASST.6.3 Konformitätsprüfung
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3.3 Zugelassene Löschanwendungen
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.5.7 IT-System-Zugangskonto
- BER.7.7 Kein Transport privater Schlüssel
- BES.1.3.1 Gesamte Lieferkette
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.4.6.3 Manipulationsschutz
- BES.4.8.1 Zertifizierung
- BES.4.8.3 IT-Grundsicherheits-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.13.1 Datenbereitstellung
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.5.7 Schulung
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.2.1 Löschverfahren

- BES.6.4 Übertragung von Supportdienstleistungen
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.4 Individuelle Implementierung kritischer Komponenten
- BES.8.5 Treuhand
- DET.2.3 Ständiger Bereitschaftsdienst
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.2 Filterung nicht benötigter Inhalte
- DET.4.10 Host-basierte Köder
- DET.4.11 Anomalien in Netzen und am Perimeter
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen
- DET.4.11.3 Netzverkehrsfluss
- DET.4.12 Monitoring der Netzverfügbarkeit
- DET.4.18 Öffentliche Blocklisten
- DET.4.19 Unautorisierte Sendeanlagen
- DET.4.2 Automatische Angriffserkennung
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- DET.4.9 Manipulations-Checkup
- DET.5.1.1 Risikobasierte Priorisierung
- DET.5.10.1 Autorisierte Bezugsquellen
- DET.5.10.5 Test gemäß Änderungsmanagement
- DET.5.3 Schwachstellenscans
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- DET.5.7 Analyse verdeckter Kanäle
- DET.5.8 Bedrohungsanalyse
- DET.5.8.1 Auswertung öffentlicher Quellen
- DET.5.9.1 Bonusprogramm
- DEV.4.7 Deterministischer Binärcode
- DLS.2.3 Vollverschlüsselung
- DLS.3.6 Portabilität

- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4.1 Niederohmigkeit
- GEB.2.4 Elektromagnetische Abschirmung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.4 Berechtigungsmarkierung
- GEB.3.5 Einbruchhemmung
- GEB.3.6 Einbruchmeldeanlagen
- GEB.4.1 Einrichtung
- GEB.4.2 Gesonderte Autorisierung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.2 Staub und Schmutz
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.8.4 Überwachung schonender Klimatisierung
- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.2 Lasttest
- GEB.9.3 Notaus
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1.6 JavaScript
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.6 Browser-Historie
- KONF.13.4 Kryptographische Signatur durch Nutzende

- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.4 Caching
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.4 Physischer Diebstahlschutz
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.3 Kiosk-Modus
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.9.2 Begrenzung der Rechenleistung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.1.1.4 Business Continuity Management System
- NOT.2.1.3 Stabsraum
- NOT.2.1.4 Stabsübung
- NOT.3.2 Geschäftsfortführungsplan

- NOT.3.4 Funktionstest
- NOT.4.12 Georedundanz
- NOT.4.17 Anwendungstest
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- PERS.5.2 Innentäter
- REA.1.3 Übungen zur Vorfallsbehandlung
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.5.3 Forensik-Dienstleister
- REA.2.6.4 Service Level
- SENS.12.1 Hohe Risiken
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.8.3 Mitbringen von IT-Systemen
- TEST.3.1.10 Penetrationstest bei Änderungen
- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering
- TEST.3.1.7 Analyse der Zusammensetzung
- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest
- TEST.4.2 Signatur
- TEST.5.3 Schrittweiser Rollout

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2.11 Physische Segmentierung
- ARCH.2.2.12 Sprungserver
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.3 Mikrosegmentierung
- ARCH.4.1.2 Quarantäne
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.13 Produktdiversität
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.7.2 Dedizierte Hardware
- ARCH.8.3 Redundante Server

- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.3.2.1 Software Discovery
- ASST.3.15 Ausleihe physischer Assets
- ASST.3.5 Tainting
- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung
- ASST.4.4 Nachweis des Zugangs
- ASST.6.3 Konformitätsprüfung
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3.3 Zugelassene Löschanwendungen
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.5.7 IT-System-Zugangskonto
- BER.7.7 Kein Transport privater Schlüssel
- BES.1.3.1 Gesamte Lieferkette
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.4.6.3 Manipulationsschutz
- BES.4.8.1 Zertifizierung
- BES.4.8.3 IT-Grundschatz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.13.1 Datenbereitstellung
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.5.7 Schulung
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.2.1 Lösungsverfahren
- BES.6.4 Übertragung von Supportdienstleistungen

- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.4 Individuelle Implementierung kritischer Komponenten
- BES.8.5 Treuhand
- DET.2.3 Ständiger Bereitschaftsdienst
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.2 Filterung nicht benötigter Inhalte
- DET.4.10 Host-basierte Köder
- DET.4.11 Anomalien in Netzen und am Perimeter
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen
- DET.4.11.3 Netzverkehrsfluss
- DET.4.12 Monitoring der Netzverfügbarkeit
- DET.4.18 Öffentliche Blocklisten
- DET.4.19 Unautorisierte Sendeanlagen
- DET.4.2 Automatische Angriffserkennung
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- DET.4.9 Manipulations-Checkup
- DET.5.1.1 Risikobasierte Priorisierung
- DET.5.10.1 Autorisierte Bezugsquellen
- DET.5.10.5 Test gemäß Änderungsmanagement
- DET.5.3 Schwachstellenscans
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- DET.5.7 Analyse verdeckter Kanäle
- DET.5.8 Bedrohungsanalyse
- DET.5.8.1 Auswertung öffentlicher Quellen
- DET.5.9.1 Bonusprogramm
- DEV.4.7 Deterministischer Binärcode
- DLS.2.3 Vollverschlüsselung
- DLS.3.6 Portabilität
- GEB.10.1.3 Redundante Klimatisierung

- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4.1 Niederohmigkeit
- GEB.2.4 Elektromagnetische Abschirmung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.4 Berechtigungsmarkierung
- GEB.3.5 Einbruchhemmung
- GEB.3.6 Einbruchmeldeanlagen
- GEB.4.1 Einrichtung
- GEB.4.2 Gesonderte Autorisierung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.2 Staub und Schmutz
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.8.4 Überwachung schonender Klimatisierung
- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.2 Lasttest
- GEB.9.3 Notaus
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1.6 JavaScript
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.6 Browser-Historie
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.7 TLS-Reports

- KONF.13.8 DMARC-Reports
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.4 Caching
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.4 Physischer Diebstahlschutz
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.3 Kiosk-Modus
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.9.2 Begrenzung der Rechenleistung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.1.1.4 Business Continuity Management System
- NOT.2.1.3 Stabsraum
- NOT.2.1.4 Stabsübung
- NOT.3.2 Geschäftsfortführungsplan
- NOT.3.4 Funktionstest

- NOT.4.12 Georedundanz
- NOT.4.17 Anwendungstest
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- PERS.5.2 Innentäter
- REA.1.3 Übungen zur Vorfallsbehandlung
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.5.3 Forensik-Dienstleister
- REA.2.6.4 Service Level
- SENS.12.1 Hohe Risiken
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.8.3 Mitbringen von IT-Systemen
- TEST.3.1.10 Penetrationstest bei Änderungen
- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering
- TEST.3.1.7 Analyse der Zusammensetzung
- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest
- TEST.4.2 Signatur
- TEST.5.3 Schrittweiser Rollout

Namespace: modal_verbs

Eintrag: KANN

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2.11 Physische Segmentierung
- ARCH.2.2.12 Sprungserver
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.3 Mikrosegmentierung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.4.1.2 Quarantäne
- ARCH.5.1.12 Software-definierte Verbindungen

- ARCH.5.1.13 Produktdiversität
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.7.2 Dedizierte Hardware
- ARCH.8.2 Redundante TK-Anbindung
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.3.2.1 Software Discovery
- ASST.3.15 Ausleihe physischer Assets
- ASST.3.5 Tainting
- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.4 Nachweis des Zugangs
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.6 Wartung durch Externe
- ASST.6.3 Konformitätsprüfung
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.4 Wiederherstelltest
- ASST.7.5 Vernichtungseinrichtungen
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.21 Notfallzugang
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.5.7 IT-System-Zugangskonto
- BER.7.7 Kein Transport privater Schlüssel
- BES.1.3.1 Gesamte Lieferkette
- BES.1.4 Outsourcing-Strategie
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus

- BES.4.5.2 Mandantentrennung
- BES.4.6.3 Manipulationsschutz
- BES.4.8.1 Zertifizierung
- BES.4.8.3 IT-Grundschutz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.13.1 Datenbereitstellung
- BES.5.5.1 Datenlokationen
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.5.7 Schulung
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.2.1 Löschverfahren
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität
- BES.8.4 Individuelle Implementierung kritischer Komponenten
- BES.8.5 Treuhand
- DET.2.2 Security Operations Center
- DET.2.3 Ständiger Bereitschaftsdienst
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.2 Filterung nicht benötigter Inhalte
- DET.3.5 Unbestreitbarkeit
- DET.4.10 Host-basierte Köder
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen
- DET.4.11.2 Netzwerk-Honeypots

- DET.4.11.3 Netzverkehrsfluss
- DET.4.12.1 Auslastung des Netzes
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.18 Öffentliche Blocklisten
- DET.4.19 Unautorisierte Sendeanlagen
- DET.4.5 Unerwünschte Datenabflüsse
- DET.4.6 Anomale Nutzung der Anwendung
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- DET.4.9 Manipulations-Checkup
- DET.5.1.1 Risikobasierte Priorisierung
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DET.5.10.5 Test gemäß Änderungsmanagement
- DET.5.3.2 Korrelation komplexer Angriffswege
- DET.5.3.3 Historische Analyse
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- DET.5.6 Threat Hunting
- DET.5.7 Analyse verdeckter Kanäle
- DET.5.8.1 Auswertung öffentlicher Quellen
- DET.5.8.1.1 Unautorisierte Publikation
- DET.5.9.1 Bonusprogramm
- DET.6.1.3 Dokumentation von Ergebnissen
- DET.6.2.1 Dynamische Sandbox-Analyse
- DET.6.2.2 Datenträgerschleuse
- DEV.4.7 Deterministischer Binärcode
- DLS.2.3 Vollverschlüsselung
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.6 Portabilität
- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.7 Brandunterdrückung
- GEB.10.3.1 Doppelter baulicher Wasserschutz

- GEB.10.3.2 Leckagesensor
- GEB.10.4.1 Niederohmigkeit
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.4 Elektromagnetische Abschirmung
- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.4 Berechtigungsmarkierung
- GEB.3.5 Einbruchhemmung
- GEB.3.6 Einbruchmeldeanlagen
- GEB.4.1 Einrichtung
- GEB.4.2 Gesonderte Autorisierung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.1.1 Archiv
- GEB.8.2 Staub und Schmutz
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.8.4 Überwachung schonender Klimatisierung
- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.2 Lasttest
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1.6 JavaScript
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.6 Browser-Historie
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.7 TLS-Reports

- KONF.13.8 DMARC-Reports
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.4 Caching
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.4 Physischer Diebstahlschutz
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.3 Kiosk-Modus
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.9.2 Begrenzung der Rechenleistung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.1.1.4 Business Continuity Management System
- NOT.2.1.3 Stabsraum
- NOT.2.1.4 Stabsübung
- NOT.3.2 Geschäftsfortführungsplan
- NOT.3.4 Funktionstest

- NOT.4.12 Georedundanz
- NOT.4.17 Anwendungstest
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- REA.1.3 Übungen zur Vorfallsbehandlung
- REA.2.2 Automatische Erstreaktion
- REA.2.5 IT-Forensik
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.5.3 Forensik-Dienstleister
- REA.2.6.4 Service Level
- SENS.12.1 Hohe Risiken
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.8.4 Begleitung Externer
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.6 Mitnahme ins Ausland
- TEST.3.1.10 Penetrationstest bei Änderungen
- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering
- TEST.3.1.7 Analyse der Zusammensetzung
- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest
- TEST.4.1.1 Unabhängigkeit der Autorisierung
- TEST.4.2 Signatur
- TEST.5.3 Schrittweiser Rollout

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2.11 Physische Segmentierung
- ARCH.2.2.12 Sprungserver
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.3 Mikrosegmentierung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.4.1.2 Quarantäne

- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.13 Produktdiversität
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.7.2 Dedizierte Hardware
- ARCH.8.2 Redundante TK-Anbindung
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.3.2.1 Software Discovery
- ASST.3.15 Ausleihe physischer Assets
- ASST.3.5 Tainting
- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung
- ASST.3.9 Aktualisierung
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.4 Nachweis des Zugangs
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.6 Wartung durch Externe
- ASST.6.3 Konformitätsprüfung
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.4 Wiederherstelltest
- ASST.7.5 Vernichtungseinrichtungen
- BER.3.14 Zugang nur durch zwei Personen
- BER.3.21 Notfallzugang
- BER.5.1.2 JIT--JEA-Berechtigungen
- BER.5.7 IT-System-Zugangskonto
- BER.7.7 Kein Transport privater Schlüssel
- BES.1.3.1 Gesamte Lieferkette
- BES.1.4 Outsourcing-Strategie
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation

- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.5.2 Mandantentrennung
- BES.4.6.3 Manipulationsschutz
- BES.4.8.1 Zertifizierung
- BES.4.8.3 IT-Grundschutz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.13.1 Datenbereitstellung
- BES.5.5.1 Datenlokationen
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.5.7 Schulung
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.2.1 Löschverfahren
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität
- BES.8.4 Individuelle Implementierung kritischer Komponenten
- BES.8.5 Treuhand
- DET.2.2 Security Operations Center
- DET.2.3 Ständiger Bereitschaftsdienst
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.12 Datenverarbeitungen
- DET.3.1.13 Integration von Cloud-Diensten
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse
- DET.3.2 Filterung nicht benötigter Inhalte
- DET.3.5 Unbestreitbarkeit
- DET.4.10 Host-basierte Köder
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen

- DET.4.11.2 Netzwerk-Honeypots
- DET.4.11.3 Netzverkehrsfluss
- DET.4.12.1 Auslastung des Netzes
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.18 Öffentliche Blocklisten
- DET.4.19 Unautorisierte Sendeanlagen
- DET.4.5 Unerwünschte Datenabflüsse
- DET.4.6 Anomale Nutzung der Anwendung
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- DET.4.9 Manipulations-Checkup
- DET.5.1.1 Risikobasierte Priorisierung
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DET.5.10.5 Test gemäß Änderungsmanagement
- DET.5.3.2 Korrelation komplexer Angriffswege
- DET.5.3.3 Historische Analyse
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- DET.5.6 Threat Hunting
- DET.5.7 Analyse verdeckter Kanäle
- DET.5.8.1 Auswertung öffentlicher Quellen
- DET.5.8.1.1 Unautorisierte Publikation
- DET.5.9.1 Bonusprogramm
- DET.6.1.3 Dokumentation von Ergebnissen
- DET.6.2.1 Dynamische Sandbox-Analyse
- DET.6.2.2 Datenträgerschleuse
- DEV.4.7 Deterministischer Binärcode
- DLS.2.3 Vollverschlüsselung
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.6 Portabilität
- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.10.2.7 Brandunterdrückung

- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4.1 Niederohmigkeit
- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.2.4 Elektromagnetische Abschirmung
- GEB.3.1.1 Videoüberwachung
- GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.4 Berechtigungsmarkierung
- GEB.3.5 Einbruchhemmung
- GEB.3.6 Einbruchmeldeanlagen
- GEB.4.1 Einrichtung
- GEB.4.2 Gesonderte Autorisierung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.4 Normgerechte Rechenzentren
- GEB.8.1.1 Archiv
- GEB.8.2 Staub und Schmutz
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.8.4 Überwachung schonender Klimatisierung
- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.2 Lasttest
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1.6 JavaScript
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.6 Browser-Historie
- KONF.13.4 Kryptographische Signatur durch Nutzende

- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.4 Caching
- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.4 Physischer Diebstahlschutz
- KONF.3.5 Standortbestimmung
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.15 Virtualisierte Browser-Umgebung
- KONF.6.16 Datenaustausch in der Virtualisierung
- KONF.6.3 Kiosk-Modus
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.9.2 Begrenzung der Rechenleistung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.1.1.4 Business Continuity Management System
- NOT.2.1.3 Stabsraum
- NOT.2.1.4 Stabsübung
- NOT.3.2 Geschäftsfortführungsplan

- NOT.3.4 Funktionstest
- NOT.4.12 Georedundanz
- NOT.4.17 Anwendungstest
- PERS.3.6.1 Sicherheitsüberprüfung (intern)
- REA.1.3 Übungen zur Vorfallsbehandlung
- REA.2.2 Automatische Erstreaktion
- REA.2.5 IT-Forensik
- REA.2.5.2 Vier-Augen-Prinzip
- REA.2.5.3 Forensik-Dienstleister
- REA.2.6.4 Service Level
- SENS.12.1 Hohe Risiken
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.7.14 Unautorisierte WLANs
- SENS.7.18 Mobiltelefone in Sicherheitsbereichen
- SENS.7.19 Unverschlüsselte SMS oder MMS
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.8.4 Begleitung Externer
- SENS.8.8 Verwendung von Wasserschutzmitteln
- SENS.9.6 Mitnahme ins Ausland
- TEST.3.1.10 Penetrationstest bei Änderungen
- TEST.3.1.5 Kontinuierliche Tests
- TEST.3.1.6 Chaos Engineering
- TEST.3.1.7 Analyse der Zusammensetzung
- TEST.3.1.8 Fuzzing
- TEST.3.1.9 Lasttest
- TEST.4.1.1 Unabhängigkeit der Autorisierung
- TEST.4.2 Signatur
- TEST.5.3 Schrittweiser Rollout

Eintrag: MUSS

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.1.1 Verfahren und Regelungen
- ARCH.1.1.1 Dokumentation
- ARCH.1.1.2 Zuweisung der Aufgaben

- ARCH.1.1.3 Bekanntgabe
- ARCH.1.2 Regelmäßige Überprüfung
- ASST.1.1 Verfahren und Regelungen
 - ASST.1.1.1 Dokumentation
 - ASST.1.1.2 Zuweisung der Aufgaben
 - ASST.1.1.3 Bekanntgabe
- ASST.1.2 Regelmäßige Überprüfung
- BER.1.1 Verfahren und Regelungen
 - BER.1.1.1 Dokumentation
 - BER.1.1.2 Zuweisung der Aufgaben
 - BER.1.1.3 Bekanntgabe
- BER.1.2 Regelmäßige Überprüfung
- BES.1.1 Verfahren und Regelungen
 - BES.1.1.1 Dokumentation
 - BES.1.1.2 Zuweisung der Aufgaben
 - BES.1.1.3 Bekanntgabe
- BES.1.2 Regelmäßige Überprüfung
- DET.1.1 Verfahren und Regelungen
 - DET.1.1.1 Dokumentation
 - DET.1.1.2 Zuweisung der Aufgaben
 - DET.1.1.3 Bekanntgabe
- DET.1.2 Regelmäßige Überprüfung
- DEV.1.1 Verfahren und Regelungen
 - DEV.1.1.1 Dokumentation
 - DEV.1.1.2 Zuweisung der Aufgaben
 - DEV.1.1.3 Bekanntgabe
- DEV.1.2 Regelmäßige Überprüfung
- DLS.1.1 Verfahren und Regelungen
 - DLS.1.1.1 Dokumentation
 - DLS.1.1.2 Zuweisung der Aufgaben
 - DLS.1.1.3 Bekanntgabe
- DLS.1.2 Regelmäßige Überprüfung
- GC.1.1 Errichtung und Aufrechterhaltung eines ISMS
- GC.10.1 Festlegung von Vorgehensweisen
- GC.10.2 Freigabe von Vorgehensweisen
- GC.11.1 Methodik für das Risikomanagement
- GC.2.1 Festlegung des externen Kontextes der Institution
- GC.2.2 Festlegung des internen Kontextes der Institution

- GC.3.1 Analyse der externen interessierten Parteien
- GC.3.2 Analyse der internen interessierten Parteien
- GC.4.1 Festlegung des Geltungsbereichs
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- GC.6.1 Festlegung von Zielen für die Informationssicherheit
- GC.6.1.2 Verpflichtung der Institutionsleitung
- GC.6.1.3 Erstellung einer Sicherheitsleitlinie
- GC.6.1.4 Freigabe der Sicherheitsleitlinie
- GC.7.1 Verfahren und Regelungen
- GC.8.1 Verfahren zur Ressourcenplanung
- GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
- GC.8.1.1.1 Informationssicherheitsbeauftragter
- GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
- GC.8.1.2 Stellvertreterregelungen
- GC.8.1.3 Vermeidung von Interessenkonflikten
- GC.8.1.4 Festlegung einer Sicherheitsorganisation
- GC.8.1.5 Sicherstellung der Qualifikation
- GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten
- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement
- GC.9.1.2 Kommunikation im Projektmanagement
- GC.9.1.3 Dokumentenlenkung
- GEB.1.1 Verfahren und Regelungen
- GEB.1.1.1 Dokumentation
- GEB.1.1.2 Zuweisung der Aufgaben
- GEB.1.1.3 Bekanntgabe
- GEB.1.2 Regelmäßige Überprüfung
- KONF.1.1 Verfahren und Regelungen
- KONF.1.1.1 Dokumentation
- KONF.1.1.2 Zuweisung der Aufgaben
- KONF.1.1.3 Bekanntgabe
- KONF.1.2 Regelmäßige Überprüfung
- NOT.1.1 Verfahren und Regelungen
- NOT.1.1.1 Dokumentation
- NOT.1.1.2 Zuweisung der Aufgaben
- NOT.1.1.3 Bekanntgabe

- NOT.1.2 Regelmäßige Überprüfung
- PERF.1.1 Verfahren und Regelungen
- PERF.3.1 Aufbau und Pflege eines Auditprogramms
 - PERF.3.1.2 Planen von internen Audits
 - PERF.3.1.3 Auswahl des Auditteams
 - PERF.3.1.4 Umfang von Audits
- PERF.4.1 Dokumentation von Auditergebnissen
 - PERF.4.1.2 Kommunikation an Stakeholder
- PERF.5.1 Eignungsprüfung
 - PERF.5.1.9 Maßnahmenvorschläge
- PERF.5.2 Bericht an die Institutionsleitung
- PERF.6.1 Sicherheitsvorfälle
 - PERF.6.1.1 Sicherheitsvorfälle
 - PERF.6.1.2 Schwachstellen
 - PERF.6.1.3 Bedrohungen
- PERF.7.1 Aktualität der Anforderungen
- PERS.1.1 Verfahren und Regelungen
 - PERS.1.1.1 Dokumentation
 - PERS.1.1.2 Zuweisung der Aufgaben
 - PERS.1.1.3 Bekanntgabe
- PERS.1.2 Regelmäßige Überprüfung
- REA.1.1 Verfahren und Regelungen
 - REA.1.1.1 Dokumentation
 - REA.1.1.2 Zuweisung der Aufgaben
 - REA.1.1.3 Bekanntgabe
- REA.1.2 Regelmäßige Überprüfung
- RISK.1.1 Methodik für das Risikomanagement
 - RISK.1.10 Freigabe der Umsetzungsplanung
 - RISK.1.3 Risikoeigentümer
 - RISK.1.5 Freigabe des Risikomanagements
- SENS.1.1 Verfahren und Regelungen
 - SENS.1.1.1 Dokumentation
 - SENS.1.1.2 Zuweisung der Aufgaben
 - SENS.1.1.3 Bekanntgabe
- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen
- STM.2.1 Erstellung eines Anforderungspakets
- STM.3.1 ISMS-Anforderungen des Informationsverbundes

- STM.4.1 Erfassung relevanter Assets
- STM.4.2 Dokumentation relevanter Assets
- STM.4.3 Mapping des Assets auf die Zielobjektkategorien
- STM.5.1 Modellierung der Anforderungen mit Zielobjekt
- STM.5.2 Vererbung von Zielobjektkategorien
- STM.5.3 Konsolidierung und Redundanzprüfung
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.6.2 Auf Grund externer Verpflichtungen
- STM.7.1 Überprüfung des gesetzten Sicherheitsniveaus
- STM.8.1 Risikobetrachtung bei fehlenden Anforderungen
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- TEST.1.1 Verfahren und Regelungen
 - TEST.1.1.1 Dokumentation
 - TEST.1.1.2 Zuweisung der Aufgaben
 - TEST.1.1.3 Bekanntgabe
- TEST.1.2 Regelmäßige Überprüfung
- UMS.1.1 Ermittlung des Umsetzungsstatus
- UMS.3.1 Umsetzungsplanung
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen
- UMS.5.1 Autorisierung von Ausnahmen
- UMS.5.2 Dokumentation von Ausnahmen
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.1.1 Verfahren zur kontinuierlichen Verbesserung
- VRB.1.2 Änderungen im ISMS
- VRB.2.1 Umgang mit Nicht-Konformitäten
- VRB.4.1 Korrekturmaßnahmen
- VRB.4.2 Verbesserungsmaßnahmen
- VRB.5.1 Priorisierung von Maßnahmen
- VRB.6.1 Wirksamkeitsprüfung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.1.1 Verfahren und Regelungen
 - ARCH.1.1.1 Dokumentation
 - ARCH.1.1.2 Zuweisung der Aufgaben
 - ARCH.1.1.3 Bekanntgabe
- ARCH.1.2 Regelmäßige Überprüfung
- ASST.1.1 Verfahren und Regelungen
 - ASST.1.1.1 Dokumentation
 - ASST.1.1.2 Zuweisung der Aufgaben
 - ASST.1.1.3 Bekanntgabe
- ASST.1.2 Regelmäßige Überprüfung
- BER.1.1 Verfahren und Regelungen
 - BER.1.1.1 Dokumentation
 - BER.1.1.2 Zuweisung der Aufgaben
 - BER.1.1.3 Bekanntgabe
- BER.1.2 Regelmäßige Überprüfung
- BES.1.1 Verfahren und Regelungen
 - BES.1.1.1 Dokumentation
 - BES.1.1.2 Zuweisung der Aufgaben
 - BES.1.1.3 Bekanntgabe
- BES.1.2 Regelmäßige Überprüfung
- DET.1.1 Verfahren und Regelungen
 - DET.1.1.1 Dokumentation
 - DET.1.1.2 Zuweisung der Aufgaben
 - DET.1.1.3 Bekanntgabe
- DET.1.2 Regelmäßige Überprüfung
- DEV.1.1 Verfahren und Regelungen
 - DEV.1.1.1 Dokumentation
 - DEV.1.1.2 Zuweisung der Aufgaben
 - DEV.1.1.3 Bekanntgabe
- DEV.1.2 Regelmäßige Überprüfung
- DLS.1.1 Verfahren und Regelungen
 - DLS.1.1.1 Dokumentation
 - DLS.1.1.2 Zuweisung der Aufgaben
 - DLS.1.1.3 Bekanntgabe
- DLS.1.2 Regelmäßige Überprüfung
- GEB.1.1 Verfahren und Regelungen
 - GEB.1.1.1 Dokumentation
 - GEB.1.1.2 Zuweisung der Aufgaben

- GEB.1.1.3 Bekanntgabe
- GEB.1.2 Regelmäßige Überprüfung
- KONF.1.1 Verfahren und Regelungen
 - KONF.1.1.1 Dokumentation
 - KONF.1.1.2 Zuweisung der Aufgaben
 - KONF.1.1.3 Bekanntgabe
- KONF.1.2 Regelmäßige Überprüfung
- NOT.1.1 Verfahren und Regelungen
 - NOT.1.1.1 Dokumentation
 - NOT.1.1.2 Zuweisung der Aufgaben
 - NOT.1.1.3 Bekanntgabe
- NOT.1.2 Regelmäßige Überprüfung
- PERS.1.1 Verfahren und Regelungen
 - PERS.1.1.1 Dokumentation
 - PERS.1.1.2 Zuweisung der Aufgaben
 - PERS.1.1.3 Bekanntgabe
- PERS.1.2 Regelmäßige Überprüfung
- REA.1.1 Verfahren und Regelungen
 - REA.1.1.1 Dokumentation
 - REA.1.1.2 Zuweisung der Aufgaben
 - REA.1.1.3 Bekanntgabe
- REA.1.2 Regelmäßige Überprüfung
- SENS.1.1 Verfahren und Regelungen
 - SENS.1.1.1 Dokumentation
 - SENS.1.1.2 Zuweisung der Aufgaben
 - SENS.1.1.3 Bekanntgabe
- TEST.1.1 Verfahren und Regelungen
 - TEST.1.1.1 Dokumentation
 - TEST.1.1.2 Zuweisung der Aufgaben
 - TEST.1.1.3 Bekanntgabe
- TEST.1.2 Regelmäßige Überprüfung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.1.1 Errichtung und Aufrechterhaltung eines ISMS
- GC.10.1 Festlegung von Vorgehensweisen
- GC.10.2 Freigabe von Vorgehensweisen
- GC.11.1 Methodik für das Risikomanagement

- GC.2.1 Festlegung des externen Kontextes der Institution
- GC.2.2 Festlegung des internen Kontextes der Institution
- GC.3.1 Analyse der externen interessierten Parteien
- GC.3.2 Analyse der internen interessierten Parteien
- GC.4.1 Festlegung des Geltungsbereichs
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
 - GC.5.1.1 Festlegung der Geschäftsprozesse
 - GC.5.1.2 Festlegung des Schutzbedarfs
 - GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- GC.6.1 Festlegung von Zielen für die Informationssicherheit
 - GC.6.1.2 Verpflichtung der Institutionsleitung
 - GC.6.1.3 Erstellung einer Sicherheitsleitlinie
 - GC.6.1.4 Freigabe der Sicherheitsleitlinie
- GC.7.1 Verfahren und Regelungen
- GC.8.1 Verfahren zur Ressourcenplanung
 - GC.8.1.1 Festlegung von Rollen und Zuständigkeiten
 - GC.8.1.1.1 Informationssicherheitsbeauftragter
 - GC.8.1.1.1.1 Vorspracherecht des Informationssicherheitsbeauftragten
 - GC.8.1.2 Stellvertreterregelungen
 - GC.8.1.3 Vermeidung von Interessenkonflikten
 - GC.8.1.4 Festlegung einer Sicherheitsorganisation
 - GC.8.1.5 Sicherstellung der Qualifikation
 - GC.8.1.6 Ressourcen für den Informationssicherheitsbeauftragten
- GC.9.1 Festlegung eines Verfahrens zum Kommunikationsmanagement
 - GC.9.1.2 Kommunikation im Projektmanagement
 - GC.9.1.3 Dokumentenlenkung
- PERF.1.1 Verfahren und Regelungen
- PERF.3.1 Aufbau und Pflege eines Auditprogramms
 - PERF.3.1.2 Planen von internen Audits
 - PERF.3.1.3 Auswahl des Auditteams
 - PERF.3.1.4 Umfang von Audits
- PERF.4.1 Dokumentation von Auditergebnissen
 - PERF.4.1.2 Kommunikation an Stakeholder
- PERF.5.1 Eignungsprüfung
 - PERF.5.1.9 Maßnahmenvorschläge
- PERF.5.2 Bericht an die Institutionsleitung
- PERF.6.1 Sicherheitsvorfälle
 - PERF.6.1.1 Sicherheitsvorfälle

- PERF.6.1.2 Schwachstellen
- PERF.6.1.3 Bedrohungen
- PERF.7.1 Aktualität der Anforderungen
- STM.1.1 Definition und Abgrenzung des Informationsverbunds
- STM.1.2 Dokumentation der externen Schnittstellen
- STM.2.1 Erstellung eines Anforderungspakets
- STM.3.1 ISMS-Anforderungen des Informationsverbundes
- STM.4.1 Erfassung relevanter Assets
- STM.4.2 Dokumentation relevanter Assets
- STM.4.3 Mapping des Assets auf die Zielobjektkategorien
- STM.5.1 Modellierung der Anforderungen mit Zielobjekt
- STM.5.2 Vererbung von Zielobjektkategorien
- STM.5.3 Konsolidierung und Redundanzprüfung
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.6.2 Auf Grund externer Verpflichtungen
- STM.7.1 Überprüfung des gesetzten Sicherheitsniveaus
- STM.8.1 Risikobetrachtung bei fehlenden Anforderungen
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- UMS.1.1 Ermittlung des Umsetzungsstatus
- UMS.3.1 Umsetzungsplanung
- UMS.3.2 Priorisierung von Maßnahmen
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen
- UMS.5.1 Autorisierung von Ausnahmen
- UMS.5.2 Dokumentation von Ausnahmen
- UMS.6.1 Nachverfolgung des Umsetzungsfortschritts
- UMS.6.2 Fortschreibung des Umsetzungsplans
- UMS.7.1 Wahrung von Compliance in der Umsetzung
- VRB.1.1 Verfahren zur kontinuierlichen Verbesserung
- VRB.1.2 Änderungen im ISMS
- VRB.2.1 Umgang mit Nicht-Konformitäten
- VRB.4.1 Korrekturmaßnahmen
- VRB.4.2 Verbesserungsmaßnahmen
- VRB.5.1 Priorisierung von Maßnahmen
- VRB.6.1 Wirksamkeitsprüfung

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.1 Methodik für das Risikomanagement
- RISK.1.10 Freigabe der Umsetzungsplanung
- RISK.1.2 Einhaltung der BSI-Kriterien
- RISK.1.3 Risikoeigentümer
- RISK.1.4 Risikoappetit
- RISK.1.5 Freigabe des Risikomanagements
- RISK.1.6 Kritikalitätskriterien für Geschäftsprozesse
- RISK.1.7 Kriterien für die Risikobeurteilung
- RISK.1.8 Kriterien für die Risikoakzeptanz

Eintrag: SOLLTE

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.1 Externe Netzanschlüsse
 - ARCH.2.2.10 Drucker-Netz
 - ARCH.2.2.2 Gastnetz
 - ARCH.2.2.3 Segmentierung von Servern und Clients
 - ARCH.2.2.5 OT-Systeme
 - ARCH.2.2.6 Demilitarisierte Zone
 - ARCH.2.2.7 Management-Netz
 - ARCH.2.2.8 Segmentierung von Test und Betrieb
 - ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ARCH.2.6 Topologieüberwachung
- ARCH.3.1 Netzabdeckung
 - ARCH.3.3 SSIDs
 - ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.4.1 Netzzugangskontrolle
 - ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
 - ARCH.5.1.1 Blockieren anfälliger Netzprotokolle

- ARCH.5.1.10 Webfilterung
 - ARCH.5.1.10.1 Bekannte schädliche Inhalte
 - ARCH.5.1.10.2 Bekannte illegale Inhalte
 - ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.7.3 Entwicklungs- und Testumgebungen
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.9.1 Dimensionierung der Netzanbindung
- ASST.2.1 Inventar der Informationen
 - ASST.2.1.1 Informationsverantwortung
- ASST.2.2 Inventar der Systeme
 - ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- ASST.2.3 Inventar der Anwendungen
 - ASST.2.3.1 Autorisierung von Anwendungen
 - ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.2.4 Klassifizierung
- ASST.3.1 Nutzungsvereinbarungen
 - ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
 - ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.13 Lagerung physischer Assets
- ASST.3.14 Reserve physischer Assets
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten

- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Geregelte Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.5.5 Wartungsfenster
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- ASST.7.1 Nicht mehr benötigte Anwendungen
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.3 Geregeltes Löschen oder Vernichten
 - ASST.7.3.1 Standardisierte Vernichtung
 - ASST.7.3.2 Lösungsverfahren
- ASST.7.6 Autorisierung von Veräußerungen
- ASST.7.7 Beschriftungen entfernen
- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BER.1.4 Inventar der Berechtigungen
- BER.2.1 Person-Identität
- BER.2.2 Einschränkung
- BER.2.3 Stammdatenprüfung
- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.2.5 Deaktivierung bei Weggang
- BER.2.6 Löschen nach Fristablauf
- BER.3.1 Zentrales Management
 - BER.3.10 Anmeldeversuchsgrenze an der Anwendung
 - BER.3.11 Systemsperre bei Inaktivität
 - BER.3.12 Sperre der Anwendung bei Inaktivität
 - BER.3.13 Zugang löschen nach Fristablauf
 - BER.3.15 Keine Gruppenkonten
 - BER.3.16 Gruppenkonten - MFA
 - BER.3.17 Gruppenkonten - Wechsel dokumentieren
 - BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
 - BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.2 Einschränkung des Managements
 - BER.3.20 Dienstekonten

- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.3.3 Protokollierung von Änderungen
- BER.3.4 Identität-Zugangskonto
- BER.3.5 Privilegierte Zugangskonten
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.4.1 Identitätsüberprüfung
- BER.5.1 Prinzip der geringsten Berechtigungen
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.2 Begründung von Berechtigungen
- BER.5.3 Überprüfung von Berechtigungen
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- BER.5.8 Entzug von Berechtigungen
- BER.6.1 Passwortmanager
- BER.6.10 Monitoring von Zugangsdaten
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.3 Deaktivierung einfacher Biometrie
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.6.9 Anlassbezogene Passwortwechsel
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
- BER.7.10 Abgelaufene Schlüssel
- BER.7.11 Integrität
- BER.7.12 Authentizität
- BER.7.13 Gültigkeit
- BER.7.14 Schlüssel vor Ablauf prüfen
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
- BER.7.16.1 Zertifizierungsstelle
- BER.7.16.2 Beglaubigung

- BER.7.16.3 Erneuerung
- BER.7.16.4 Revocation
- BER.7.16.5 Beglaubigungsstatus
- BER.7.16.6 Revocationstatus
- BER.7.2 Schlüssellänge
- BER.7.3 Verzeichnis öffentlicher Schlüssel
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BER.7.9 Zweckbindung
- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.1.4.1 Freigabe der Strategie
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.1 Erfassung des Bedarfes
- BES.2.1.1 Verwendungszweck
- BES.2.1.3 Systemvoraussetzungen
- BES.2.1.4 Kompatibilität
- BES.2.1.4.1 Kompatibilität der Schnittstellen
- BES.2.1.4.2 Kompatibilität der Netzanbindung
- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.2 Auswahlkriterien
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.3 Beschaffung anhand der Kriterien
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.4.5 Security by Design
- BES.4.6 Security by Default

- BES.4.6.1 Authentifizierung des Kunden
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.7 ISMS beim Dienstleister
- BES.4.8 Konformitätsnachweise
- BES.4.8.2 Cloud-Konformität
- BES.5.1 Kompetenzen
- BES.5.10 Behandlung von Vorfällen
- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.11 Recht auf Audit
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.14 Löschregeln
- BES.5.2 Service Level Agreement
- BES.5.3 Compliance-Verpflichtungen
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.5 Nutzungsregelungen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.8 Rechte für geistiges Eigentum
- BES.5.9 Umgang mit Änderungen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.3 Übertragbarkeit von Daten
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.10 Serviceprofil
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration

- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.5 Netzverbindungen ab Werk
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.2.1.2 Meldeformulare
- DET.2.1.3 Rückmeldungen
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
- DET.3.1.1 Authentifizierungen
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.3.3 Speicherkapazität
- DET.3.4 Revisionssicherheit
- DET.4.1 Überwachung der Protokollierung
- DET.4.11 Anomalien in Netzen und am Perimeter
- DET.4.12 Monitoring der Netzverfügbarkeit
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.15 Ressourcenauslastung von Hostsystemen
- DET.4.2 Automatische Angriffserkennung
- DET.4.3 Überwachung der Angriffserkennung
- DET.4.4 Änderungen an Sicherheitsrichtlinien
- DET.5.1 Zeitnahes Schwachstellenmanagement
- DET.5.10 Zeitnahes Patchmanagement
- DET.5.10.1 Autorisierte Bezugsquellen
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.10.4 Integritätsprüfung von Patches
- DET.5.2 Schwachstellenregister
- DET.5.3 Schwachstellenscans
- DET.5.3.1 Autorisierung kritischer Scans
- DET.5.8 Bedrohungsanalyse

- DET.5.9 Externe Schwachstellenmeldungen
- DET.6.1 Beurteilung von Ereignissen
 - DET.6.1.1 Automatisierte Feststellung
 - DET.6.1.2 Automatische Alarmierung
- DET.6.2 Beurteilung von Eingängen
- DEV.2.1 Security by Design Architektur
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
 - DEV.2.6.1 Eingabevalidierung
 - DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.3.4 Passwort-Hashing
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.2 Bibliotheksquellen
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.6 Compileroptionen
- DEV.4.8 Default-Zugangsdaten
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.6.1 Freigabe nach Änderungen und Tests
- DEV.7.1 Sichere Bereitstellung
- DEV.7.2 Zertifikatsmonitoring
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.2.2 Transportverschlüsselung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
 - DLS.3.1.1 Audit oder Zertifikat
- DLS.3.4 Anhörung

- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- DLS.4.1 Dekommissionierung
- DLS.4.1.1 Unabhängigkeit
- DLS.4.1.2 Berechtigungen deaktivieren
- GC.6.1.1 Festlegung einer Sicherheitsstrategie
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.7.1.2 Anhörung zuständiger Stellen
- GC.7.1.3 Vertragliche Verpflichtungen
- GC.7.1.4 Prävention von Verstößen
- GC.9.1.1 Externer Austausch zur Informationssicherheit
- GEB.1.3 Autorisierung von Standorten
- GEB.1.3.1 Abnahme von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
- GEB.10.1.2 Klimamessung
- GEB.10.2 Brandschutz
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.3 Wasserschutz
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.2.1 Installation von Perimetern
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.3 Besucheranmeldung
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.5.3 Lieferzugang
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme

- GEB.6.3 Netzkomponenten
- GEB.7.1 Schlüsselbeauftragte
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.7.3 Schlüsselaudit
- GEB.8.1 Gesonderte Aufbewahrung
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- GEB.9.7 Zweckentfremdung
- KONF.1.3 Management von Werkzeugen
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.10.5 Überprüfung der Konfiguration
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.11.2 Warteraum
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.5 Erraten von Zugriffslinks
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.1 Eingabevalidierung
- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.11 Aktive Dateiinhalte
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)

- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.1.8 Duplikate im Verzeichnisbaum
- KONF.12.1.9 Journaling
- KONF.12.10 Cookie-Attribute
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- KONF.12.14 DNS-Falschinformationen
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.3 Cookies
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.12.7 Erweiterte Attribute
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.1.1 SPAM-Filter
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.2.1 Grundkonfiguration für Systeme
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.2.4.1 Nicht benötigte Zertifikate

- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
 - KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.3 SIM-PIN
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
 - KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2 DNS-Anbindung
 - KONF.4.2.1 DNS-Verschlüsselung
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.5.1 Authentifizierung am System
 - KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.12 Konferenzmoderation
- KONF.6.14 Browser Sandboxing
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.6 Getrennte Datenhaltung
 - KONF.6.6.1 Mandantenfähigkeit
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code
- KONF.7.1 Echtzeitscanner
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.15 Lokale Firewall
- KONF.7.16 Anti-Exploit
 - KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung

- KONF.7.5 Alarmierung
- KONF.7.6 Automatische Updates
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.8.2 Automatische Updates der Anwendung
- KONF.9.1 Speicherplatzbegrenzung
- NOT.2.1 Verfahren und Regelungen
- NOT.2.1.1 Rollen
- NOT.2.1.2 Alarmierung
- NOT.3.1 Wiederanlaufplan
- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen
- NOT.4.1 Dokumentation der Quellen
- NOT.4.10 Getrennte Aufbewahrung
- NOT.4.11 Datenträgerarchiv
- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.15 Vorgehen zur Wiederherstellung
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation
- NOT.4.6 Geschützte Aufbewahrung
- NOT.4.7 Versionierte Datensicherung
- NOT.4.8 Verschlüsselte Datensicherung
- NOT.4.9 Speichermedien
- PERF.1.1.1 Auswertung der Gefährdungslage
- PERF.1.1.2 Auswertung des Umsetzungsplans
- PERF.1.1.3 Auswertung von Auditergebnissen
- PERF.1.1.4 Auswertung von Sicherheitsvorfällen
- PERF.2.1 Überwachung der Einhaltung von Verpflichtungen
- PERF.3.1.1 Erstellen eines Auditsplans

- PERF.4.1.1 Einheitliches Bewertungsschema
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern
- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.3 Rollentrennung
- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.2.4 Zuständigkeiten
- PERS.3.1 Dienst- oder Arbeitsvertrag
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- PERS.3.4 Stellenbeschreibungen
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- PERS.3.7 Einarbeitung
- PERS.4.1 Qualifikationsbedarf
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- PERS.5.1 Maßregelung
- PERS.5.2 Innentäter
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- PERS.6.1.2 Neubesetzung
- REA.2.1 Triage und Erstreaktion
- REA.2.3 Dokumentation von Vorfällen
- REA.2.4 Diagnosedaten
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.6 Ursachenanalyse und Behandlung

- REA.2.6.1 Dokumentation des Vorgehens
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.2.1 Information zuständiger Behörden
- REA.2.6.3 Koordinierung
- REA.2.6.5 Eskalation
- REA.3.1 Verbesserung durch Erkenntnisse
- REA.3.1.1 Quantitative Analyse
- SENS.1.2 Erfolgsmessung
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.2.1 Schutzziele
- SENS.2.2 Meldewege
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8 Melden von Ereignissen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.2 Weitergabe von Informationen

- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.5 Löschfristen
- SENS.5.6 Papiervernichtung
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.12 Öffentliche WLANs
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.15 Social Engineering Anrufe
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.2 Virensan
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.25 Zugang zum Fahrzeug
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links
- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.7.9 Aktive Inhalte
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.5 Verwahrung Intern
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.3 Verwahrung außer Haus
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit

- SENS.9.7 Reise- und Sicherheitshinweise
- TEST.1.3 Einschränkung von Änderungen
- TEST.2.1 Versionshistorie
- TEST.2.2 Folgenabschätzung
- TEST.2.2.1 Kategorisierung von Änderungen
- TEST.2.2.2 Anpassung der Dokumentation
- TEST.2.2.3 Dokumentation der Abhängigkeiten
- TEST.3.1 Sicherheitstest
- TEST.3.1.1 Dokumentation von Testergebnissen
- TEST.3.1.2 Integritätstest
- TEST.3.1.3 Testdaten
- TEST.3.1.4 Testumgebung
- TEST.3.2 Testabdeckung
- TEST.4.1 Autorisierung von Änderungen
- TEST.4.1.1.1 Staging
- TEST.4.1.2 Dokumentation der Freigabe
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen
- TEST.5.1 Information betroffener Kreise
- TEST.5.2 Verschlüsselte Bereitstellung
- TEST.5.4 Persistenz
- TEST.5.5 Rückblick
- UMS.2.1 Bewertung des Restrisikos
- VRB.2.2 Anpassung des ISMS
- VRB.3.1 Identifikation von Verbesserungspotenzialen
- VRB.7.1 Bewertung der erreichten Verbesserung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
- ARCH.2.2.1 Externe Netzanschlüsse
- ARCH.2.2.10 Drucker-Netz
- ARCH.2.2.2 Gastnetz
- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.6 Demilitarisierte Zone

- ARCH.2.2.7 Management-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.4 Inventar der Netze
- ARCH.2.5 Netzplan
- ARCH.2.6 Topologieüberwachung
- ARCH.3.1 Netzabdeckung
- ARCH.3.3 SSIDs
- ARCH.3.4 Verschlüsselte Netzanbindung
- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.7.3 Entwicklungs- und Testumgebungen
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.9.1 Dimensionierung der Netzanbindung
- ASST.2.1 Inventar der Informationen
- ASST.2.1.1 Informationsverantwortung
- ASST.2.2 Inventar der Systeme
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme

- ASST.2.3 Inventar der Anwendungen
 - ASST.2.3.1 Autorisierung von Anwendungen
 - ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.2.4 Klassifizierung
- ASST.3.1 Nutzungsvereinbarungen
 - ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
 - ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.13 Lagerung physischer Assets
- ASST.3.14 Reserve physischer Assets
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.3 Kennzeichnung
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.3 Autorisierung von Veröffentlichungen
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Geregelter Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.5.5 Wartungsfenster
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- ASST.7.1 Nicht mehr benötigte Anwendungen
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.3 Geregelter Löschen oder Vernichten
 - ASST.7.3.1 Standardisierte Vernichtung
 - ASST.7.3.2 Lösungsverfahren
- ASST.7.6 Autorisierung von Veräußerungen
- ASST.7.7 Beschriftungen entfernen
- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BER.1.4 Inventar der Berechtigungen
- BER.2.1 Person-Identität
- BER.2.2 Einschränkung
- BER.2.3 Stammdatenprüfung

- BER.2.4 Protokollierung von Stammdatenänderungen
- BER.2.5 Deaktivierung bei Weggang
- BER.2.6 Löschen nach Fristablauf
- BER.3.1 Zentrales Management
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.15 Keine Gruppenkonten
- BER.3.16 Gruppenkonten - MFA
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.2 Einschränkung des Managements
- BER.3.20 Dienstkonten
- BER.3.22 Notfallzugang Verzeichnisdienst
- BER.3.3 Protokollierung von Änderungen
- BER.3.4 Identität-Zugangskonto
- BER.3.5 Privilegierte Zugangskonten
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.4.1 Identitätsüberprüfung
- BER.5.1 Prinzip der geringsten Berechtigungen
- BER.5.1.1 Rollenbasierte Berechtigung
- BER.5.2 Begründung von Berechtigungen
- BER.5.3 Überprüfung von Berechtigungen
- BER.5.3.1 Überprüfung tatsächlicher Berechtigungen
- BER.5.4 Kompromittierte Berechtigungsmittel
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- BER.5.8 Entzug von Berechtigungen
- BER.6.1 Passwortmanager
- BER.6.10 Monitoring von Zugangsdaten
- BER.6.2 Vorkonfigurierte Authentisierungsmittel
- BER.6.3 Deaktivierung einfacher Biometrie
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter

- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- BER.6.8 Kriterien für die Qualität von Passwörtern
- BER.6.9 Anlassbezogene Passwortwechsel
- BER.7.1 Etablierte Algorithmen bei der Schlüsselerzeugung
- BER.7.10 Abgelaufene Schlüssel
- BER.7.11 Integrität
- BER.7.12 Authentizität
- BER.7.13 Gültigkeit
- BER.7.14 Schlüssel vor Ablauf prüfen
- BER.7.15 Vorgehensweise nach Nutzung
- BER.7.16 Vorgaben für die Schlüsselbeglaubigung
 - BER.7.16.1 Zertifizierungsstelle
 - BER.7.16.2 Beglaubigung
 - BER.7.16.3 Erneuerung
 - BER.7.16.4 Revocation
 - BER.7.16.5 Beglaubigungsstatus
 - BER.7.16.6 Revocationstatus
- BER.7.2 Schlüssellänge
- BER.7.3 Verzeichnis öffentlicher Schlüssel
- BER.7.4 Erzeugung auf sicheren IT-Systemen
- BER.7.5 Kriterien für die Qualität von Zufallszahlen
- BER.7.6 Etablierte Algorithmen beim Transport
- BER.7.8 Etablierte Algorithmen bei der Schlüsselnutzung
- BER.7.9 Zweckbindung
- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
 - BES.1.4.1 Freigabe der Strategie
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.1 Erfassung des Bedarfes
 - BES.2.1.1 Verwendungszweck
 - BES.2.1.3 Systemvoraussetzungen
 - BES.2.1.4 Kompatibilität
 - BES.2.1.4.1 Kompatibilität der Schnittstellen
 - BES.2.1.4.2 Kompatibilität der Netzanbindung
 - BES.2.1.4.3 Kompatibilität des Administrationsmodells

- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.2 Auswahlkriterien
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.3 Beschaffung anhand der Kriterien
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.4.5 Security by Design
- BES.4.6 Security by Default
- BES.4.6.1 Authentifizierung des Kunden
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.7 ISMS beim Dienstleister
- BES.4.8 Konformitätsnachweise
- BES.4.8.2 Cloud-Konformität
- BES.5.1 Kompetenzen
- BES.5.10 Behandlung von Vorfällen
- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.11 Recht auf Audit
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.14 Löschregeln
- BES.5.2 Service Level Agreement
- BES.5.3 Compliance-Verpflichtungen
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.5 Nutzungsregelungen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.8 Rechte für geistiges Eigentum
- BES.5.9 Umgang mit Änderungen

- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.3 Übertragbarkeit von Daten
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.7.1 Eingangskontrolle
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.10 Serviceprofil
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4 Dokumentation der Komponenten
- BES.7.4.5 Netzverbindungen ab Werk
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.7.4.9 Auslagerungsregister
- DET.2.1 Meldeverfahren
- DET.2.1.1 Sofortmaßnahmen Nutzender
- DET.2.1.2 Meldeformulare
- DET.2.1.3 Rückmeldungen
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
- DET.3.1.1 Authentifizierungen
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.3.3 Speicherkapazität
- DET.3.4 Revisionssicherheit
- DET.4.1 Überwachung der Protokollierung
- DET.4.11 Anomalien in Netzen und am Perimeter
- DET.4.12 Monitoring der Netzverfügbarkeit

- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.15 Ressourcenauslastung von Hostsystemen
- DET.4.2 Automatische Angriffserkennung
- DET.4.3 Überwachung der Angriffserkennung
- DET.4.4 Änderungen an Sicherheitsrichtlinien
- DET.5.1 Zeitnahes Schwachstellenmanagement
- DET.5.10 Zeitnahes Patchmanagement
- DET.5.10.1 Autorisierte Bezugsquellen
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.10.4 Integritätsprüfung von Patches
- DET.5.2 Schwachstellenregister
- DET.5.3 Schwachstellenscans
- DET.5.3.1 Autorisierung kritischer Scans
- DET.5.8 Bedrohungsanalyse
- DET.5.9 Externe Schwachstellenmeldungen
- DET.6.1 Beurteilung von Ereignissen
- DET.6.1.1 Automatisierte Feststellung
- DET.6.1.2 Automatische Alarmierung
- DET.6.2 Beurteilung von Eingängen
- DEV.2.1 Security by Design Architektur
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- DEV.2.6.1 Eingabevalidierung
- DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.3.4 Passwort-Hashing
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.2 Bibliotheksquellen
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.4 Integrität externer Softwarebibliotheken

- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.6 Compileroptionen
- DEV.4.8 Default-Zugangsdaten
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.6.1 Freigabe nach Änderungen und Tests
- DEV.7.1 Sichere Bereitstellung
- DEV.7.2 Zertifikatsmonitoring
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.2.2 Transportverschlüsselung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.4 Anhörung
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- DLS.4.1 Dekommissionierung
- DLS.4.1.1 Unabhängigkeit
- DLS.4.1.2 Berechtigungen deaktivieren
- GEB.1.3 Autorisierung von Standorten
- GEB.1.3.1 Abnahme von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
- GEB.10.1.2 Klimamessung
- GEB.10.2 Brandschutz
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.3 Wasserschutz
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.2.1 Installation von Perimetern
- GEB.2.2 Dokumentation öffentlicher Bereiche
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.2 Anmelde- und Empfangsbereiche

- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.3 Besucheranmeldung
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock
- GEB.5.3 Lieferzugang
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.6.2 Geschützte Aufstellung
- GEB.6.2.1 Hostsysteme
- GEB.6.3 Netzkomponenten
- GEB.7.1 Schlüsselbeauftragte
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.7.3 Schlüsselaudit
- GEB.8.1 Gesonderte Aufbewahrung
- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- GEB.9.7 Zweckentfremdung
- KONF.1.3 Management von Werkzeugen
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.1.5 Verschlüsselung von Konfigurationsgeheimnissen
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.10.5 Überprüfung der Konfiguration
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.11.2 Warteraum
- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.5 Erraten von Zugriffslinks
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.11.8.2 Einschränkung von TK-Verbindungen

- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.1 Eingabevalidierung
 - KONF.12.1.1 Zertifikatsprüfung
 - KONF.12.1.10 HTTP-Response-Header
 - KONF.12.1.11 Aktive Dateiinhalte
 - KONF.12.1.2 Content Security Policy (CSP)
 - KONF.12.1.3 Same-Origin-Policy
 - KONF.12.1.4 Subresource Integrity-Prüfung
 - KONF.12.1.5 HTTP Strict Transport Security (HSTS)
 - KONF.12.1.7 Filtern schädlicher Webinhalte
 - KONF.12.1.8 Duplikate im Verzeichnisbaum
 - KONF.12.1.9 Journaling
- KONF.12.10 Cookie-Attribute
- KONF.12.12 Verbindungsprotokoll
- KONF.12.13 Sendebericht
- KONF.12.14 DNS-Falschinformationen
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.3 Cookies
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.12.7 Erweiterte Attribute
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.13.1 Filtern schädlicher Nachrichten
 - KONF.13.1.1 SPAM-Filter
 - KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2 Authentizität von Nachrichten
 - KONF.13.2.1 Verifikation der Sendeberechtigung
 - KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.5 Publikation der Sendeberechtigung
 - KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.9 Publikation der DMARC-Richtlinie
- KONF.14.1 Verschlüsselung beim Transport
 - KONF.14.1.1 Obligatorische Verschlüsselung

- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.2.1 Grundkonfiguration für Systeme
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.3 SIM-PIN
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2 DNS-Anbindung
- KONF.4.2.1 DNS-Verschlüsselung
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.12 Konferenzmoderation
- KONF.6.14 Browser Sandboxing
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.6 Getrennte Datenhaltung
- KONF.6.6.1 Mandantenfähigkeit
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.6.8 Berechtigungen des Webserver-Prozesses

- KONF.6.9 Zugriff auf Code
- KONF.7.1 Echtzeitscanner
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.15 Lokale Firewall
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.5 Alarmierung
- KONF.7.6 Automatische Updates
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.8.2 Automatische Updates der Anwendung
- KONF.9.1 Speicherplatzbegrenzung
- NOT.2.1 Verfahren und Regelungen
- NOT.2.1.1 Rollen
- NOT.2.1.2 Alarmierung
- NOT.3.1 Wiederanlaufplan
- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- NOT.3.5 Ausweich-Telekommunikation
- NOT.3.6 Sicherheitsmechanismen
- NOT.4.1 Dokumentation der Quellen
- NOT.4.10 Getrennte Aufbewahrung
- NOT.4.11 Datenträgerarchiv
- NOT.4.13 Datensouveränität
- NOT.4.14 Offline-Kopie
- NOT.4.15 Vorgehen zur Wiederherstellung
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.2 Sicherung des Systems
- NOT.4.3 Sicherung der Anwendung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation
- NOT.4.6 Geschützte Aufbewahrung

- NOT.4.7 Versionierte Datensicherung
- NOT.4.8 Verschlüsselte Datensicherung
- NOT.4.9 Speichermedien
- PERS.2.1 Aufgaben
- PERS.2.2 Rollen
- PERS.2.3 Rollentrennung
- PERS.2.3.1 Rollentrennung - Verzeichnisdienst
- PERS.2.3.2 Rollentrennung - Virtualisierung
- PERS.2.3.3 Rollentrennung - Audits
- PERS.2.3.4 Rollentrennung - Änderungen und Tests
- PERS.2.4 Zuständigkeiten
- PERS.3.1 Dienst- oder Arbeitsvertrag
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- PERS.3.4 Stellenbeschreibungen
- PERS.3.5 Prüfung der Bewerbungsunterlagen
- PERS.3.6 Vertrauenswürdigkeit von Bewerbenden
- PERS.3.7 Einarbeitung
- PERS.4.1 Qualifikationsbedarf
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- PERS.5.1 Maßregelung
- PERS.5.2 Innentäter
- PERS.5.3 Vertrauens-Check sicherheitskritischer Rollen
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- PERS.6.1.2 Neubesetzung
- REA.2.1 Triage und Erstreaktion
- REA.2.3 Dokumentation von Vorfällen
- REA.2.4 Diagnosedaten
- REA.2.5.1 Rechtssichere Beweissicherung
- REA.2.6 Ursachenanalyse und Behandlung
- REA.2.6.1 Dokumentation des Vorgehens
- REA.2.6.2 Kommunikation bei Vorfällen
- REA.2.6.2.1 Information zuständiger Behörden
- REA.2.6.3 Koordinierung
- REA.2.6.5 Eskalation
- REA.3.1 Verbesserung durch Erkenntnisse

- REA.3.1.1 Quantitative Analyse
- SENS.1.2 Erfolgsmessung
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.4 Systemadministration - Strukturierte Verkabelung
- SENS.10.5 Systemadministration - Internetnutzung
- SENS.11.1 Sensibilisierung der Institutionsleitung
- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling
- SENS.2.1 Schutzziele
- SENS.2.2 Meldewege
- SENS.2.3 Verschlüsselung und Signatur
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8 Melden von Ereignissen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.2 Weitergabe von Informationen
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.5 Löschfristen
- SENS.5.6 Papiervernichtung
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.1 Spezifische Sensibilisierung

- SENS.7.10 Trennen nicht benötigter Anschlüsse
- SENS.7.11 Heimliche Aufzeichnung
- SENS.7.12 Öffentliche WLANs
- SENS.7.13 Unverschlüsselte WLANs
- SENS.7.15 Social Engineering Anrufe
- SENS.7.16 Mailbox-PIN und Co.
- SENS.7.17 Unverschlüsseltes Telefonieren
- SENS.7.2 Virensan
- SENS.7.20 Authentifizierung von Gesprächspartnern
- SENS.7.21 Rechtsunsicherheit von Faxen
- SENS.7.22 Unverschlüsselte Faxleitungen
- SENS.7.23 Geolokation
- SENS.7.24 Zertifikatswarnungen
- SENS.7.25 Zugang zum Fahrzeug
- SENS.7.3 Automatische Antworten
- SENS.7.4 SPAM - Löschen oder Melden
- SENS.7.5 SPAM - Nichtbeantwortung
- SENS.7.6 SPAM - Links
- SENS.7.7 SPAM - Anhänge
- SENS.7.8 Gefälschte E-Mails
- SENS.7.9 Aktive Inhalte
- SENS.8.1 Risiken der Nutzung von mobilen Endgeräten
- SENS.8.2 Schließen von Türen und Fenstern
- SENS.8.4.1 Beaufsichtigung Externer
- SENS.8.5 Verwahrung Intern
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.8.7 Verwendung von Brandschuttmitteln
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.3 Verwahrung außer Haus
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.7 Reise- und Sicherheitshinweise
- TEST.1.3 Einschränkung von Änderungen
- TEST.2.1 Versionshistorie
- TEST.2.2 Folgenabschätzung
- TEST.2.2.1 Kategorisierung von Änderungen
- TEST.2.2.2 Anpassung der Dokumentation

- TEST.2.2.3 Dokumentation der Abhängigkeiten
- TEST.3.1 Sicherheitstest
 - TEST.3.1.1 Dokumentation von Testergebnissen
 - TEST.3.1.2 Integritätstest
 - TEST.3.1.3 Testdaten
 - TEST.3.1.4 Testumgebung
- TEST.3.2 Testabdeckung
- TEST.4.1 Autorisierung von Änderungen
 - TEST.4.1.1.1 Staging
- TEST.4.1.2 Dokumentation der Freigabe
- TEST.4.3 Rückfalllösung
- TEST.4.4 Geregelte Notfalländerungen
- TEST.5.1 Information betroffener Kreise
- TEST.5.2 Verschlüsselte Bereitstellung
- TEST.5.4 Persistenz
- TEST.5.5 Rückblick

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.6.1.1 Festlegung einer Sicherheitsstrategie
- GC.7.1.1 Gesetzliche Verpflichtungen
- GC.7.1.2 Anhörung zuständiger Stellen
- GC.7.1.3 Vertragliche Verpflichtungen
- GC.7.1.4 Prävention von Verstößen
- GC.9.1.1 Externer Austausch zur Informationssicherheit
- PERF.1.1.1 Auswertung der Gefährdungslage
- PERF.1.1.2 Auswertung des Umsetzungsplans
- PERF.1.1.3 Auswertung von Auditergebnissen
- PERF.1.1.4 Auswertung von Sicherheitsvorfällen
- PERF.2.1 Überwachung der Einhaltung von Verpflichtungen
- PERF.3.1.1 Erstellen eines Auditsplans
- PERF.4.1.1 Einheitliches Bewertungsschema
- PERF.5.1.1 Ergebnisse von Folgemaßnahmen
- PERF.5.1.2 Geänderte Rahmenbedingungen
- PERF.5.1.3 Erfolge und Probleme
- PERF.5.1.4 Interne Überprüfungen und Audits
- PERF.5.1.5 Eignungsprüfung bisheriger Sicherheitsmaßnahmen
- PERF.5.1.6 Rückmeldung von Stakeholdern

- PERF.5.1.7 Status des Realisierungsplans
- PERF.5.1.8 Verbesserungen
- UMS.2.1 Bewertung des Restrisikos
- VRB.2.2 Anpassung des ISMS
- VRB.3.1 Identifikation von Verbesserungspotenzialen
- VRB.7.1 Bewertung der erreichten Verbesserung
- VRB.8.1 Behandlung von Compliance-Verstößen

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.9 Bestätigung des Restrisikos

Namespace: practices

Eintrag: Änderungen und Tests

nicht unterstützt

Eintrag: Architektur

nicht unterstützt

Eintrag: Berechtigung

nicht unterstützt

Eintrag: Beschaffungsmanagement

nicht unterstützt

Eintrag: Detektion

nicht unterstützt

Eintrag: Dienstleistersteuerung

nicht unterstützt

Eintrag: Entwicklung

nicht unterstützt

Eintrag: Gebäudemanagement

nicht unterstützt

Eintrag: Governance und Compliance

nicht unterstützt

Eintrag: Informationen und Assets

nicht unterstützt

Eintrag: Konfiguration

nicht unterstützt

Eintrag: Monitoring-Evaluation

nicht unterstützt

Eintrag: Notfallplanung

nicht unterstützt

Eintrag: Personal

nicht unterstützt

Eintrag: Risikomanagement

nicht unterstützt

Eintrag: Sensibilisierung

nicht unterstützt

Eintrag: Sicherheitsvorfallsbehandlung

nicht unterstützt

Eintrag: Strukturmodellierung

nicht unterstützt

Eintrag: Umsetzung

nicht unterstützt

Eintrag: Verbesserung

nicht unterstützt

Namespace: result

Eintrag: Alarmierung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DET.6.1.2 Automatische Alarmierung
- NOT.2.1.2 Alarmierung

BSI/Grundschutz/Quellkataloge/Kernel

- DET.6.1.2 Automatische Alarmierung
- NOT.2.1.2 Alarmierung

Eintrag: Anforderung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.6.3 Konformitätsprüfung
- GC.8.1.5 Sicherstellung der Qualifikation
- PERF.7.1 Aktualität der Anforderungen
- PERS.2.3.3 Rollentrennung - Audits
- STM.2.1 Erstellung eines Anforderungspakets
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- TEST.3.1 Sicherheitstest
- UMS.2.1 Bewertung des Restrisikos
- UMS.3.1 Umsetzungsplanung
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.6.3 Konformitätsprüfung
- PERS.2.3.3 Rollentrennung - Audits
- TEST.3.1 Sicherheitstest

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.8.1.5 Sicherstellung der Qualifikation
- PERF.7.1 Aktualität der Anforderungen
- STM.2.1 Erstellung eines Anforderungspakets
- STM.5.4 Modellierung der Anforderungen ohne Zielobjektkategorie
- STM.6.1 Auf Grund anforderungsloser Assets
- STM.9.1 Verteilung der führenden Zuständigkeiten
- STM.9.2 Weitere Parameter
- UMS.2.1 Bewertung des Restrisikos
- UMS.3.1 Umsetzungsplanung
- UMS.4.1 Benennung von Umsetzungszuständigen
- UMS.4.2 Festlegung von Umsetzungsfristen

Eintrag: Asset

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.1.1 Verfahren und Regelungen
- ASST.2.1 Inventar der Informationen
- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.13 Lagerung physischer Assets
- ASST.3.14 Reserve physischer Assets
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.7.6 Autorisierung von Veräußerungen
- BES.5.5 Nutzungsregelungen
- BES.6.6 Rückgewähr von Assets
- GEB.1.3 Autorisierung von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- NOT.4.5.1 Zum Archiv gehörende Assets
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.8.6 Rückgabe nicht mehr benötigter Assets

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.1.1 Verfahren und Regelungen
- ASST.2.1 Inventar der Informationen
- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.13 Lagerung physischer Assets
- ASST.3.14 Reserve physischer Assets
- ASST.6.1 Abhandenkommen
- ASST.6.2 Rückkehr abhandengekommener Assets
- ASST.7.6 Autorisierung von Veräußerungen
- BES.5.5 Nutzungsregelungen
- BES.6.6 Rückgewähr von Assets
- GEB.1.3 Autorisierung von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- NOT.4.5.1 Zum Archiv gehörende Assets

- SENS.2.4 Nutzung unautorisierter Assets
- SENS.8.6 Rückgabe nicht mehr benötigter Assets

Eintrag: Authentizität

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.7.12 Authentizität
- KONF.13.2 Authentizität von Nachrichten

BSI/Grundschutz/Quellkataloge/Kernel

- BER.7.12 Authentizität
- KONF.13.2 Authentizität von Nachrichten

Eintrag: Autorisierung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.9.1 Autorisierung von Änderungen

BSI/Grundschutz/Quellkataloge/Kernel

- BER.1.3 Inventar Authentifizierungs- und Autorisierungssysteme
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.9.1 Autorisierung von Änderungen

Eintrag: Biometrie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.6.3 Deaktivierung einfacher Biometrie

BSI/Grundschutz/Quellkataloge/Kernel

- BER.6.3 Deaktivierung einfacher Biometrie

Eintrag: Elementare Gefährdungen

Keine Controls gefunden.

Eintrag: Gefährdung (englisch "applied threat")

Keine Controls gefunden.

Eintrag: Geschäftsprozess

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.2.1.2 Geschäftsprozessprofile
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs
- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf
- NOT.3.2 Geschäftsfortführungsplan
- SENS.11.1 Sensibilisierung der Institutionsleitung

BSI/Grundschutz/Quellkataloge/Kernel

- BES.2.1.2 Geschäftsprozessprofile
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- NOT.3.2 Geschäftsfortführungsplan
- SENS.11.1 Sensibilisierung der Institutionsleitung

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.5.1 Vorgehen bei der Informationssicherheitseinstufung
- GC.5.1.1 Festlegung der Geschäftsprozesse
- GC.5.1.2 Festlegung des Schutzbedarfs

- GC.5.1.3 Geschäftsprozesse mit hohem Schutzbedarf

BSI/Grundschutz/Quellkataloge/Risikomanagement

- RISK.1.6 Kritikalitätskriterien für Geschäftsprozesse

Eintrag: Institutionen

Keine Controls gefunden.

Eintrag: Integrität

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.7.11 Integrität
- DET.5.10.4 Integritätsprüfung von Patches
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.5.3 Integritätsprüfung
- TEST.3.1.2 Integritätstest

BSI/Grundschutz/Quellkataloge/Kernel

- BER.7.11 Integrität
- DET.5.10.4 Integritätsprüfung von Patches
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.5.3 Integritätsprüfung
- TEST.3.1.2 Integritätstest

Eintrag: Kompetenz

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.5.1 Kompetenzen

BSI/Grundschutz/Quellkataloge/Kernel

- BES.5.1 Kompetenzen

Eintrag: Korrekturmaßnahme

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- VRB.4.1 Korrekturmaßnahmen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- VRB.4.1 Korrekturmaßnahmen

Eintrag: Maßnahme / Schutzmaßnahme

Keine Controls gefunden.

Eintrag: Praktik

Keine Controls gefunden.

Eintrag: Redundanz

Keine Controls gefunden.

Eintrag: Schwachstelle (englisch "vulnerability")

Keine Controls gefunden.

Eintrag: Sicherheitskritisches Ereignis

Keine Controls gefunden.

Eintrag: Sicherheitsrelevantes Ereignis

Keine Controls gefunden.

Eintrag: Sicherheitsvorfall

Keine Controls gefunden.

Eintrag: Verfügbarkeit

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.5.5 Wartungsfenster
- DET.4.12 Monitoring der Netzverfügbarkeit

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.5.5 Wartungsfenster
- DET.4.12 Monitoring der Netzverfügbarkeit

Eintrag: Vertraulichkeit

Keine Controls gefunden.

Eintrag: Zielobjekt

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DLS.3.4 Anhörung
- SENS.7.1 Spezifische Sensibilisierung

BSI/Grundschutz/Quellkataloge/Kernel

- DLS.3.4 Anhörung
- SENS.7.1 Spezifische Sensibilisierung

Eintrag: Zielobjektkategorie

Keine Controls gefunden.

Eintrag: Zugang

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.2.11 Physische Segmentierung
- ASST.4.4 Nachweis des Zugangs
- BER.3.1 Zentrales Management

- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.2 Einschränkung des Managements
- BER.3.20 Dienstkonten
- BER.3.21 Notfallzugang
- BER.3.3 Protokollierung von Änderungen
- BER.3.5 Privilegierte Zugangskonten
- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.6.10 Monitoring von Zugangsdaten
- BES.6.1 Entziehung der Zugangsberechtigungen
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DEV.4.8 Default-Zugangsdaten
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.5.2 Keine Mehrfachanmeldung
- SENS.4.1.1 Verdeckte Eingabe
- SENS.7.25 Zugang zum Fahrzeug

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.2.11 Physische Segmentierung
- ASST.4.4 Nachweis des Zugangs
- BER.3.1 Zentrales Management
- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.18 Gruppenkonten - Passwortwechsel bei Weggang
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.2 Einschränkung des Managements
- BER.3.20 Dienstkonten
- BER.3.21 Notfallzugang
- BER.3.3 Protokollierung von Änderungen
- BER.3.5 Privilegierte Zugangskonten

- BER.3.8 Ereignisgesteuerte Deaktivierung
- BER.6.10 Monitoring von Zugangsdaten
- BES.6.1 Entziehung der Zugangsberechtigungen
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- DEV.4.8 Default-Zugangsdaten
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.5.2 Keine Mehrfachanmeldung
- SENS.4.1.1 Verdeckte Eingabe
- SENS.7.25 Zugang zum Fahrzeug

Eintrag: Zugangskonto

Keine Controls gefunden.

Eintrag: Zugriff

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.5.1.10 Webfilterung
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.5.1.2 JIT--JEA-Berechtigungen
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- GEB.6.2 Geschützte Aufstellung
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.5 Erraten von Zugriffslinks
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware

- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.6.9 Zugriff auf Code
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- SENS.10.5 Systemadministration - Internetnutzung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.5.1.10 Webfilterung
- BER.3.17 Gruppenkonten - Wechsel dokumentieren
- BER.5.1.2 JIT--JEA-Berechtigungen
- DEV.2.4 Einschränkung Zugriffs auf Quellcode
- GEB.6.2 Geschützte Aufstellung
- KONF.1.4 Einschränkung des Zugriffs auf Dokumentation
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.5 Erraten von Zugriffslinks
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.6.9 Zugriff auf Code
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- SENS.10.5 Systemadministration - Internetnutzung

Eintrag: Zutritt

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.1.1 Videoüberwachung
- GEB.3.3 Authentifizierung vor Zutritt

- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.4.2 Gesonderte Autorisierung

BSI/Grundschutz/Quellkataloge/Kernel

- GEB.3.1 Überwachung von Zutrittspunkten
- GEB.3.1.1 Videoüberwachung
- GEB.3.3 Authentifizierung vor Zutritt
- GEB.3.3.1 Zugangskontrollanlage
- GEB.3.3.2 Dokumentation von Zutritten
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.4.2 Gesonderte Autorisierung

Namespace: security_level

Eintrag: erhöht

nicht unterstützt

Eintrag: normal-SdT

nicht unterstützt

Namespace: tags

Eintrag: Advanced Persistent Threat (APT)

Keine Controls gefunden.

Eintrag: Advanced Persistent Threats (APT)

Keine Controls gefunden.

Eintrag: Archivierung

Keine Controls gefunden.

Eintrag: Auslandsreisen

Keine Controls gefunden.

Eintrag: Authentication and Authorization

Keine Controls gefunden.

Eintrag: Automatic Session Locking

Keine Controls gefunden.

Eintrag: Automatische Sicherheitsrichtlinie

Keine Controls gefunden.

Eintrag: BCM

Keine Controls gefunden.

Eintrag: Bring Your Own Device

Keine Controls gefunden.

Eintrag: Brute Force Angriffe

Keine Controls gefunden.

Eintrag: Brute-Force-Attacke

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter

- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- KONF.11.5 Erraten von Zugriffslinks

BSI/Grundschutz/Quellkataloge/Kernel

- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.13 Zugang löschen nach Fristablauf
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.6.4 Mehr-Faktor-Authentisierung am Perimeter
- BER.6.5 Mehr-Faktor-Authentisierung für weitreichende Berechtigungen
- KONF.11.5 Erraten von Zugriffslinks

Eintrag: Change Management

Keine Controls gefunden.

Eintrag: Command & Control

Keine Controls gefunden.

Eintrag: Compliance Management

Keine Controls gefunden.

Eintrag: Compliance-Management

Keine Controls gefunden.

Eintrag: Credential Stuffing

Keine Controls gefunden.

Eintrag: Cryptography

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.6.8 Kriterien für die Qualität von Passwörtern
- DEV.3.4 Passwort-Hashing
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.4.2.1 DNS-Verschlüsselung

BSI/Grundschutz/Quellkataloge/Kernel

- BER.6.8 Kriterien für die Qualität von Passwörtern
- DEV.3.4 Passwort-Hashing
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.4.2.1 DNS-Verschlüsselung

Eintrag: Data Exfiltration

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DET.4.11 Anomalien in Netzen und am Perimeter

BSI/Grundschutz/Quellkataloge/Kernel

- DET.4.11 Anomalien in Netzen und am Perimeter

Eintrag: Data Leak

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.6.10 Auflistung von Verzeichnisinhalten

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.6.10 Auflistung von Verzeichnisinhalten

Eintrag: DDoS

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe

Eintrag: Defense-in-depth

Keine Controls gefunden.

Eintrag: Denial of Service

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.15.1 Begrenzung des Speicherplatzes
- KONF.15.2 Begrenzung der Rechenleistung
- KONF.15.3 Denial of Service

Eintrag: Error Handling

Keine Controls gefunden.

Eintrag: Exit-Strategie

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.2.1 Löschverfahren
- BES.6.3 Übertragbarkeit von Daten
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- DLS.3.6 Portabilität
- DLS.4.1 Dekommissionierung
- DLS.4.1.1 Unabhängigkeit
- DLS.4.1.2 Berechtigungen deaktivieren

BSI/Grundschutz/Quellkataloge/Kernel

- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.2.1 Löschverfahren
- BES.6.3 Übertragbarkeit von Daten
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.8.1 Bereithaltung alternativer Lieferanten
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen

- BES.8.3 Ressourcensouveränität
- DLS.3.5 Blockierung unzuverlässiger Dienstleister
- DLS.3.6 Portabilität
- DLS.4.1 Dekommissionierung
- DLS.4.1.1 Unabhängigkeit
- DLS.4.1.2 Berechtigungen deaktivieren

Eintrag: Failover

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.3 Redundante Server

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.8.1 Redundanz im Kernnetz
- ARCH.8.3 Redundante Server

Eintrag: Führungsverantwortung

Keine Controls gefunden.

Eintrag: Hochverfügbarkeit

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.15.4 Überbuchung von virtualisierten Ressourcen

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.15.4 Überbuchung von virtualisierten Ressourcen

Eintrag: Honeypot

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DET.4.10 Host-basierte Köder
- DET.4.11.2 Netzwerk-Honeypots

BSI/Grundschutz/Quellkataloge/Kernel

- DET.4.10 Host-basierte Köder
- DET.4.11.2 Netzwerk-Honeypots

Eintrag: Insider Threat

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme

BSI/Grundschutz/Quellkataloge/Kernel

- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme

Eintrag: Inspektion

Keine Controls gefunden.

Eintrag: Internet Exposure

Keine Controls gefunden.

Eintrag: Inventories

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GC.7.1.1 Gesetzliche Verpflichtungen

BSI/Grundschutz/Quellkataloge/Methodik-Grundschutz++

- GC.7.1.1 Gesetzliche Verpflichtungen

Eintrag: Kompetenzmanagement

BSI/Grundschrift/Anwenderkatalog/Grundschrift++

- BES.5.1 Kompetenzen
- BES.5.7 Schulung
- PERS.6.1 Vorgehensweise für den Weggang

BSI/Grundschrift/Quellkataloge/Kernel

- BES.5.1 Kompetenzen
- BES.5.7 Schulung
- PERS.6.1 Vorgehensweise für den Weggang

Eintrag: Kontakt mit Behörden

Keine Controls gefunden.

Eintrag: Langzeitarchivierung

Keine Controls gefunden.

Eintrag: Lateral Movement

BSI/Grundschrift/Anwenderkatalog/Grundschrift++

- ARCH.2.3 Mikrosegmentierung
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung

BSI/Grundschrift/Quellkataloge/Kernel

- ARCH.2.3 Mikrosegmentierung
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung

Eintrag: Lieferketten

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.4.3 Softwarebestandteile (SBOM)
- KONF.7.11 Einschränkung von Softwarebibliotheken

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.4.3 Softwarebestandteile (SBOM)
- KONF.7.11 Einschränkung von Softwarebibliotheken

Eintrag: Living off the land

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.7.10 Einschränkung der Ausführung

BSI/Grundschutz/Quellkataloge/Kernel

- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.7.10 Einschränkung der Ausführung

Eintrag: MFA

Keine Controls gefunden.

Eintrag: Network Access Control

Keine Controls gefunden.

Eintrag: Password Policy

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.6.10 Monitoring von Zugangsdaten

- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel

BSI/Grundschutz/Quellkataloge/Kernel

- BER.6.10 Monitoring von Zugangsdaten
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel

Eintrag: Pentest

Keine Controls gefunden.

Eintrag: Phishing

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.12.1.1 Zertifikatsprüfung
- KONF.13.1 Filtern schädlicher Nachrichten

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.12.1.1 Zertifikatsprüfung
- KONF.13.1 Filtern schädlicher Nachrichten

Eintrag: Physical Access Control

Keine Controls gefunden.

Eintrag: Privilege Escalation

Keine Controls gefunden.

Eintrag: Privilegierte Rechte

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.3.21 Notfallzugang
- BER.3.5 Privilegierte Zugangskonten
- BER.5.1 Prinzip der geringsten Berechtigungen
- SENS.10.5 Systemadministration - Internetnutzung

BSI/Grundschutz/Quellkataloge/Kernel

- BER.3.21 Notfallzugang
- BER.3.5 Privilegierte Zugangskonten
- BER.5.1 Prinzip der geringsten Berechtigungen
- SENS.10.5 Systemadministration - Internetnutzung

Eintrag: Produktbeschreibung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.2.6.1 Eingabevalidierung
- DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- KONF.2.8 Abgesicherter und authentisierter Bootprozess

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.2.6.1 Eingabevalidierung
- DEV.2.6.2 Ausgabekodierung
- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- KONF.2.8 Abgesicherter und authentisierter Bootprozess

Eintrag: PSTN

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.8.2 Redundante TK-Anbindung
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.8.2 Redundante TK-Anbindung
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen

Eintrag: Recon

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.11.4 Veröffentlichung von Domain-Informationen

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.11.4 Veröffentlichung von Domain-Informationen

Eintrag: Replay Attacks

Keine Controls gefunden.

Eintrag: Rogue Access Point

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.4.1 Netzzugangskontrolle

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.4.1 Netzzugangskontrolle

Eintrag: Secure Compiling Practices

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.4.2 Bibliotheksquellen
- DEV.4.5 Updates externer Softwarebibliotheken

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.4.2 Bibliotheksquellen
- DEV.4.5 Updates externer Softwarebibliotheken

Eintrag: Security by Default

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DEV.4.8 Default-Zugangsdaten
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default

BSI/Grundschutz/Quellkataloge/Kernel

- DEV.4.8 Default-Zugangsdaten
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default

Eintrag: Security by Design

Keine Controls gefunden.

Eintrag: Separation of Concerns

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.10 Drucker-Netz
 - ARCH.2.2.11 Physische Segmentierung
 - ARCH.2.2.12 Sprungserver
- ARCH.2.2.2 Gastnetz
- ARCH.2.2.3 Segmentierung von Servern und Clients
- ARCH.2.2.4 VoIP-Netz
- ARCH.2.2.5 OT-Systeme
- ARCH.2.2.7 Management-Netz
- ARCH.2.2.8 Segmentierung von Test und Betrieb
- ARCH.2.2.9 Segmentierung von IPv4 und IPv6

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.10 Drucker-Netz
 - ARCH.2.2.11 Physische Segmentierung
 - ARCH.2.2.12 Sprungserver
 - ARCH.2.2.2 Gastnetz
 - ARCH.2.2.3 Segmentierung von Servern und Clients
 - ARCH.2.2.4 VoIP-Netz
 - ARCH.2.2.5 OT-Systeme
 - ARCH.2.2.7 Management-Netz
 - ARCH.2.2.8 Segmentierung von Test und Betrieb
 - ARCH.2.2.9 Segmentierung von IPv4 und IPv6

Eintrag: Session Hijacking

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.14.5 Zeitüberschreitung von Netzverbindungen

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.14.5 Zeitüberschreitung von Netzverbindungen

Eintrag: Shadow IT

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
 - ASST.3.11.1 Autorisierung von Peripheriegeräten

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
 - ASST.3.11.1 Autorisierung von Peripheriegeräten

Eintrag: Shared Responsibility Model

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.1.4 Outsourcing-Strategie
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung

BSI/Grundschutz/Quellkataloge/Kernel

- BES.1.4 Outsourcing-Strategie
- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung

Eintrag: Shoulder Surfing

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- SENS.9.1 Verarbeitung in der Öffentlichkeit

BSI/Grundschutz/Quellkataloge/Kernel

- SENS.9.1 Verarbeitung in der Öffentlichkeit

Eintrag: VPN

Keine Controls gefunden.

Eintrag: Zero Trust

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.1.2 Quarantäne
- ASST.2.2 Inventar der Systeme
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- KONF.11.1 Authentifizierung vor dem Zugriff

- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.6.5 Dynamische Zugriffskontrolle im System

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.1.2 Quarantäne
- ASST.2.2 Inventar der Systeme
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.12 Sperre der Anwendung bei Inaktivität
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.6.5 Dynamische Zugriffskontrolle im System

Namespace: target_object_categories

Eintrag: Administrierende

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.3.13 Lagerung physischer Assets
- BER.3.5 Privilegierte Zugangskonten
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- SENS.10.1 Grundprinzipien der Systemadministration
- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.5 Systemadministration - Internetnutzung
- TEST.2.2 Folgenabschätzung

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.3.13 Lagerung physischer Assets
- BER.3.5 Privilegierte Zugangskonten
- PERS.4.2.1 Produktspezifische Schulungen und Sensibilisierungen
- SENS.10.1 Grundprinzipien der Systemadministration

- SENS.10.2 Umgang mit privilegierten Berechtigungen
- SENS.10.3 Systemadministration - Sicherheitsvorfälle
- SENS.10.5 Systemadministration - Internetnutzung
- TEST.2.2 Folgenabschätzung

Eintrag: Anwendungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.7.1 Nicht mehr benötigte Anwendungen
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.6 Anomale Nutzung der Anwendung
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- DEV.2.6.1 Eingabevalidierung
- DEV.2.6.2 Ausgabekodierung

- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.3.4 Passwort-Hashing
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.2 Bibliotheksquellen
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.6 Compileroptionen
- DEV.4.7 Deterministischer Binärcode
- DEV.4.8 Default-Zugangsdaten
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.7.2 Zertifikatsmonitoring
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.10.5 Überprüfung der Konfiguration
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1 Eingabevalidierung
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung

- KONF.6.6 Getrennte Datenhaltung
- KONF.6.6.1 Mandantenfähigkeit
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.8.2 Automatische Updates der Anwendung
- NOT.4.17 Anwendungstest
- NOT.4.3 Sicherung der Anwendung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.7.1 Dedizierte Hostsysteme für Server
- ARCH.8.3 Redundante Server
- ARCH.9.2 Lastverteilung
- ARCH.9.3 Automatische Skalierung
- ARCH.9.4 Content Delivery Network
- ASST.2.3.2 Software Bill of Materials (SBOM)
- ASST.7.1 Nicht mehr benötigte Anwendungen
- BER.3.10 Anmeldeversuchsgrenze an der Anwendung
- BER.3.12 Sperre der Anwendung bei Inaktivität
- BER.3.6 Single-Sign-On
- BER.3.7 Hinweise bei Anmeldefehlern
- BER.5.6 Anwendungsfunktionen ohne Authentifizierung
- DET.3.1 Protokollierung sicherheitsrelevanter Ereignisse
- DET.3.1.10 Nutzungsstatistik
- DET.3.1.11 Anwendungsspezifische Ereignisse
- DET.3.1.7 Was, Wann, Wo
- DET.3.1.8 Privilegierte Ereignisse
- DET.3.1.9 Fehler der Anwendung
- DET.4.14 Verfügbarkeit der Anwendung
- DET.4.16 Ressourcenauslastung der Server-Dienste
- DET.4.17 Anwendungsbasiertes Kapazitätsmanagement
- DET.4.6 Anomale Nutzung der Anwendung
- DET.5.10.3 Automatisierte Überwachung von Anwendungsupdates
- DEV.2.2 Dokumentation der (Software-)Architektur
- DEV.2.3 Ausführbarkeit mit minimalen Rechten
- DEV.2.5 Einschränkung des Zugriffs auf Zugangsdaten
- DEV.2.6 Widerstandsfähigkeit gegen gängige Angriffsmuster
- DEV.2.6.1 Eingabevalidierung
- DEV.2.6.2 Ausgabekodierung

- DEV.3.1 Replay-Angriffe
- DEV.3.2 Routinen zur Fehlerbehandlung
- DEV.3.3 Deaktivierung der Ausgabe schützenswerter Daten durch Fehlermeldungen
- DEV.3.4 Passwort-Hashing
- DEV.4.1 Nutzerinformation bei kritischen Ereignissen
- DEV.4.10 Protokollierung von Codeänderungen
- DEV.4.11 Test bei Änderungen am Quellcode
- DEV.4.2 Bibliotheksquellen
- DEV.4.3 Softwarebestandteile (SBOM)
- DEV.4.4 Integrität externer Softwarebibliotheken
- DEV.4.5 Updates externer Softwarebibliotheken
- DEV.4.6 Compileroptionen
- DEV.4.7 Deterministischer Binärcode
- DEV.4.8 Default-Zugangsdaten
- DEV.4.9 Voreinstellungen nach dem Prinzip Security by Default
- DEV.5.1 Verankerung des Zeitraums für Updates
- DEV.5.2 Information über Zeitraum für Updates
- DEV.5.3 Integritätsprüfung
- DEV.7.2 Zertifikatsmonitoring
- KONF.10.1 Grundkonfiguration für Anwendungen
- KONF.10.1.1 Versionierung der Anwendungskonfiguration
- KONF.10.2 Kryptographische Verfahren in Anwendungen
- KONF.10.3 Änderung von Default-Zugangsdaten
- KONF.10.4 Deaktivierung nicht benötigter Anwendungsfunktionen
- KONF.10.5 Überprüfung der Konfiguration
- KONF.10.5.1 Automatisierte Überprüfung der Konfiguration
- KONF.11.1 Authentifizierung vor dem Zugriff
- KONF.11.1.2 Authentifizierung von Netzverbindungen - clientseitig
- KONF.11.3 Alternative Authentifizierung
- KONF.11.7 Übersicht angemeldeter Verbindungen
- KONF.11.8 Einschränkung von Schnittstellen
- KONF.11.9 Verschlüsselung schützenswerter Daten (at-rest)
- KONF.12.1 Eingabevalidierung
- KONF.14.1 Verschlüsselung beim Transport
- KONF.14.1.1 Obligatorische Verschlüsselung
- KONF.14.1.2 Ende-zu-Ende-Verschlüsselung
- KONF.14.5 Zeitüberschreitung von Netzverbindungen
- KONF.6.13 Dynamische Zugriffskontrolle in der Anwendung

- KONF.6.6 Getrennte Datenhaltung
- KONF.6.6.1 Mandantenfähigkeit
- KONF.6.7 Privilegierte Funktionen der Anwendung
- KONF.8.2 Automatische Updates der Anwendung
- NOT.4.17 Anwendungstest
- NOT.4.3 Sicherung der Anwendung

Eintrag: Cloud-Dienste

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.4.8.2 Cloud-Konformität
- BES.7.4.10 Serviceprofil
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- DET.3.1.13 Integration von Cloud-Diensten

BSI/Grundschutz/Quellkataloge/Kernel

- BES.1.5 Autorisierung des Bereitstellungsmodells
- BES.1.6 Dokumentation des Bereitstellungsmodells
- BES.1.7 Vereinbarung der geteilten Verantwortung
- BES.2.2 Dokumentation des Rechtsraums und der Datenlokation
- BES.2.3 Vereinbarung des Rechtsraums und der Datenlokation
- BES.4.8.2 Cloud-Konformität
- BES.7.4.10 Serviceprofil
- BES.7.4.12 Software Bill of Materials (SBOM) - Cloud
- DET.3.1.13 Integration von Cloud-Diensten

Eintrag: Dateiserver

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.12.1.9 Journaling
- KONF.12.7 Erweiterte Attribute

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.12.1.9 Journaling
- KONF.12.7 Erweiterte Attribute

Eintrag: Daten

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.2.1.1 Informationsverantwortung
- ASST.2.4 Klassifizierung
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.5 Tainting
- ASST.3.9 Aktualisierung
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.4 Nachweis des Zugangs
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3 Geregeltes Löschen oder Vernichten
- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Lösungsverfahren
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.4 Wiederherstelltest
- DET.3.1.12 Datenverarbeitungen
- DET.3.5 Unbestreitbarkeit
- DLS.2.2 Transportverschlüsselung
- DLS.2.3 Vollverschlüsselung
- NOT.4.14 Offline-Kopie
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets

- NOT.4.5.2 Zum Archiv gehörende Dokumentation

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.2.1.1 Informationsverantwortung
- ASST.2.4 Klassifizierung
- ASST.3.10 Autorisierung von Datenlokationen
- ASST.3.11 Autorisierung von Systemen
- ASST.3.11.1 Autorisierung von Peripheriegeräten
- ASST.3.12 Autorisierung von Personen oder Institutionen
- ASST.3.2 Entfernung nicht erforderlicher Rest- oder Zusatzdaten
- ASST.3.5 Tainting
- ASST.3.9 Aktualisierung
- ASST.4.1 Autorisierung von Schnittstellen
- ASST.4.2 Vertraulichkeit und Integrität beim Transport
- ASST.4.4 Nachweis des Zugangs
- ASST.4.5 Vereinbarungen zum Austausch
- ASST.7.2 Aufbewahrungs- und Löschfristen
- ASST.7.2.1 Langfristige Archivierung
- ASST.7.3 Geregelttes Löschen oder Vernichten
- ASST.7.3.1 Standardisierte Vernichtung
- ASST.7.3.2 Lösungsverfahren
- ASST.7.3.3 Zugelassene Löschanwendungen
- ASST.7.4 Wiederherstelltest
- DET.3.1.12 Datenverarbeitungen
- DET.3.5 Unbestreitbarkeit
- DLS.2.2 Transportverschlüsselung
- DLS.2.3 Vollverschlüsselung
- NOT.4.14 Offline-Kopie
- NOT.4.16 Test der Datensicherung
- NOT.4.16.1 Test der Wiederherstellung
- NOT.4.4 Automatische Datensicherung
- NOT.4.5 Archivierung langfristig benötigter Daten
- NOT.4.5.1 Zum Archiv gehörende Assets
- NOT.4.5.2 Zum Archiv gehörende Dokumentation

Eintrag: Datenträgerarchiv

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.8.2 Staub und Schmutz
- GEB.8.4 Überwachung schonender Klimatisierung

BSI/Grundschutz/Quellkataloge/Kernel

- GEB.8.2 Staub und Schmutz
- GEB.8.4 Überwachung schonender Klimatisierung

Eintrag: Dienstleistungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.4.6.1 Authentifizierung des Kunden
- BES.5.1 Kompetenzen
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.5 Nutzungsregelungen
- BES.5.5.1 Datenlokationen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.8 Rechte für geistiges Eigentum
- BES.5.9 Umgang mit Änderungen
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.2.1 Löschverfahren
- BES.6.3 Übertragbarkeit von Daten
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.8.5 Treuhand
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben

- DLS.4.1 Dekommissionierung
- DLS.4.1.2 Berechtigungen deaktivieren

BSI/Grundschutz/Quellkataloge/Kernel

- BES.4.6.1 Authentifizierung des Kunden
- BES.5.1 Kompetenzen
- BES.5.12 Informationspflichten
- BES.5.13 Bereitstellung von Datensicherungen
- BES.5.5 Nutzungsregelungen
- BES.5.5.1 Datenlokationen
- BES.5.5.2 Autorisierung der Zugriffsberechtigung
- BES.5.8 Rechte für geistiges Eigentum
- BES.5.9 Umgang mit Änderungen
- BES.5.9.1 Autorisierung von Änderungen
- BES.6.1 Entziehung der Zugangsberechtigungen
- BES.6.2 Löschung von Daten
- BES.6.2.1 Löschverfahren
- BES.6.3 Übertragbarkeit von Daten
- BES.6.4 Übertragung von Supportdienstleistungen
- BES.6.5 Behandlung aufzubewahrender Aufzeichnungen
- BES.6.6 Rückgewähr von Assets
- BES.7.4.6 Shared Responsibility
- BES.7.4.7 Organisatorische Schnittstellen
- BES.7.4.8 Technische Schnittstellen
- BES.8.5 Treuhand
- DLS.2.1 Mehr-Faktor-Authentifizierung
- DLS.3.1 Einhaltung der Sicherheitsvorgaben
- DLS.4.1 Dekommissionierung
- DLS.4.1.2 Berechtigungen deaktivieren

Eintrag: DNS-Server

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.12.14 DNS-Falschinformationen

- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.11.4 Veröffentlichung von Domain-Informationen
- KONF.11.8.1 Einschränkung von Zonentransfers
- KONF.12.14 DNS-Falschinformationen
- KONF.14.2 Source Port Randomisierung
- KONF.14.3 Iterative Beantwortung

Eintrag: E-Mail

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DET.4.18 Öffentliche Blocklisten
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.5 Publikation der Sendeberechtigung
- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.13.9 Publikation der DMARC-Richtlinie

BSI/Grundschutz/Quellkataloge/Kernel

- DET.4.18 Öffentliche Blocklisten
- KONF.13.10 Authentifizierung der Server-Zertifikate über DNS
- KONF.13.11 MTA-STS
- KONF.13.2.1 Verifikation der Sendeberechtigung
- KONF.13.2.2 Verifikation der Serversignatur
- KONF.13.3 Kryptographische Signatur des Mailservers
- KONF.13.4 Kryptographische Signatur durch Nutzende
- KONF.13.5 Publikation der Sendeberechtigung

- KONF.13.5.1 Strenge Senderpolicy
- KONF.13.6 Publikation der Serversignatur
- KONF.13.7 TLS-Reports
- KONF.13.8 DMARC-Reports
- KONF.13.9 Publikation der DMARC-Richtlinie

Eintrag: Einkäufe

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.1.3.1 Gesamte Lieferkette
- BES.2.1 Erfassung des Bedarfes
- BES.2.1.4 Kompatibilität
- BES.2.1.4.1 Kompatibilität der Schnittstellen
- BES.2.1.4.2 Kompatibilität der Netzanbindung
- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.2 Auswahlkriterien
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.3 Beschaffung anhand der Kriterien
- BES.4.5 Security by Design
- BES.4.6 Security by Default
- BES.4.8 Konformitätsnachweise
- BES.4.8.1 Zertifizierung
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.10 Behandlung von Vorfällen
- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.10.4 Konfliktlösungsprozesse

- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.3 Compliance-Verpflichtungen
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.7 Schulung
- BES.7.1 Eingangskontrolle
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.4 Dokumentation der Komponenten
- BES.8.1 Bereithaltung alternativer Lieferanten

BSI/Grundschutz/Quellkataloge/Kernel

- BES.1.3 Lieferanten- und Dienstleisterverzeichnis
- BES.1.3.1 Gesamte Lieferkette
- BES.2.1 Erfassung des Bedarfes
- BES.2.1.4 Kompatibilität
- BES.2.1.4.1 Kompatibilität der Schnittstellen
- BES.2.1.4.2 Kompatibilität der Netzanbindung
- BES.2.1.4.3 Kompatibilität des Administrationsmodells
- BES.2.1.4.4 Kompatibilität des Datenmanagementmodells
- BES.2.4 Anhörung Nutzender
- BES.2.5 Anhörung Adminstrierender
- BES.3.1 Klassifizierung von Lieferantenbeziehungen
- BES.3.2 Auswahlkriterien
- BES.3.2.1 Zertifizierte Lieferanten
- BES.3.2.2 Quellendiversifikation
- BES.3.3 Unzuverlässige Lieferanten
- BES.4.1 Klassifizierung von Beschaffungsvorhaben
- BES.4.2 Dokumentation der Beschaffungskriterien
- BES.4.3 Beschaffung anhand der Kriterien
- BES.4.5 Security by Design
- BES.4.6 Security by Default
- BES.4.8 Konformitätsnachweise
- BES.4.8.1 Zertifizierung
- BES.4.9 Sicherheitsüberprüfung (extern)
- BES.5.10 Behandlung von Vorfällen

- BES.5.10.1 Erreichbarkeit über Meldewege
- BES.5.10.2 Melden von Vorfällen
- BES.5.10.3 Schwachstellenbehebung
- BES.5.10.4 Konfliktlösungsprozesse
- BES.5.10.5 Konsequenzen bei Verstößen
- BES.5.3 Compliance-Verpflichtungen
- BES.5.4 Informationssicherheitskontrollmechanismen
- BES.5.6 Vergabe von Unteraufträgen
- BES.5.6.1 Weitergabe der Beschaffungskriterien
- BES.5.6.2 Autorisierung von Unterauftragnehmern
- BES.5.7 Schulung
- BES.7.1 Eingangskontrolle
- BES.7.4 Vollständigkeit der Unterlagen
- BES.7.4.4 Dokumentation der Komponenten
- BES.8.1 Bereithaltung alternativer Lieferanten

Eintrag: Endgeräte

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.3.4 Physischer Diebstahlschutz
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.3 Kiosk-Modus

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.2.5.1.1 Automatische Konfigurationsverwaltung
- KONF.3.4 Physischer Diebstahlschutz
- KONF.3.6 Fernlöschung oder -sperre
- KONF.3.6.1 Automatische Fernlöschung oder -sperre
- KONF.5.1.2 Pre-Boot-Authentifizierung
- KONF.6.1.3 Isolierte Arbeitsumgebungen
- KONF.6.2 Gemeinsam genutzte Verzeichnisse
- KONF.6.3 Kiosk-Modus

Eintrag: Externe Netzanschlüsse

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.13 Produktdiversität
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.8.2 Redundante TK-Anbindung
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.5.1.10 Webfilterung
- ARCH.5.1.10.1 Bekannte schädliche Inhalte
- ARCH.5.1.10.2 Bekannte illegale Inhalte
- ARCH.5.1.10.3 Speicherdienste
- ARCH.5.1.11 P-A-P-Struktur
- ARCH.5.1.13 Produktdiversität
- ARCH.5.1.5 Deaktivierung von Split Tunneling
- ARCH.5.1.6 Blockieren direkter Management-Verbindungen
- ARCH.5.1.7 Edge-Routing
- ARCH.5.1.8 Inspektion verschlüsselter Verbindungen
- ARCH.5.1.9 Filterung von DNS
- ARCH.6.1 Kontrollierte Verbindungsführung
- ARCH.6.2 Verschlüsselung von Weiterverkehrsverbindungen
- ARCH.8.2 Redundante TK-Anbindung
- DET.4.11.1 Authentifizierungsversuche an externen Schnittstellen

Eintrag: Fahrzeuge

Keine Controls gefunden.

Eintrag: Fax

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.12.13 Sendebericht

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.12.13 Sendebericht

Eintrag: Führungskräfte

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling

BSI/Grundschutz/Quellkataloge/Kernel

- SENS.11.2 Führen als Vorbild
- SENS.11.3 Whaling

Eintrag: Gebäude

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.2.2 Dokumentation öffentlicher Bereiche

BSI/Grundschutz/Quellkataloge/Kernel

- GEB.2.2 Dokumentation öffentlicher Bereiche

Eintrag: Hostsysteme

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.7.2 Dedizierte Hardware
- BER.3.20 Dienstkonten
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.15 Ressourcenauslastung von Hostsystemen
- GEB.6.2.1 Hostsysteme
- KONF.9.2 Begrenzung der Rechenleistung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.7.2 Dedizierte Hardware
- BER.3.20 Dienstkonten
- DET.4.13 Verfügbarkeit des Hostsystems
- DET.4.15 Ressourcenauslastung von Hostsystemen
- GEB.6.2.1 Hostsysteme
- KONF.9.2 Begrenzung der Rechenleistung

Eintrag: Informationen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.3.6 Verifikation
- ASST.3.7 Pseudonymisierung
- ASST.3.8 Anonymisierung

Eintrag: Institutionsleitung

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- SENS.11.1 Sensibilisierung der Institutionsleitung

BSI/Grundschutz/Quellkataloge/Kernel

- SENS.11.1 Sensibilisierung der Institutionsleitung

Eintrag: Interne Netzsegmente

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.1.2 Quarantäne

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.4.1 Netzzugangskontrolle
- ARCH.4.1.1 Dynamische Netzzugangskontrolle
- ARCH.4.1.2 Quarantäne

Eintrag: Interpersonelle Kommunikation

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.1.1 SPAM-Filter
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.2 Authentizität von Nachrichten

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.13.1 Filtern schädlicher Nachrichten
- KONF.13.1.1 SPAM-Filter
- KONF.13.1.2 Interpretation aktiver Inhalte
- KONF.13.2 Authentizität von Nachrichten

Eintrag: IT-Produkte

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.2.1.1 Verwendungszweck
- BES.2.1.3 Systemvoraussetzungen

- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.6.3 Manipulationsschutz
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.7.4.5 Netzverbindungen ab Werk
- BES.8.4 Individuelle Implementierung kritischer Komponenten

BSI/Grundschutz/Quellkataloge/Kernel

- BES.2.1.1 Verwendungszweck
- BES.2.1.3 Systemvoraussetzungen
- BES.2.1.5 Lizenzierung
- BES.2.1.6 Support- und Wartungsverträge
- BES.4.5.1 Entwicklung nach einem Sicherheitslebenszyklus
- BES.4.6.3 Manipulationsschutz
- BES.5.10.3.1 Schwachstellenmeldeprozess
- BES.5.6.3 Nachverfolgbarkeit der Lieferkette
- BES.7.4.1 Beschreibung der Sicherheitsarchitektur
- BES.7.4.2 Beschreibung von Sicherheitsmechanismen
- BES.7.4.3 Empfohlene Konfiguration
- BES.7.4.4.1 Software Bill of Materials (SBOM)
- BES.7.4.5 Netzverbindungen ab Werk
- BES.8.4 Individuelle Implementierung kritischer Komponenten

Eintrag: IT-Systeme

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.3 Mikrosegmentierung
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten

- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Regelte Wartungen
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.5.5 Wartungsfenster
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.3 Konformitätsprüfung
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.7 IT-System-Zugangskonto
- DET.3.1.1 Authentifizierungen
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse
- DET.4.10 Host-basierte Köder
- DET.4.2 Automatische Angriffserkennung
- DET.4.9 Manipulations-Checkup
- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.6.2 Geschützte Aufstellung
- KONF.2.1 Grundkonfiguration für Systeme
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
- KONF.2.5.1 Automatische Konfigurationsverwaltung

- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.3 SIM-PIN
- KONF.3.5 Standortbestimmung
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2 DNS-Anbindung
- KONF.4.2.1 DNS-Verschlüsselung
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen
- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.7.1 Echtzeitscanner
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.15 Lokale Firewall
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.5 Alarmierung

- KONF.7.6 Automatische Updates
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.9.1 Speicherplatzbegrenzung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.4.2 Sicherung des Systems

BSI/Grundschrift/Quellkataloge/Kernel

- ARCH.2.3 Mikrosegmentierung
- ARCH.5.2 Blockieren direkter öffentlicher Verbindungen
- ASST.2.3.1 Autorisierung von Anwendungen
- ASST.3.4 Kennzeichnung ohne vertrauliche Daten
- ASST.5.1 Wartungsbedarf dokumentieren
- ASST.5.2 Geregelter Wartungen
- ASST.5.3 Autorisierung von Wartungen
- ASST.5.4 Behandlung als Änderungen und Tests
- ASST.5.5 Wartungsfenster
- ASST.5.7 Dokumentation von Wartungen
- ASST.6.3 Konformitätsprüfung
- ASST.6.4 Zurücksetzen auf Ausgangszustand
- BER.3.11 Systemsperre bei Inaktivität
- BER.3.19 Zwischenspeicherung von Zugangsdaten
- BER.3.9 Anmeldeversuchsgrenze am System
- BER.5.5 Systemfunktionen ohne Authentifizierung
- BER.5.7 IT-System-Zugangskonto
- DET.3.1.1 Authentifizierungen
- DET.3.1.2 Ausgeführte Kommandozeilenbefehle
- DET.3.1.3 Anbindung von Peripheriegeräten
- DET.3.1.4 Systemfehler
- DET.3.1.5 Störungen der Netzerreichbarkeit
- DET.3.1.6 Systemspezifische Ereignisse
- DET.4.10 Host-basierte Köder
- DET.4.2 Automatische Angriffserkennung
- DET.4.9 Manipulations-Checkup

- DET.5.10.2 Automatisierte Überwachung von Systemupdates
- DET.5.4 Regelmäßige Penetrationstests
- DET.5.5 Red Teaming
- GEB.5.4 Schutz gegen Manipulation
- GEB.5.5 Physische Mikrosegmentierung
- GEB.6.1 Zugang zu Ausgabesystemen
- GEB.6.2 Geschützte Aufstellung
- KONF.2.1 Grundkonfiguration für Systeme
- KONF.2.1.1 Versionierung der Systemkonfiguration
- KONF.2.2 Kryptographische Verfahren in IT-Systemen
- KONF.2.3 Änderung von Default-Zugangsdaten
- KONF.2.4 Deaktivierung nicht benötigter Systemfunktionen
- KONF.2.4.1 Nicht benötigte Zertifikate
- KONF.2.4.2 Externe Cloud-Anbindungen
- KONF.2.5 Überprüfung der Konfiguration
- KONF.2.5.1 Automatische Konfigurationsverwaltung
- KONF.2.6 Souveräne Werkzeuge
- KONF.2.7 Alternative Administrationszugänge
- KONF.2.8 Abgesicherter und authentisierter Bootprozess
- KONF.3.1 Kryptographischer Hardwarespeicher
- KONF.3.2 Speicherverschlüsselung
- KONF.3.3 SIM-PIN
- KONF.3.5 Standortbestimmung
- KONF.3.7 Einschränkung angeschlossener Peripherie
- KONF.3.8 Einschränkung von Wechselmedien
- KONF.4.1 Anbindung an Verzeichnisdienst
- KONF.4.1.1 Weiterleitung von Anmeldeinformationen
- KONF.4.2 DNS-Anbindung
- KONF.4.2.1 DNS-Verschlüsselung
- KONF.4.3 Authentifizierung von Fernwartungsfunktionen
- KONF.4.4 Einschränkung von Fernwartungsfunktionen
- KONF.4.5 Zeitquellen
- KONF.5.1 Authentifizierung am System
- KONF.5.1.1 Authentifizierung an der Firmware
- KONF.5.2 Keine Mehrfachanmeldung
- KONF.6.1 Minimal erforderliche Berechtigungen für Anwendungen
- KONF.6.1.1 Datenkapselung
- KONF.6.1.2 Isolierung von Anwendungen

- KONF.6.4 Privilegierte Systemfunktionen
- KONF.6.4.1 Rollenbasierte Privilegierung
- KONF.6.5 Dynamische Zugriffskontrolle im System
- KONF.7.1 Echtzeitscanner
- KONF.7.10 Einschränkung der Ausführung
- KONF.7.11 Einschränkung von Softwarebibliotheken
- KONF.7.12 Einschränkung von Skripten
- KONF.7.13 Einschränkung von Systemaufrufen
- KONF.7.14 Code-Signierung im Betriebssystemkern
- KONF.7.15 Lokale Firewall
- KONF.7.16 Anti-Exploit
- KONF.7.16.1 Anti-Exploit für den Arbeitsspeicher
- KONF.7.2 Regelmäßige Scans
- KONF.7.3 Host-basierte Angriffserkennung
- KONF.7.4 Angriffserkennung anhand von Netzverkehr
- KONF.7.5 Alarmierung
- KONF.7.6 Automatische Updates
- KONF.7.7 Regelmäßiger Funktionstest
- KONF.7.8 Dual-Engine-Strategie
- KONF.7.9 Einschränkung der Installation
- KONF.8.1 Automatische Überprüfung
- KONF.8.1.1 Automatische Sicherheitsupdates
- KONF.9.1 Speicherplatzbegrenzung
- KONF.9.3 Alternative Komponenten für kritische Funktionen
- NOT.4.2 Sicherung des Systems

Eintrag: Mitarbeitende

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.5.6 Wartung durch Externe
- PERS.3.1 Dienst- oder Arbeitsvertrag
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- PERS.3.7 Einarbeitung
- PERS.4.1 Qualifikationsbedarf
- PERS.6.1.2 Neubesetzung
- SENS.8.7 Verwendung von Brandschuttmitteln

- SENS.8.8 Verwendung von Wasserschutzmitteln

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.5.6 Wartung durch Externe
- PERS.3.1 Dienst- oder Arbeitsvertrag
- PERS.3.2 Verfahrensanweisungen
- PERS.3.3 Betriebs- und Geschäftsgeheimnisse
- PERS.3.7 Einarbeitung
- PERS.4.1 Qualifikationsbedarf
- PERS.6.1.2 Neubesetzung
- SENS.8.7 Verwendung von Brandschutzmitteln
- SENS.8.8 Verwendung von Wasserschutzmitteln

Eintrag: Mobiltelefone

Keine Controls gefunden.

Eintrag: Netze

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.1 Externe Netzanschlüsse
 - ARCH.2.2.10 Drucker-Netz
 - ARCH.2.2.11 Physische Segmentierung
 - ARCH.2.2.2 Gastnetz
 - ARCH.2.2.3 Segmentierung von Servern und Clients
 - ARCH.2.2.4 VoIP-Netz
 - ARCH.2.2.5 OT-Systeme
 - ARCH.2.2.6 Demilitarisierte Zone
 - ARCH.2.2.7 Management-Netz
 - ARCH.2.2.8 Segmentierung von Test und Betrieb
 - ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.5 Netzplan
- ARCH.2.6 Topologieüberwachung
- ARCH.4.2 Autorisiertes Routing

- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen
 - ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
 - ARCH.5.1.12 Software-definierte Verbindungen
 - ARCH.5.1.2 Netzbasierte Angriffe
 - ARCH.5.1.3 TCP-basierte Angriffe
 - ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.9.1 Dimensionierung der Netzanbindung
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- DET.4.11 Anomalien in Netzen und am Perimeter
 - DET.4.11.2 Netzwerk-Honeypots
 - DET.4.11.3 Netzverkehrsfluss
- DET.4.12 Monitoring der Netzverfügbarkeit
 - DET.4.12.1 Auslastung des Netzes
- GEB.6.3 Netzkomponenten

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.2.1 Netzsegmente
- ARCH.2.2 Einschränkung von Verbindungen zwischen Segmenten
 - ARCH.2.2.1 Externe Netzanschlüsse
 - ARCH.2.2.10 Drucker-Netz
 - ARCH.2.2.11 Physische Segmentierung
 - ARCH.2.2.2 Gastnetz
 - ARCH.2.2.3 Segmentierung von Servern und Clients
 - ARCH.2.2.4 VoIP-Netz
 - ARCH.2.2.5 OT-Systeme
 - ARCH.2.2.6 Demilitarisierte Zone
 - ARCH.2.2.7 Management-Netz
 - ARCH.2.2.8 Segmentierung von Test und Betrieb
 - ARCH.2.2.9 Segmentierung von IPv4 und IPv6
- ARCH.2.5 Netzplan
- ARCH.2.6 Topologieüberwachung
- ARCH.4.2 Autorisiertes Routing
- ARCH.4.3 Authentifizierung von Routingprotokollen
- ARCH.5.1 Einschränkung und Inspektion von Verbindungen

- ARCH.5.1.1 Blockieren anfälliger Netzprotokolle
- ARCH.5.1.12 Software-definierte Verbindungen
- ARCH.5.1.2 Netzbasierte Angriffe
- ARCH.5.1.3 TCP-basierte Angriffe
- ARCH.5.1.4 UDP-basierte Angriffe
- ARCH.8.1 Redundanz im Kernnetz
- ARCH.9.1 Dimensionierung der Netzanbindung
- ARCH.9.5 Schutz gegen volumetrische DoS-Angriffe
- ASST.2.2.1 Aufdecken unautorisierter IT-Systeme
- DET.4.11 Anomalien in Netzen und am Perimeter
- DET.4.11.2 Netzwerk-Honeypots
- DET.4.11.3 Netzverkehrsfluss
- DET.4.12 Monitoring der Netzverfügbarkeit
- DET.4.12.1 Auslastung des Netzes
- GEB.6.3 Netzkomponenten

Eintrag: Nutzende

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.3.1 Nutzungsvereinbarungen
- ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- BER.6.1 Passwortmanager
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter
- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- SENS.12.1 Hohe Risiken
- SENS.2.1 Schutzziele
- SENS.2.2 Meldewege
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8 Melden von Ereignissen

- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.4.1 Personengebundene Authentisierungsmittel
 - SENS.4.1.1 Verdeckte Eingabe
 - SENS.4.1.2 Untersagung von Passwort Recycling
 - SENS.4.1.3 Wahl von Passwörtern
 - SENS.4.1.4 Passwörter nur im Passwortmanager
 - SENS.4.1.5 Biometrische Authentifikation
 - SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.5 Löschfristen
- SENS.5.6 Papiervernichtung
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören
- SENS.9.3 Verwahrung außer Haus
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.6 Mitnahme ins Ausland
- SENS.9.7 Reise- und Sicherheitshinweise

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.3.1 Nutzungsvereinbarungen
 - ASST.3.1.1 Weitergabe nur bei Erforderlichkeit
- BER.6.1 Passwortmanager
- BER.6.6 Blockieren von Passwort Recycling
- BER.6.7 Trivialpasswörter

- NOT.3.3 Sensibilisierung zum Vorgehen im Notfall
- PERS.4.2 Rollenspezifische Schulungen und Sensibilisierungen
- PERS.6.1 Vorgehensweise für den Weggang
- PERS.6.1.1 Entzug von Berechtigungen gemäß BER
- SENS.12.1 Hohe Risiken
- SENS.2.1 Schutzziele
- SENS.2.2 Meldewege
- SENS.2.4 Nutzung unautorisierter Assets
- SENS.2.4.1 Verbindung unautorisierter IT-Systeme
- SENS.2.5 Zuständigkeitsbereiche
- SENS.2.6 Umgehung von Sicherheitsfunktionen
- SENS.2.7 Änderung von Konfigurationen
- SENS.2.8 Melden von Ereignissen
- SENS.2.8.1 Melden von Fehler- und Warnmeldungen
- SENS.3.1 Schadprogramme
- SENS.3.2 Öffnen in der Sandbox
- SENS.3.3 Umwandeln verdächtiger Dateien
- SENS.4.1 Personengebundene Authentisierungsmittel
- SENS.4.1.1 Verdeckte Eingabe
- SENS.4.1.2 Untersagung von Passwort Recycling
- SENS.4.1.3 Wahl von Passwörtern
- SENS.4.1.4 Passwörter nur im Passwortmanager
- SENS.4.1.5 Biometrische Authentifikation
- SENS.4.1.6 Keine Weitergabe personengebundener Authentisierungsmittel
- SENS.4.2 Mehrfachnutzung von Zugängen
- SENS.4.3 Abmelden nach Nutzung
- SENS.5.1 Datenablage
- SENS.5.3 Weitergabe von Erreichbarkeiten
- SENS.5.4 Rest- und Zusatzdaten
- SENS.5.5 Löschfristen
- SENS.5.6 Papiervernichtung
- SENS.6.1 Scan angenommener Wechseldatenträger
- SENS.6.2 Verschlüsselung
- SENS.7.1 Spezifische Sensibilisierung
- SENS.8.3 Mitbringen von IT-Systemen
- SENS.8.6 Rückgabe nicht mehr benötigter Assets
- SENS.9.1 Verarbeitung in der Öffentlichkeit
- SENS.9.2 Vorsicht vor Mithören

- SENS.9.3 Verwahrung außer Haus
- SENS.9.4 Mobile Arbeit mit Dokumenten
- SENS.9.5 Mitnahme zur mobilen Arbeit
- SENS.9.6 Mitnahme ins Ausland
- SENS.9.7 Reise- und Sicherheitshinweise

Eintrag: Office-Anwendungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.12.1.11 Aktive Dateiinhalte

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.12.1.11 Aktive Dateiinhalte

Eintrag: Outsourcing

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BES.1.4 Outsourcing-Strategie
- BES.1.4.1 Freigabe der Strategie
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.4.5.2 Mandamententrennung
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.7 ISMS beim Dienstleister
- BES.4.8.3 IT-Grundschutz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.5.11 Recht auf Audit
- BES.5.13.1 Datenbereitstellung
- BES.5.14 Löschregeln
- BES.5.2 Service Level Agreement
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4.11 Dokumentierte Mandamententrennung

- BES.7.4.9 Auslagerungsregister
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check
- DLS.3.4 Anhörung
- DLS.3.6 Portabilität
- DLS.4.1.1 Unabhängigkeit
- NOT.4.13 Datensouveränität

BSI/Grundschutz/Quellkataloge/Kernel

- BES.1.4 Outsourcing-Strategie
- BES.1.4.1 Freigabe der Strategie
- BES.2.1.2 Geschäftsprozessprofile
- BES.2.6 Outsourcing auf Grundlage der Geschäftsprozessprofile
- BES.4.4 Vertragsvorlage für Outsourcing
- BES.4.5.2 Mandantentrennung
- BES.4.6.2 Verschlüsselung durch den Anbieter
- BES.4.7 ISMS beim Dienstleister
- BES.4.8.3 IT-Grundschutz-Analyse der Infrastruktur
- BES.4.8.4 Offenlegung der Risikoanalyse
- BES.5.11 Recht auf Audit
- BES.5.13.1 Datenbereitstellung
- BES.5.14 Löschregeln
- BES.5.2 Service Level Agreement
- BES.7.1.1 Test der Kompatibilität
- BES.7.1.2 Netzcheck
- BES.7.2 Prozesse vor Netzanbindung
- BES.7.3 Anhörung Prozessbeteiligter
- BES.7.4.11 Dokumentierte Mandantentrennung
- BES.7.4.9 Auslagerungsregister
- BES.8.2 Verfahren zur Übertragung von Geschäftsprozessen
- BES.8.3 Ressourcensouveränität
- DLS.3.1.1 Audit oder Zertifikat
- DLS.3.2 Checkup
- DLS.3.3 Strategie-Check

- DLS.3.4 Anhörung
- DLS.3.6 Portabilität
- DLS.4.1.1 Unabhängigkeit
- NOT.4.13 Datensouveränität

Eintrag: Räume

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DET.4.19 Unautorisierte Sendeanlagen
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock

BSI/Grundschutz/Quellkataloge/Kernel

- DET.4.19 Unautorisierte Sendeanlagen
- GEB.10.2.1 Baulicher Brandschutz
- GEB.10.2.2 Brandabschnitte
- GEB.10.2.3 Rauchdichtheit
- GEB.10.2.4 Brandwiderstandsklassen
- GEB.5.1 Clean Desk
- GEB.5.2 Screen Lock

Eintrag: Räume für technische Infrastruktur

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- GEB.9.7 Zweckentfremdung

BSI/Grundschutz/Quellkataloge/Kernel

- GEB.10.5 Ableitfähiger Fußbodenbelag
- GEB.9.6 Zugang zu Räumen für technische Infrastruktur
- GEB.9.7 Zweckentfremdung

Eintrag: Serverräume

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.1.2 Klimamessung
- GEB.10.2.7 Brandunterdrückung
- GEB.6.4 Normgerechte Rechenzentren

BSI/Grundschutz/Quellkataloge/Kernel

- GEB.10.1.1 Luftstrom-Analyse
- GEB.10.1.2 Klimamessung
- GEB.10.2.7 Brandunterdrückung
- GEB.6.4 Normgerechte Rechenzentren

Eintrag: Standorte

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ASST.7.5 Vernichtungseinrichtungen
- GEB.1.3 Autorisierung von Standorten
- GEB.1.3.1 Abnahme von Standorten
- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
- GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2 Brandschutz
- GEB.10.2.5 Vermeidung von Brandlasten
- GEB.10.2.6 Brandmeldeanlagen
- GEB.10.2.8 Brandschutzprüfung
- GEB.10.3 Wasserschutz
- GEB.10.3.1 Doppelter baulicher Wasserschutz
- GEB.10.3.2 Leckagesensor
- GEB.10.4 Blitzschutzeinrichtungen
- GEB.10.4.1 Niederohmigkeit
- GEB.2.1 Installation von Perimetern
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.2.4 Elektromagnetische Abschirmung

- GEB.3.1 Überwachung von Zutrittspunkten
 - GEB.3.1.1 Videoüberwachung
 - GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.3 Authentifizierung vor Zutritt
 - GEB.3.3.1 Zugangskrollanlage
 - GEB.3.3.2 Dokumentation von Zutritten
 - GEB.3.3.3 Besucheranmeldung
- GEB.3.5 Einbruchhemmung
- GEB.3.6 Einbruchmeldeanlagen
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.4.1 Einrichtung
- GEB.4.2 Gesonderte Autorisierung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.7.1 Schlüsselbeauftragte
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.7.3 Schlüsselaudit
- GEB.8.1 Gesonderte Aufbewahrung
 - GEB.8.1.1 Archiv
- GEB.8.3 Schutz der Datenträger vor Brandschäden
- GEB.9.1 Normgerechte Stromversorgung
 - GEB.9.1.1 Vorausschauende Lastanalyse
 - GEB.9.1.2 Dedizierte Elektrountervertelung
 - GEB.9.1.3 Redundante Stromversorgung
 - GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.2 Lasttest
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- GEB.9.5 Strukturierte Datenverkabelung
 - GEB.9.5.1 Physisch geschützte Verlegung

BSI/Grundschutz/Quellkataloge/Kernel

- ASST.7.5 Vernichtungseinrichtungen
- GEB.1.3 Autorisierung von Standorten
 - GEB.1.3.1 Abnahme von Standorten

- GEB.1.4 Exponierte Bereiche
- GEB.1.5 Strukturpläne
- GEB.10.1 Klimatisierung
 - GEB.10.1.3 Redundante Klimatisierung
- GEB.10.2 Brandschutz
 - GEB.10.2.5 Vermeidung von Brandlasten
 - GEB.10.2.6 Brandmeldeanlagen
 - GEB.10.2.8 Brandschutzprüfung
- GEB.10.3 Wasserschutz
 - GEB.10.3.1 Doppelter baulicher Wasserschutz
 - GEB.10.3.2 Leckagesensor
- GEB.10.4 Blitzschutzeinrichtungen
 - GEB.10.4.1 Niederohmigkeit
- GEB.2.1 Installation von Perimetern
- GEB.2.3 Erkundung aus dem öffentlichen Raum
- GEB.2.4 Elektromagnetische Abschirmung
- GEB.3.1 Überwachung von Zutrittspunkten
 - GEB.3.1.1 Videoüberwachung
 - GEB.3.1.2 Überprüfung mitgeführter Gegenstände
- GEB.3.2 Anmelde- und Empfangsbereiche
- GEB.3.3 Authentifizierung vor Zutritt
 - GEB.3.3.1 Zugangskontrollanlage
 - GEB.3.3.2 Dokumentation von Zutritten
 - GEB.3.3.3 Besucheranmeldung
- GEB.3.5 Einbruchhemmung
- GEB.3.6 Einbruchmeldeanlagen
- GEB.3.7 Kontrolle der Zutrittskontrolle
- GEB.4.1 Einrichtung
- GEB.4.2 Gesonderte Autorisierung
- GEB.4.3 Schleusen
- GEB.4.4 Vereinzelungsanlage
- GEB.5.3 Lieferzugang
- GEB.7.1 Schlüsselbeauftragte
- GEB.7.2 Verwahrung von Schlüsseln
- GEB.7.3 Schlüsselaudit
- GEB.8.1 Gesonderte Aufbewahrung
 - GEB.8.1.1 Archiv
- GEB.8.3 Schutz der Datenträger vor Brandschäden

- GEB.9.1 Normgerechte Stromversorgung
- GEB.9.1.1 Vorausschauende Lastanalyse
- GEB.9.1.2 Dedizierte Elektrounterverteilung
- GEB.9.1.3 Redundante Stromversorgung
- GEB.9.1.4 Langanhaltende Sekundärversorgung
- GEB.9.2 Lasttest
- GEB.9.3 Notaus
- GEB.9.4 Überspannungsschutz
- GEB.9.5 Strukturierte Datenverkabelung
- GEB.9.5.1 Physisch geschützte Verlegung

Eintrag: TK-Anwendungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.12 Verbindungsprotokoll

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.11.1.1 Authentifizierung von geplanten Konversationen
- KONF.11.6 Einschränkung unauthentifizierter Anschlüsse
- KONF.11.8.2 Einschränkung von TK-Verbindungen
- KONF.11.8.2.1 Einschränkung der TK-Gegenstellen
- KONF.12.11 Anonyme oder Pseudonyme Kommunikation
- KONF.12.12 Verbindungsprotokoll

Eintrag: Verzeichnisdienste

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- BER.3.22 Notfallzugang Verzeichnisdienst
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- KONF.12.1.8 Duplikate im Verzeichnisbaum

BSI/Grundschutz/Quellkataloge/Kernel

- BER.3.22 Notfallzugang Verzeichnisdienst
- DET.4.6.1 Verhaltensanalyse von Zugangskonten
- KONF.12.1.8 Duplikate im Verzeichnisbaum

Eintrag: Virtualisierungslösungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.7.3 Entwicklungs- und Testumgebungen
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.6.16 Datenaustausch in der Virtualisierung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.7.3 Entwicklungs- und Testumgebungen
- KONF.15.4 Überbuchung von virtualisierten Ressourcen
- KONF.6.16 Datenaustausch in der Virtualisierung

Eintrag: VK-Anwendungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.11.2 Warteraum
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.6.12 Konferenzmoderation

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.11.2 Warteraum
- KONF.12.8 Teilnahme per Default ohne Bild und Ton
- KONF.12.9 Information über Aufzeichnung
- KONF.6.12 Konferenzmoderation

Eintrag: Webanwendungen

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.11.5 Erraten von Zugriffslinks
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.10 Cookie-Attribute

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.11.5 Erraten von Zugriffslinks
- KONF.12.1.10 HTTP-Response-Header
- KONF.12.1.7 Filtern schädlicher Webinhalte
- KONF.12.10 Cookie-Attribute

Eintrag: Webbrowser

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.6 JavaScript
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung
- KONF.12.3 Cookies
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.12.6 Browser-Historie
- KONF.6.14 Browser Sandboxing
- KONF.6.15 Virtualisierte Browser-Umgebung

BSI/Grundschutz/Quellkataloge/Kernel

- KONF.12.1.1 Zertifikatsprüfung
- KONF.12.1.2 Content Security Policy (CSP)
- KONF.12.1.3 Same-Origin-Policy
- KONF.12.1.4 Subresource Integrity-Prüfung
- KONF.12.1.5 HTTP Strict Transport Security (HSTS)
- KONF.12.1.6 JavaScript
- KONF.12.2 Verschlüsselungsstatus der aktuellen Verbindung

- KONF.12.3 Cookies
- KONF.12.4 Speicherung von Zugangsdaten
- KONF.12.5 Auto-Vervollständigung von Daten
- KONF.12.6 Browser-Historie
- KONF.6.14 Browser Sandboxing
- KONF.6.15 Virtualisierte Browser-Umgebung

Eintrag: Webserver

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code

BSI/Grundschutz/Quellkataloge/Kernel

- DET.4.7 Auslaufen von Domains
- DET.4.8 Ausstellung neuer HTTPS-Zertifikate
- KONF.6.10 Auflistung von Verzeichnisinhalten
- KONF.6.11 Einschränkung von Uploads
- KONF.6.8 Berechtigungen des Webserver-Prozesses
- KONF.6.9 Zugriff auf Code

Eintrag: WLANs

BSI/Grundschutz/Anwenderkatalog/Grundschutz++

- ARCH.3.1 Netzabdeckung
- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.3.3 SSIDs
- ARCH.3.4 Verschlüsselte Netzanbindung

BSI/Grundschutz/Quellkataloge/Kernel

- ARCH.3.1 Netzabdeckung

- ARCH.3.2 Einschränkung in Sicherheitsbereichen
- ARCH.3.3 SSIDs
- ARCH.3.4 Verschlüsselte Netzanbindung

Namespace: topics

Eintrag: Abnahme

nicht unterstützt

Eintrag: Administration

nicht unterstützt

Eintrag: Analyse der interessierten Parteien

nicht unterstützt

Eintrag: Anforderungsergänzung

nicht unterstützt

Eintrag: Anforderungsmodellierung auf die Assets

nicht unterstützt

Eintrag: Asset-Modellierung

nicht unterstützt

Eintrag: Auditprogramm und -durchführung

nicht unterstützt

Eintrag: Aufgaben, Rollen, Zuständigkeiten

nicht unterstützt

Eintrag: Ausfallsicherheit

nicht unterstützt

Eintrag: Auswahl von Lieferanten

nicht unterstützt

Eintrag: Auswahl von Produkten und Dienstleistungen - Kündigung

nicht unterstützt

Eintrag: Auswahl von Produkten und Dienstleistungen - Zusammenarbeit

nicht unterstützt

Eintrag: Auswahl von Produkten und Dienstleistungen

nicht unterstützt

Eintrag: Authentifizierung

nicht unterstützt

Eintrag: Authentisierung

nicht unterstützt

Eintrag: Bedarfserfassung

nicht unterstützt

Eintrag: Behandlung von Compliance-Verstößen

nicht unterstützt

Eintrag: Berechtigungsmanagement

nicht unterstützt

Eintrag: Bereitstellung

nicht unterstützt

Eintrag: Bereitstellung und Betrieb

nicht unterstützt

Eintrag: Besondere Aufbauorganisation

nicht unterstützt

Eintrag: Bewertung der erreichten Verbesserung

nicht unterstützt

Eintrag: Bewertung fehlender Umsetzungen

nicht unterstützt

Eintrag: Bewertungsschema und Auditberichte

nicht unterstützt

Eintrag: Datensicherung

nicht unterstützt

Eintrag: Dedizierte Systeme

nicht unterstützt

Eintrag: Definition und Abgrenzung des Informationsverbunds

nicht unterstützt

Eintrag: Dekommissionierung von Dienstleistern

nicht unterstützt

Eintrag: Dokumentation und Kommunikation

nicht unterstützt

Eintrag: Durchführung der Risikobetrachtung

nicht unterstützt

Eintrag: Entwicklung einer Sicherheitsleitlinie

nicht unterstützt

Eintrag: Ermittlung des Umsetzungsstatus

nicht unterstützt

Eintrag: Erstellung eines Anforderungspakets

nicht unterstützt

Eintrag: Festlegung des Geltungsbereichs

nicht unterstützt

Eintrag: Festlegung des Kontextes der Institution

nicht unterstützt

Eintrag: Festlegung und Freigabe der Vorgehensweise

nicht unterstützt

Eintrag: Fortschrittsverfolgung der Realisierung

nicht unterstützt

Eintrag: Freigabe

nicht unterstützt

Eintrag: Freigabeverfahren

nicht unterstützt

Eintrag: Freigabeverfahren und Ausnahmemanagement

nicht unterstützt

Eintrag: Gemeinsame Arbeitsbereiche

nicht unterstützt

Eintrag: Gestaltungsentscheidungen

nicht unterstützt

Eintrag: Grundlagen

nicht unterstützt

Eintrag: Grundlegende Sensibilisierung

nicht unterstützt

Eintrag: Identifikation von Verbesserungspotenzialen

nicht unterstützt

Eintrag: Identitätsmanagement

nicht unterstützt

Eintrag: Implementierung des Compliance-Managements

nicht unterstützt

Eintrag: Initiierung des Risikomanagements

nicht unterstützt

Eintrag: Inventarisierung

nicht unterstützt

Eintrag: ISMS-Anforderungen des Informationsverbundes

nicht unterstützt

Eintrag: Kapazitätsmanagement

nicht unterstützt

Eintrag: Kompensierende Kontrollmechanismen

nicht unterstützt

Eintrag: Konfiguration von Anwendungen

nicht unterstützt

Eintrag: Konfiguration von Systemen

nicht unterstützt

Eintrag: Kontinuierliche Verbesserung

nicht unterstützt

Eintrag: Kontrolle von Dienstleistern

nicht unterstützt

Eintrag: Kontrollierte Datenverarbeitung

nicht unterstützt

Eintrag: Korrektur- und Verbesserungsplan

nicht unterstützt

Eintrag: Korrektur- und Verbesserungsvorschläge

nicht unterstützt

Eintrag: Leistungsbewertung des ISMS

nicht unterstützt

Eintrag: Löschen und Vernichten

nicht unterstützt

Eintrag: Management von Schwachstellen

nicht unterstützt

Eintrag: Managementbewertungen

nicht unterstützt

Eintrag: Meldung von Ereignissen

nicht unterstützt

Eintrag: Mobiles Arbeiten

nicht unterstützt

Eintrag: Monitoringmethoden und -tools

nicht unterstützt

Eintrag: Nachbereitung

nicht unterstützt

Eintrag: Netzdesign

nicht unterstützt

Eintrag: Notfallvorsorge

nicht unterstützt

Eintrag: Nutzung von digitalen Dienstleistungen

nicht unterstützt

Eintrag: Passwortgebrauch

nicht unterstützt

Eintrag: Perimeterschutz

nicht unterstützt

Eintrag: Personalbetreuung

nicht unterstützt

Eintrag: Personalentwicklung

nicht unterstützt

Eintrag: Personalzugang

nicht unterstützt

Eintrag: Physische Sicherheit

nicht unterstützt

Eintrag: Physischer Perimeter

nicht unterstützt

Eintrag: Physischer Schutz

nicht unterstützt

Eintrag: Physischer Zutritt

nicht unterstützt

Eintrag: Platzierung von Assets

nicht unterstützt

Eintrag: Protokollierung

nicht unterstützt

Eintrag: Prozess der Informationssicherheitseinstufung

nicht unterstützt

Eintrag: Reaktion

nicht unterstützt

Eintrag: Regelungen zum Gebrauch

nicht unterstützt

Eintrag: Regelungen zum Transfer

nicht unterstützt

Eintrag: Ressourcenauslastung

nicht unterstützt

Eintrag: Risiko

nicht unterstützt

Eintrag: Rollen und Berechtigungen

nicht unterstützt

Eintrag: Rücknahme von Assets

nicht unterstützt

Eintrag: Schlüsselmanagement

nicht unterstützt

Eintrag: Schlüsselverwaltung

nicht unterstützt

Eintrag: Schutz vor Elementarschäden

nicht unterstützt

Eintrag: Schutz vor Schadcode

nicht unterstützt

Eintrag: Schutz vor Schadprogrammen

nicht unterstützt

Eintrag: Senden und Empfangen von Nachrichten

nicht unterstützt

Eintrag: Sensibilisierung der Leitungsebene

nicht unterstützt

Eintrag: Sicherheitsbereiche

nicht unterstützt

Eintrag: Sicherheitsorganisation und Rollen

nicht unterstützt

Eintrag: Sicherheitsupdates

nicht unterstützt

Eintrag: Softwareentwicklung - Code

nicht unterstützt

Eintrag: Softwareentwicklung - Härtung

nicht unterstützt

Eintrag: Softwareentwicklung - Security by Design

nicht unterstützt

Eintrag: Softwareentwicklung - Updates

nicht unterstützt

Eintrag: Spezifische Risiken

nicht unterstützt

Eintrag: Tests

nicht unterstützt

Eintrag: Überprüfung des gesetzten Sicherheitsniveaus

nicht unterstützt

Eintrag: Überwachung der Compliance

nicht unterstützt

Eintrag: Überwachung von Aktivitäten

nicht unterstützt

Eintrag: Umgang mit Datenträgern

nicht unterstützt

Eintrag: Umgang mit Informationen

nicht unterstützt

Eintrag: Umgang mit Nicht-Konformitäten

nicht unterstützt

Eintrag: Umgang mit spezifischen Zielobjekten

nicht unterstützt

Eintrag: Umsetzungsplanung und Priorisierung

nicht unterstützt

Eintrag: Validierung der Anforderungen

nicht unterstützt

Eintrag: Verfügbarkeit von Ressourcen

nicht unterstützt

Eintrag: Versorgungseinrichtungen

nicht unterstützt

Eintrag: Verteilte Anwendungen

nicht unterstützt

Eintrag: Vertrauensbeziehungen

nicht unterstützt

Eintrag: Vertrauenswürdige Basisdienste

nicht unterstützt

Eintrag: Vertraulichkeit und Integrität im Weitverkehrsnetz

nicht unterstützt

Eintrag: Verwahrung von Speichermedien

nicht unterstützt

Eintrag: Vorbereitung

nicht unterstützt

Eintrag: Vorfallserkennung

nicht unterstützt

Eintrag: Wahrung von Compliance in der Umsetzung

nicht unterstützt

Eintrag: Wartung

nicht unterstützt

Eintrag: Weggang von Mitarbeitenden

nicht unterstützt

Eintrag: Wireless LAN

nicht unterstützt

Eintrag: Wirksamkeitsprüfung

nicht unterstützt

Eintrag: Zugangsbeschränkungen

nicht unterstützt

Eintrag: Zugangskonten

nicht unterstützt

Eintrag: Zuständigkeiten und Umsetzungsfristen

nicht unterstützt